

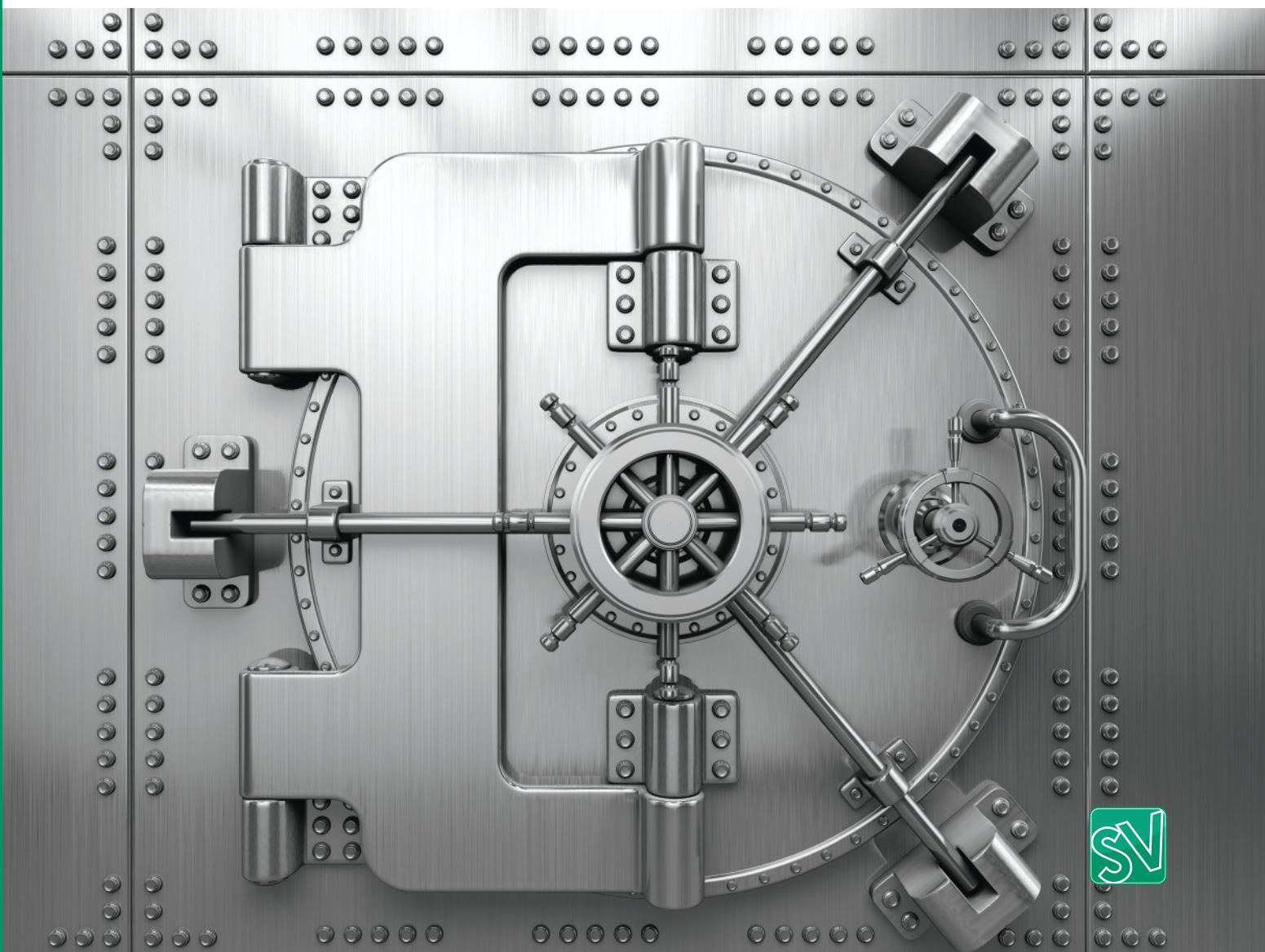
William Stallings

CRIPTOGRAFIA

e segurança de redes

PRINCÍPIOS E PRÁTICAS

6ª EDIÇÃO

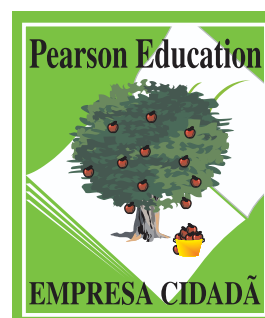


CRIPTOGRAFIA

e segurança de redes

PRINCÍPIOS E PRÁTICAS

Este é o código de acesso para
o material complementar que
acompanha o livro, disponível na
Sala Virtual (sv.pearson.com.br):



William Stallings

CRIPTOGRAFIA

e segurança de redes

PRINCÍPIOS E PRÁTICAS

6ª EDIÇÃO

Tradução

Daniel Vieira

Revisão técnica

Paulo Sérgio Licciardi Messeder Barreto

Professor doutor na Poli-USP

Rafael Misoczki

Doutor pela Universidade de Paris

PEARSON

abdr
ASSOCIAÇÃO
BRASILEIRA
DE DIREITOS
REPROGRÁFICOS
Respeite o direito autoral

© 2015 by Pearson Education do Brasil

Todos os direitos reservados. Nenhuma parte desta publicação poderá ser reproduzida ou transmitida de qualquer modo ou por qualquer outro meio, eletrônico ou mecânico, incluindo fotocópia, gravação ou qualquer outro tipo de sistema de armazenamento e transmissão de informação, sem prévia autorização, por escrito, da Pearson Education do Brasil.

SUPERVISORA DE PRODUÇÃO EDITORIAL	Silvana Afonso
COORDENADOR DE PRODUÇÃO EDITORIAL	Sérgio Nascimento
EDITOR DE AQUISIÇÕES	Vinícius Souza
EDITORA DE TEXTO	Ana Mendes e Daniela Braz
EDITOR ASSISTENTE	Marcos Guimarães
PREPARAÇÃO	Renata Truys
REVISÃO	Sabrina Feldman
CAPA	Rita Ralha
DIAGRAMAÇÃO	Casa de Ideias

Dados Internacionais de Catalogação na Publicação (CIP)
(Câmara Brasileira do Livro, SP, Brasil)

Stallings, William
Criptografia e segurança de redes: princípios e práticas / William Stallings; tradução Daniel Vieira; revisão técnica Paulo Sérgio Licciardi Messeder Barreto, Rafael Misoczki. – 6. ed. – São Paulo: Pearson Education do Brasil, 2015.

Título original: *Cryptography and network security*
ISBN 978-85-430-1450-0

1. Computadores - Segurança 2. Criptografia 3. Dados - Proteção I. Barreto, Paulo Sérgio Licciardi Messeder. II. Misoczki, Rafael. III. Título.

14-05439

CDD-005.82

Índice para catálogo sistemático:

1. Criptografia: Dados : Segurança:
Computadores : Processamento de dados
005.82

2014

Direitos exclusivos para a língua portuguesa cedidos à
Pearson Education do Brasil Ltda.,
uma empresa do grupo Pearson Education
Rua Nelson Francisco, 26
CEP 02712-100 – São Paulo – SP – Brasil
Fone: 11 2178-8686 – Fax: 11 2178-8688
vendas@pearson.com

Sumário

Notação	xi
---------	----

Apresentação	xiii
--------------	------

 00 Guia para leitores e instrutores	1
--	----------

0.1	ESBOÇO DO LIVRO	1
0.2	ROTEIRO PARA LEITORES E INSTRUTORES	2
0.3	INTERNET E RECURSOS DA WEB	3
0.3	PADRÕES	4

 01 Introdução	5
--	----------

1.1	CONCEITOS DE SEGURANÇA DE COMPUTADORES	6
1.2	A ARQUITETURA DE SEGURANÇA OSI	10
1.3	ATAQUES À SEGURANÇA	11
1.4	SERVIÇOS DE SEGURANÇA	12
1.5	MECANISMOS DE SEGURANÇA	15
1.6	UM MODELO PARA SEGURANÇA DE REDE	16
1.7	LEITURA RECOMENDADA	18
1.8	PRINCIPAIS TERMOS, PERGUNTAS PARA REVISÃO E PROBLEMAS	19

PARTE 1: CIFRAS SIMÉTRICAS	20
-----------------------------------	-----------

 02 Técnicas clássicas de encriptação	20
---	-----------

2.1	MODELO DE CIFRA SIMÉTRICA	21
2.2	TÉCNICAS DE SUBSTITUIÇÃO	25
2.3	TÉCNICAS DE TRANSPOSIÇÃO	37
2.4	MÁQUINAS DE ROTOR	38
2.5	ESTEGANOGRAFIA	39
2.6	LEITURA RECOMENDADA	40
2.7	PRINCIPAIS TERMOS, PERGUNTAS PARA REVISÃO E PROBLEMAS	41

03	Cifras de bloco e o data encryption standard	45
3.1	ESTRUTURA TRADICIONAL DE CIFRA DE BLOCO	46
3.2	DATA ENCRYPTION STANDARD	54
3.3	UM EXEMPLO DO DES	55
3.4	A FORÇA DO DES	58
3.5	PRINCÍPIOS DE PROJETO DE CIFRA DE BLOCO	59
3.6	LEITURA RECOMENDADA	60
3.7	PRINCIPAIS TERMOS, PERGUNTAS PARA REVISÃO E PROBLEMAS	61
04	Conceitos básicos de teoria dos números e corpos finitos	64
4.1	DIVISIBILIDADE E O ALGORITMO DE DIVISÃO	65
4.2	ALGORITMO DE EUCLIDES	67
4.3	ARITMÉTICA MODULAR	69
4.4	GRUPOS, ANÉIS E CORPOS	76
4.5	CORPOS FINITOS NA FORMA $GF(P)$	79
4.6	ARITMÉTICA DE POLINÔMIOS	81
4.7	CORPOS FINITOS NA FORMA $GF(2^N)$	86
4.9	PRINCIPAIS TERMOS, PERGUNTAS PARA REVISÃO E PROBLEMAS	96
4.8	LEITURA RECOMENDADA	96
APÊNDICE 4A	SIGNIFICADO DE MOD	99
05	Advanced Encryption Standard	101
5.1	ARITMÉTICA DE CORPO FINITO	102
5.2	ESTRUTURA DO AES	103
5.3	FUNÇÕES DE TRANSFORMAÇÃO DO AES	107
5.4	EXPANSÃO DE CHAVE DO AES	116
5.5	EXEMPLO DE AES	118
5.6	IMPLEMENTAÇÃO DO AES	122
5.7	LEITURA RECOMENDADA	125
5.8	PRINCIPAIS TERMOS, PERGUNTAS PARA REVISÃO E PROBLEMAS	125
APÊNDICE 5A	POLINÔMIOS COM COEFICIENTES EM $GF(28)$	127
APÊNDICE 5B	AES SIMPLIFICADO	129
06	Operação de cifra de bloco	136
6.1	ENCRIPTAÇÃO MÚLTIPLA E TRIPLE DES	137
6.2	MODO ELECTRONIC CODEBOOK	141
6.3	MODO CIPHER BLOCK CHAINING	143
6.4	MODO CIPHER FEEDBACK	145
6.5	MODO OUTPUT FEEDBACK	146
6.6	MODO COUNTER	148

6.7	MODO XTS-AES PARA DISPOSITIVOS DE ARMAZENAMENTO ORIENTADOS A BLOCO	151
6.8	LEITURA RECOMENDADA	155
6.9	PRINCIPAIS TERMOS, PERGUNTAS PARA REVISÃO E PROBLEMAS	155



07 Geração de número pseudoaleatório e cifras de fluxo 159

7.1	PRINCÍPIOS DE GERAÇÃO DE NÚMEROS PSEUDOALEATÓRIOS	160
7.2	GERADORES DE NÚMEROS PSEUDOALEATÓRIOS	165
7.3	GERADORES DE NÚMEROS PSEUDOALEATÓRIOS COM UMA CIFRA DE BLOCO	167
7.4	CIFRAS DE FLUXO	172
7.5	RC4	173
7.6	GERADORES DE NÚMEROS ALEATÓRIOS VERDADEIROS	175
7.7	LEITURA RECOMENDADA	179
7.8	PRINCIPAIS TERMOS, PERGUNTAS PARA REVISÃO E PROBLEMAS	180

PARTE 2: CIFRAS ASSIMÉTRICAS 182



08 Mais teoria dos números 182

8.1	NÚMEROS PRIMOS	183
8.2	TEOREMAS DE FERMAT E EULER	185
8.3	TESTE DE PRIMALIDADE	188
8.4	O TEOREMA CHINÊS DO RESTO	190
8.5	LOGARITMOS DISCRETOS	191
8.6	LEITURA RECOMENDADA	195
8.7	PRINCIPAIS TERMOS, PERGUNTAS PARA REVISÃO E PROBLEMAS	196



09 Criptografia de chave pública e RSA 199

9.1	PRINCÍPIOS DE CRIPTOSSISTEMAS DE CHAVE PÚBLICA	201
9.2	ALGORITMO RSA	207
9.3	LEITURA RECOMENDADA	218
9.4	PRINCIPAIS TERMOS, PERGUNTAS PARA REVISÃO E PROBLEMAS	219
APÊNDICE 20A A COMPLEXIDADE DOS ALGORITMOS		223



10 Outros criptossistemas de chave pública 225

10.1	TROCA DE CHAVES DIFFIE-HELLMAN	226
10.2	SISTEMA CRIPTOGRÁFICO ELGAMAL	229
10.3	ARITMÉTICA DE CURVA ELÍPTICA	232
10.4	CRIPTOGRAFIA DE CURVA ELÍPTICA	239
10.5	GERAÇÃO DE NÚMERO PSEUDOALEATÓRIO BASEADA EM UMA CIFRA ASSIMÉTRICA	241
10.6	LEITURA RECOMENDADA	243
10.7	PRINCIPAIS TERMOS, PERGUNTAS PARA REVISÃO E PROBLEMAS	243

PARTE 3: ALGORITMOS CRIPTOGRÁFICOS PARA INTEGRIDADE DE DADOS 246

11 Funções de hash criptográficas 246

11.1	APLICAÇÕES DE FUNÇÕES DE HASH CRIPTOGRÁFICAS	247
11.2	DUAS FUNÇÕES DE HASH SIMPLES	251
11.3	REQUISITOS E SEGURANÇA	253
11.4	FUNÇÕES DE HASH BASEADAS EM CIPHER BLOCK CHAINING	258
11.5	SECURE HASH ALGORITHM (SHA)	258
11.6	SHA-3	266
11.7	LEITURA RECOMENDADA	276
11.8	PRINCIPAIS TERMOS, PERGUNTAS PARA REVISÃO E PROBLEMAS	276

12 Códigos de autenticação de mensagem 280

12.1	REQUISITOS DE AUTENTICAÇÃO DE MENSAGEM	281
12.2	FUNÇÕES DE AUTENTICAÇÃO DE MENSAGEM	282
12.3	REQUISITOS PARA CÓDIGOS DE AUTENTICAÇÃO DE MENSAGEM	287
12.4	SEGURANÇA DE MACs	289
12.5	MACs BASEADOS EM FUNÇÕES DE HASH: HMAC	290
12.6	MACs BASEADOS EM CIFRAS DE BLOCO: DAA E CMAC	293
12.7	ENCRIPTAÇÃO AUTENTICADA: CCM E GCM	295
12.8	KEY WRAPPING	300
12.9	GERAÇÃO DE NÚMERO PSEUDOALEATÓRIO USANDO FUNÇÕES DE HASH E MACs	304
12.10	LEITURA RECOMENDADA	306
12.11	PRINCIPAIS TERMOS, PERGUNTAS PARA REVISÃO E PROBLEMAS	307

13 Assinaturas digitais 309

13.1	ASSINATURAS DIGITAIS	310
13.2	ESQUEMA DE ASSINATURA DIGITAL ELGAMAL	313
13.3	ESQUEMA DE ASSINATURA DIGITAL SCHNORR	314
13.4	ALGORITMO DE ASSINATURA DIGITAL DO NIST	315
13.5	ALGORITMO DE ASSINATURA DIGITAL DE CURVA ELÍPTICA	317
13.6	ALGORITMO DE ASSINATURA DIGITAL RSA-PSS	320
13.7	LEITURA RECOMENDADA	323
13.8	PRINCIPAIS TERMOS, PERGUNTAS PARA REVISÃO E PROBLEMAS	324

14 Gerenciamento e distribuição de chaves 327

14.1	DISTRIBUIÇÃO DE CHAVE SIMÉTRICA USANDO ENCRIPTAÇÃO SIMÉTRICA	328
14.2	DISTRIBUIÇÃO DE CHAVE SIMÉTRICA USANDO ENCRIPTAÇÃO ASSIMÉTRICA	335
14.3	DISTRIBUIÇÃO DE CHAVES PÚBLICAS	337
14.4	CERTIFICADOS X.509	341

14.5	INFRAESTRUTURA DE CHAVE PÚBLICA	347
14.6	LEITURA RECOMENDADA	349
14.7	PRINCIPAIS TERMOS, PERGUNTAS PARA REVISÃO E PROBLEMAS	350



Autenticação do usuário

353

15.1	PRINCÍPIOS DE AUTENTICAÇÃO DE USUÁRIO REMOTO	354
15.2	AUTENTICAÇÃO DE USUÁRIO REMOTO USANDO ENCRIPTAÇÃO SIMÉTRICA	356
15.3	KERBEROS	359
15.4	AUTENTICAÇÃO DE USUÁRIO REMOTO USANDO ENCRIPTAÇÃO ASSIMÉTRICA	373
15.5	GERENCIAMENTO DE IDENTIDADES FEDERADAS	375
15.6	VERIFICAÇÃO DE IDENTIDADE PESSOAL	380
15.7	LEITURA RECOMENDADA	385
15.8	PRINCIPAIS TERMOS, PERGUNTAS PARA REVISÃO E PROBLEMAS	385



Controle de acesso à rede e segurança na nuvem

388

16.1	CONTROLE DE ACESSO À REDE	389
16.2	EXTENSIBLE AUTHENTICATION PROTOCOL (EAP)	391
16.3	CONTROLE DE ACESSO À REDE BASEADO EM PORTA IEEE 802.1X	394
16.4	COMPUTAÇÃO EM NUVEM	396
16.5	RISCOS E CONTRAMEDIDAS DE SEGURANÇA NA NUVEM	401
16.6	PROTEÇÃO DE DADOS NA NUVEM	402
16.7	SEGURANÇA NA NUVEM COMO UM SERVIÇO	405
16.8	LEITURA RECOMENDADA	408
16.9	PRINCIPAIS TERMOS, PERGUNTAS PARA REVISÃO E PROBLEMAS	408



Segurança na camada de transporte

410

17.1	CONSIDERAÇÕES SOBRE SEGURANÇA NA WEB	411
17.2	SECURE SOCKETS LAYER	413
17.3	TRANSPORT LAYER SECURITY	423
17.4	HTTPS	427
17.5	SECURE SHELL (SSH)	428
17.6	LEITURA RECOMENDADA	437
17.7	PRINCIPAIS TERMOS, PERGUNTAS PARA REVISÃO E PROBLEMAS	437



Segurança em rede wireless

439

18.1	SEGURANÇA EM REDE WIRELESS	440
18.2	SEGURANÇA DE DISPOSITIVO MÓVEL	442
18.3	VISÃO GERAL DA LAN WIRELESS IEEE 802.11	446
18.4	SEGURANÇA DA LAN WIRELESS IEEE 802.11	451
18.5	LEITURA RECOMENDADA	462
18.6	PRINCIPAIS TERMOS, PERGUNTAS PARA REVISÃO E PROBLEMAS	462

19 Segurança do correio eletrônico 465

19.1	PRETTY GOOD PRIVACY	466
19.2	S/MIME	470
19.3	DOMAINKEYS IDENTIFIED MAIL	484
19.4	LEITURA RECOMENDADA	490
19.5	PRINCIPAIS TERMOS, PERGUNTAS PARA REVISÃO E PROBLEMAS	490
APÊNDICE 19A CONVERSÃO RADIX-64		491

20 Segurança IP 493

20.1	VISÃO GERAL DA SEGURANÇA IP	494
20.2	POLÍTICA DE SEGURANÇA IP	497
20.3	ENCAPSULANDO O PAYLOAD DE SEGURANÇA	502
20.4	COMBINANDO ASSOCIAÇÕES DE SEGURANÇA	508
20.5	TROCA DE CHAVES NA INTERNET	511
20.6	PACOTES CRIPTOGRÁFICOS	518
20.7	LEITURA RECOMENDADA	519
20.8	PRINCIPAIS TERMOS, PERGUNTAS PARA REVISÃO E PROBLEMAS	519

Apêndice A 521

PROJETOS PARA O ENSINO DE CRIPTOGRAFIA E SEGURANÇA DE REDE		521
A.1	PROJETOS EM SAGE COMPUTER ALGEBRA	522
A.2	PROJETOS DE HACKING	522
A.3	PROJETOS DE CIFRA DE BLOCO	523
A.4	EXERCÍCIOS DE LABORATÓRIO	523
A.5	PROJETOS DE PESQUISA	523
A.6	PROJETOS DE PROGRAMAÇÃO	524
A.7	AVALIAÇÕES PRÁTICAS DE SEGURANÇA	524
A.8	PROJETOS DE FIREWALL	524
A.9	ESTUDOS DE CASO	525
A.10	TRABALHOS ESCRITOS	525
A.11	TRABALHOS DE LEITURA/RELATÓRIO	525
A.12	TÓPICOS PARA DISCUSSÃO	525

Referências 526

ABREVIACÕES	526
-------------	-----

Créditos 536

Índice remissivo 541

Notação

Até mesmo os nativos têm dificuldade para dominar este vocabulário peculiar.

– *O Ramo Dourado*, Sir James George Frazer

Símbolo	Expressão	Significado
D, K	$D(K, Y)$	Decriptografia simétrica do texto cifrado Y usando a chave secreta K
D, PR_a	$D(PR_a, Y)$	Decriptografia assimétrica do texto cifrado Y usando a chave privada de A PR_a
D, PU_a	$D(PU_a, Y)$	Decriptografia assimétrica do texto cifrado Y usando a chave pública de A PU_a
E, K	$E(K, X)$	Criptografia simétrica do texto claro X usando a chave secreta K
E, PR_a	$E(PR_a, X)$	Criptografia assimétrica do texto claro X usando a chave privada de A PR_a
E, PU_a	$E(PU_a, X)$	Criptografia assimétrica do texto claro X usando a chave pública de A PU_a
K		Chave secreta
PR_a		Chave privada do usuário A
PU_a		Chave pública do usuário A
MAC, K	$MAC(K, X)$	Código de autenticação de mensagem da mensagem X usando a chave secreta K
$GF(p)$		O campo finito de ordem p , onde p é primo. O campo é definido como o conjunto Z_p junto com as operações aritméticas módulo p .
$GF(2^n)$		O campo finito de ordem 2^n
Z_n		Conjunto de inteiros não negativos menores que n
$\gcd$	$\gcd(i, j)$	Máximo divisor comum; o maior inteiro positivo que divide i e j sem resto na divisão.
mod	$a \text{ mod } m$	Resto após divisão de a por m
$\text{mod}, \equiv$	$a \equiv b \pmod{m}$	$a \text{ mod } m = b \text{ mod } m$
$\text{mod}, \not\equiv$	$a \not\equiv b \pmod{m}$	$a \text{ mod } m \neq b \text{ mod } m$
dlog	$\text{dlog}_{a, p}(b)$	Logaritmo discreto do número b para a base $a \pmod{p}$
φ	$\phi(n)$	O número de inteiros positivos menores que n e relativamente primos de n . Esta é a função totiente de Euler.
Σ	$\sum_{i=1}^n a_i$	$a_1 + a_2 + \dots + a_n$
Π	$\prod_{i=1}^n a_i$	$a_1 \times a_2 \times \dots \times a_n$

Símbolo	Expressão	Significado
$ $	$i j$	i divide j , o que significa que não existe resto quando j é dividido por i
$ \cdot $	$ a $	Valor absoluto de a
$\ $	$x \ y$	x concatenado com y
$\approx$	$x \approx y$	x é aproximadamente igual a y
$\oplus$	$x \oplus y$	OU exclusivo de x e y para variáveis de único bit; OU exclusivo bit a bit de x e y para variáveis de múltiplos bits
$\lfloor \cdot \rfloor$	$\lfloor x \rfloor$	O maior inteiro menor ou igual a x
$\in$	$x \in S$	O elemento x está contido no conjunto S .
$\leftrightarrow$	$A \leftrightarrow (a_1, a_2, \dots, a_k)$	O inteiro A corresponde à sequência de inteiros $(a_1, a_2, \dots, a_k)$

Apresentação

“Há o livro, inspetor. Deixo-o com você, e não duvide que ele contém uma explicação completa.”

— *A Aventura da Juba do Leão*, Sir Arthur Conan Doyle

O que há de novo na sexta edição

Nos quatro anos desde que a quinta edição deste livro foi publicada, o campo tem visto inovações e melhorias contínuas. Nesta nova edição, tento capturar essas mudanças mantendo uma cobertura ampla e abrangente do campo inteiro. Para iniciar esse processo de revisão, a quinta edição deste livro foi extensivamente revisada por diversos professores que lecionam no assunto e por profissionais que trabalham no setor. O resultado é que, em muitos lugares, a narrativa foi esclarecida e encurtada, e ilustrações foram aperfeiçoadas.

Além desses refinamentos para melhorar a facilidade de utilização e pedagogia, houve mudanças substanciais ao longo do livro. Mantivemos praticamente a mesma organização do capítulo, mas grande parte do material foi revisado e novo material foi adicionado. As mudanças mais notáveis são as seguintes:

- **Controle de acesso de rede:** um novo capítulo oferece cobertura de controle de acesso de rede, incluindo uma visão geral mais discussões do protocolo de autenticação extensível (Extensible Authentication Protocol) e IEEE 802.1X.
- **Segurança em nuvem:** uma nova seção aborda os problemas de segurança relacionados à nova e interessante área de computação em nuvem.
- **SHA-3:** uma nova seção aborda o novo padrão de hash criptográfico, SHA-3, que foi adotado em 2012.
- **Key wrapping:** o uso de *key wrapping* para proteger chaves simétricas foi adotado em diversas aplicações. Uma nova seção aborda esse assunto.
- **Algoritmo de assinatura digital de curva elíptica (ECDSA):** como o ECDSA (Elliptic Curve Digital Signature Algorithm) é mais eficiente do que outros esquemas de assinatura digital, ele está sendo cada vez mais adotado para aplicações de assinatura digital. Uma nova seção aborda ECDSA.
- **RSA Probabilistic Signature Scheme (RSA-PSS):** esquemas de assinatura digital baseados em RSA talvez sejam os mais utilizados. Uma nova seção aborda o RSA-PSS padronizado recentemente, que está no processo de substituição dos esquemas mais antigos, baseados em RSA.
- **Gerador de números aleatórios verdadeiros:** os geradores de números aleatórios tradicionalmente tiveram um papel limitado, devido à sua baixa taxa de bits, mas uma nova geração de geradores de números aleatórios verdadeiros por hardware agora está disponível e se compara em desempenho aos geradores de números pseudoaleatórios por software. Uma nova seção aborda esse assunto e discute o Digital Random Number Generator (DRNG) da Intel.
- **Verificação de identidade pessoal (PIV):** o NIST emitiu um conjunto abrangente de padrões para autenticação de usuário baseada em *smartcard*, que está sendo bastante adotado. Uma nova seção aborda PIV.

- **Segurança de dispositivo móvel:** a segurança de dispositivo móvel tornou-se um aspecto essencial da segurança de rede corporativa. Uma nova seção aborda esse importante assunto.
- **Software malicioso:** este capítulo oferece um foco diferente do capítulo sobre software malicioso na edição anterior. Cada vez mais vemos o malware do tipo backdoor/rootkit instalado por ataques de engenharia social, em vez de uma infecção direta, mais clássica, dos vírus/vermes. E o *phishing* está mais proeminente do que nunca. Essas tendências são refletidas no tratamento do assunto.
- **Exemplo de plano de estudos:** o texto contém mais material do que pode ser abordado de modo conveniente em um semestre. Por conseguinte, os instrutores recebem diversos planos de estudo de exemplo, que orientam o uso do texto dentro de um tempo limitado (por exemplo, 16 semanas ou 12 semanas). Esses exemplos são baseados na experiência do mundo real pelos professores na quinta edição.
- **VideoNotes sobre exemplos do Sage:** a nova edição acompanha uma série de palestras de VideoNotes que aumentam e esclarecem os exemplos criptográficos apresentados no Apêndice B, que introduz o Sage.
- **Objetivos de aprendizagem:** cada capítulo agora começa com uma lista de objetivos de aprendizagem.

Objetivos

Este livro tem por finalidade oferecer um estudo prático dos princípios e processos da criptografia e da segurança de redes. Na primeira parte, as questões básicas a serem focalizadas por uma capacidade de segurança de redes são exploradas oferecendo-se um tutorial e um estudo da tecnologia de criptografia e segurança de redes. A última parte trata dos processos de segurança de redes: aplicações práticas que têm sido implementadas e estão sendo usadas para proporcionar segurança de redes.

O assunto (e, portanto, este livro) se baseia em diversas disciplinas. Em particular, é impossível apreciar o significado de algumas das técnicas discutidas nesta obra sem um conhecimento básico da teoria dos números e alguns resultados da teoria da probabilidade. Apesar disso, tentamos tornar o livro autocontido. Ele apresenta não apenas os resultados matemáticos básicos que são necessários, mas também oferece ao leitor um conhecimento intuitivo desses resultados. Esse material de base é apresentado conforme a necessidade. Essa abordagem ajuda a motivar o material que é introduzido, e o autor considera isso preferível a simplesmente apresentar todo o material matemático de uma só vez no início da obra.

Suporte dos currículos de ciência da computação da ACM/IEEE 2013

A obra é voltada para audiências acadêmicas e profissionais. Como um livro-texto, ele serve como um curso de graduação de um semestre em criptografia e segurança de redes para as carreiras de ciência da computação, engenharia da computação e engenharia elétrica. As mudanças nesta edição têm por finalidade fornecer um suporte da versão atual de rascunho do ACM/ IEEE Computer Science Curricula 2013 (CS2013). O CS2013 acrescenta Garantia e Segurança da Informação (IAS) à recomendação curricular como uma das Áreas de Conhecimento no Corpo de Conhecimento da Ciência da Computação. O documento afirma que a IAS agora faz parte da recomendação curricular devido ao seu papel crítico no estudo da ciência da computação. O CS2013 divide o trabalho do curso inteiro em três categorias: Camada Núcleo 1 (todos os tópicos deverão ser incluídos no currículo), Camada Núcleo 2 (todos ou quase todos os tópicos deverão ser incluídos), e eletivo (desejável para oferecer amplitude e profundidade). Na área de IAS, o CS2013 recomenda tópicos nos Conceitos Fundamentais e Segurança de Rede na Camada 1 e na Camada 2, e tópicos de Criptografia como eletivos. Este texto aborda praticamente todos os tópicos listados pelo CS2013 nessas três categorias.

O livro também serve como um volume básico de referência e é adequado para o autoestudo.

Plano do texto

O livro está dividido em sete partes, que são descritas no Capítulo 0.

- Cifras simétricas
- Cifras assimétricas
- Algoritmos de integridade criptográfica de dados
- Confiança mútua
- Rede e segurança na Internet

- Segurança de sistemas (Disponível na Sala Virtual)
- Questões legais e éticas (Disponível na Sala Virtual)

O livro contém uma série de recursos pedagógicos, incluindo a utilização do sistema de álgebra de computador Sage e diversas figuras e tabelas para esclarecer as discussões. Cada capítulo conta com uma lista de palavras-chave, perguntas de revisão, problemas de lição de casa e sugestões de leitura complementar. A obra também inclui um extenso glossário, uma lista de acrônimos usados com frequência e uma bibliografia.



A Sala Virtual (sv.pearson.com.br) oferece recursos adicionais que auxiliarão professores e alunos na exposição das aulas e no processo de aprendizagem.

Para o professor:

- Apresentações em PowerPoint.
- Galeria de imagens.
- Manual de soluções (em inglês).

Para o estudante:

- Exercícios de múltipla escolha.
- Capítulos adicionais (em inglês).
- Apêndices (em inglês).
- Manual de projetos (em inglês).
- Links úteis.

Projetos e outros exercícios para estudantes

Para muitos instrutores, um componente importante de um curso de criptografia ou segurança de redes é um projeto ou conjunto de projetos pelo qual o aluno obtém experiência prática para reforçar os conceitos do texto. Este livro oferece um grau de suporte sem paralelo, incluindo um componente de projetos no curso. O IRC não apenas inclui orientação sobre como atribuir e estruturar os projetos, mas também contém um conjunto de tarefas de projeto que aborda uma grande gama de tópicos do texto:

- **Projetos do Sage:** descritos na próxima seção.
- **Projeto de hacking:** exercício criado para esclarecer as principais questões sobre detecção e prevenção de intrusão.
- **Projetos de cifra em bloco:** um laboratório que explora a operação do algoritmo de criptografia AES, rastreando sua execução, calculando uma rodada a mão e depois explorando os diversos modos de uso da cifra em bloco. A largura de banda também aborda o DES. Nos dois casos, um applet Java on-line é utilizado (ou pode ser baixado) para executar o AES ou DES.
- **Exercícios de laboratório:** uma série de projetos que envolvem programação e experiência com os conceitos do livro.
- **Projetos de pesquisa:** uma série de trabalhos de pesquisa que instrui o aluno a pesquisar um assunto em particular na Internet e escrever um relatório.
- **Projetos de programação:** uma série de projetos de programação que aborda uma grande variedade de tópicos e que podem ser implementados em uma linguagem adequada em qualquer plataforma.
- **Avaliações práticas de segurança:** um conjunto de exercícios para examinar a infraestrutura e as práticas atuais de uma organização existente.
- **Projetos de firewall:** um simulador de visualização de firewall de rede portátil, juntamente com exercícios para ensino dos fundamentos dos firewalls.
- **Estudos de caso:** um conjunto de estudos de caso do mundo real, incluindo objetivos de aprendizagem, descrição de caso e uma série de perguntas de discussão do caso.
- **Trabalhos escritos:** um conjunto de trabalhos escritos sugeridos, organizados por capítulo.

- **Trabalhos de leitura/relatório:** uma lista de artigos na literatura, um para cada capítulo, que podem ser designados para o aluno ler e depois escrever um pequeno relatório.

Este conjunto diversificado de projetos e outros exercícios do aluno permite que o instrutor use o livro como um componente em uma rica e variada experiência de aprendizagem e personalize um plano de curso para atender as necessidades específicas do instrutor e dos alunos. Consulte o Apêndice A deste livro para obter os detalhes.

Sistema de álgebra de computador Sage

Um dos recursos mais importantes desta obra é o uso do Sage para exemplos criptográficos e trabalhos para casa. Sage é um pacote de fonte aberto, multiplataforma e freeware, que implementa um sistema matemático e de álgebra de computador muito poderoso, flexível e facilmente compreendido. Diferente dos sistemas concorrentes (como Mathematica, Maple e MATLAB), não há envolvimento de acordos de licença ou taxas. Assim, o Sage pode ser utilizado em computadores e redes na escola, e os estudantes podem baixar o software individualmente para seus próprios computadores pessoais, para uso em casa. Outra vantagem do uso do Sage é que os estudantes aprendem uma ferramenta poderosa e flexível, que pode ser usada para praticamente qualquer aplicação matemática, não apenas criptografia.

O uso do Sage pode fazer uma diferença significativa para o aprendizado da matemática de algoritmos criptográficos. Este livro oferece um grande número de exemplos do uso do Sage, abordando muitos conceitos criptográficos no Apêndice B, que está incluído neste livro.

O Apêndice C (na Sala Virtual, em inglês) lista exercícios em cada uma das áreas, para permitir que o estudante obtenha experiência prática com algoritmos criptográficos. Esse apêndice está disponível para instrutores no IRC para este livro. O Apêndice C inclui uma seção sobre como baixar e começar a usar o Sage, uma seção sobre programação com Sage e exercícios que podem ser atribuídos a estudantes nas seguintes categorias:

- **Capítulo 2 – Criptografia clássica:** Cifras afins e a cifra de Hill.
- **Capítulo 3 – Cifras de bloco e o Data Encryption Standard:** Exercícios baseados no SDDES.
- **Capítulo 4 – Conceitos básicos em teoria dos números e campos finitos:** Algoritmo de Euclides e Euclides estendido, aritmética de polinômios e GF(24).
- **Capítulo 5 – Advanced Encryption Standard:** Exercícios baseados no SAES.
- **Capítulo 7 – Geração de números pseudoaleatórios e cifras de bloco:** Gerador Blum Blum Shub e de congruência linear, e ANSI X9.17 PRNG.
- **Capítulo 8 – Teoria dos números:** Função totiente de Euler, Miller Rabin, fatoração, exponenciação modular, logaritmo discreto e teorema chinês do resto.
- **Capítulo 9 – Criptografia de chave pública e RSA:** criptografia/decritografia e assinatura RSA.
- **Capítulo 10 – Outros criptossistemas de chave pública:** Diffie-Hellman, curva elíptica.
- **Capítulo 11 – Funções de hash criptográficas:** Função de hash da teoria dos números.
- **Capítulo 13 – Assinaturas digitais:** DSA.

Agradecimentos

Esta nova edição foi beneficiada com a crítica de diversas pessoas que generosamente dedicaram seu tempo e habilidades. As pessoas citadas a seguir revisaram todo ou grande parte do manuscrito: Steven Tate (University of North Carolina em Greensboro), Kemal Akkaya (Southern Illinois University), Bulent Yener (Rensselaer Polytechnic Institute), Ellen Gethner (University of Colorado, Denver), Stefan A. Robila (Montclair State University) e Albert Levi (Sabanci University, Istambul, Turquia).

Também sou grato às pessoas que ofereceram revisões técnicas detalhadas de um ou mais capítulos: Kashif Aftab, Jon Baumgardner, Alan Cantrell, Rajiv Dasmohapatra, Edip Demirbilek, Dhananjay Dey, Dan Dieterle, Gerardo Iglesias Galvan, Michel Garcia, David Gueguen, Anasuya Threse Innocent, Dennis Kavanagh, Duncan Keir, Robert Knox, Bob Kupperstein, Bo Lin, Kousik Nandy, Nickolay Olshevsky, Massimiliano Sembiante, Oscar So e Varun Tewari.

Além disso, tive a sorte de conseguir revisões de tópicos individuais pelos “gurus no assunto”, incluindo Jesse Walker, da Intel (gerador de números aleatórios digitais da Intel), Russ Housley, da Vigil Security (*key wrapping*), Joan Daemen (AES), Edward F. Schaefer, da Santa Clara University (Simplified AES), Tim

Mathews, anteriormente na RSA Laboratories (S/MIME), Alfred Menezes, da University of Waterloo (criptografia de curva elíptica), William Sutton, editor da *The Cryptogram* (criptografia clássica), Avi Rubin, da Johns Hopkins University (teoria dos números), Michael Markowitz, da Information Security Corporation (SHA e DSS), Don Davis, da IBM Internet Security Systems (Kerberos), Steve Kent, da BBN Technologies (X.509) e Phil Zimmerman (PGP).

Nikhil Bhargava (IIT Delhi) desenvolveu o conjunto de problemas para casa e soluções on-line. Dan Shumow, da Microsoft e University of Washington, desenvolveu todos os exemplos e trabalhos do Sage nos Apêndices B e C. Professor Sreekanth Malladi, da Dakota State University, desenvolveu os exercícios sobre hacking. Lawrie Brown, da Australian Defence Force Academy, ofereceu os projetos de cifra em bloco AES/DES e os trabalhos sobre avaliação de segurança.

Sanjay Rao e Ruben Torres, da Purdue University, desenvolveram os exercícios de laboratório que aparecem no IRC. As pessoas mencionadas a seguir contribuíram com projetos que aparecem no suplemento do instrutor: Henning Schulzrinne (Columbia University), Cetin Kaya Koc (Oregon State University) e David Balenson (Trusted Information Systems e George Washington University). Kim McLaughlin desenvolveu o banco de testes.

Por fim, gostaria de agradecer às muitas pessoas responsáveis pela publicação deste livro, todas realizando um excelente trabalho, como sempre. Isso inclui o pessoal da Pearson, particularmente minha editora, Tracy Johnson, editora associada Carole Snyder, supervisor de produção Robert Engelhardt e gerente de projeto de produção Pat Brown. Sou grato a Shiny Rajesh e ao pessoal de produção na Integra por outro trabalho rápido e excelente. Também sou grato ao pessoal de marketing e vendas da Pearson, cujos esforços foram essenciais para que este livro estivesse sendo lido por você.

Com todo esse auxílio, pouco resta para eu poder dar o crédito completo. Porém, tenho o orgulho de dizer que, sem qualquer ajuda, selecionei todas as citações.

Sobre o autor

Dr. William Stallings é autor de 17 títulos e, contando as edições revisadas, mais de 40 livros sobre segurança de computador, redes de computadores e arquitetura de computadores. Seus escritos apareceram em diversas publicações, incluindo *Proceedings of the IEEE*, *ACM Computing Reviews* e *Cryptologia*.

Ele recebeu por 11 vezes o prêmio de melhor livro-texto de Ciência da Computação do ano, pela Text and Academic Authors Association.

Por mais de 30 anos no campo, ele tem sido colaborador técnico, gerente técnico e executivo com diversas empresas de alta tecnologia. Ele projetou e implementou conjuntos de protocolos baseados em TCP/IP e OSI em diversos computadores e sistemas operacionais, variando desde microcomputadores até computadores de grande porte. Como consultor, ele aconselhou agências do governo, fornecedores de computador e software e principais usuários a respeito de projeto, seleção e uso de software e produtos de rede.

Ele criou e mantém o *Computer Science Student Resource Site*, em (computerScienceStudent.com). Esse site oferece documentos e links sobre diversos assuntos de interesse geral para estudantes (e profissionais) de ciência da computação. É membro do quadro editorial da *Cryptologia*, uma publicação acadêmica dedicada a todos os aspectos da criptologia.

Dr. Stallings possui PhD em ciência da computação pelo MIT e bacharelado em engenharia elétrica pela Universidade de Notre Dame.

Guia para leitores e instrutores



TÓPICOS ABORDADOS

0.1 ESBOÇO DO LIVRO

0.2 ROTEIRO PARA LEITORES E INSTRUTORES

Assunto

Ordem dos tópicos

0.3 INTERNET E RECURSOS DA WEB

Websites deste livro

Site de recursos para alunos de ciência da computação

Outros Websites

“arte da guerra nos ensina a contar não com a probabilidade de o inimigo não chegar, mas com nossa própria prontidão para recebê-lo; não com a chance de não ser atacado, mas, sim, com o fato de tornar nossa posição inatacável.”

— A arte da guerra, Sun Tzu

Este livro, com o Website que o acompanha, abrange um material extenso. Aqui, o leitor poderá ter uma visão geral.

0.1 Esboço do livro

Após um capítulo introdutório, o Capítulo 1, o livro é organizado em sete partes:

Parte Um: Cifras simétricas: oferece um estudo da encriptação simétrica, incluindo algoritmos clássicos e modernos. A ênfase está no algoritmo mais importante, o Advanced Encryption Standard (AES). O Data Encryption Standard (DES) também é abordado. Essa parte também enfatiza o algoritmo de encriptação de fluxo, RC4, e o tópico de geração de números pseudoaleatórios e aleatórios.

Parte Dois: Cifras assimétricas: oferece um estudo sobre algoritmos de chave pública, incluindo RSA (Rivest-Shamir-Adelman) e curva elíptica.

Parte Três: Algoritmos criptográficos de integridade de dados: começa com um estudo das funções de hash criptográficas. Esta parte, então, abrange duas abordagens para a integridade de dados, que contam com funções de hash criptográficas: códigos de autenticação de mensagem e assinaturas digitais.

Parte Quatro: Confiança mútua: abrange os tópicos de gerenciamento e distribuição de chaves, além de técnicas de autenticação do usuário.

Parte Cinco: Segurança na rede e segurança na Internet: examina o uso de algoritmos criptográficos e protocolos de segurança para oferecer segurança nas redes e na Internet. Os tópicos abordados incluem controle de acesso à rede, segurança na nuvem, segurança no nível de transporte, segurança na rede sem fio, segurança de e-mail e segurança IP.

Parte Seis: Segurança do sistema: trata das instalações de segurança criadas para proteger um sistema de computador contra ameaças à segurança, incluindo intrusos, vírus e *worms*. Essa parte também examina a tecnologia de firewall.

Parte Sete: Questões legais e éticas: trata das questões legais e éticas relacionadas à segurança de computador e de rede.

Diversos apêndices on-line na Sala Virtual deste livro contêm tópicos adicionais relevantes ao tema.

Obs: As partes seis e sete integram o conteúdo on-line, não fazendo parte do livro impresso. Para mais informações acesse a Sala Virtual (sv.pearson.com.br).

0.2 Roteiro para leitores e instrutores

Assunto

O material neste livro é organizado em quatro categorias gerais:

- **Algoritmos criptográficos:** esse é o estudo das técnicas para garantir o sigilo e/ou a autenticidade da informação. Os dois ramos principais da criptologia são a criptografia, que é o estudo do projeto dessas técnicas; e a criptoanálise, que trata de frustrar essas técnicas, recuperar informações ou forjar informações que serão aceitas como autênticas.
- **Confiança mútua:** é o estudo de técnicas e algoritmos para oferecer confiança mútua em duas áreas principais. Primeiro, o gerenciamento e distribuição de chaves lida com o estabelecimento de confiança nas chaves criptográficas usadas entre duas entidades que se comunicam. Segundo, a autenticação do usuário lida com o estabelecimento de confiança na identidade de um parceiro que se comunica.
- **Segurança da rede:** essa área explica o uso dos algoritmos de criptografia nos protocolos de rede e aplicações de rede.
- **Segurança de computador:** neste livro, usamos esse termo para nos referir à segurança dos computadores contra intrusos (por exemplo, hackers) e software malicioso (por exemplo, vírus). Normalmente, o computador a ser protegido está conectado a uma rede e as maiores ameaças surgem desta.

As duas primeiras partes do livro tratam de duas técnicas criptográficas distintas: algoritmos criptográficos simétricos e algoritmos criptográficos de chave pública, ou assimétricos. Os algoritmos simétricos utilizam uma única chave, compartilhada por duas partes. Os algoritmos de chave pública utilizam duas chaves: uma chave privada, conhecida apenas por uma das partes, e uma chave pública, disponível a outras partes.

Ordem dos tópicos

Este livro contém um material muito extenso. Para o instrutor ou leitor que deseja um tratamento mais curto, existem diversas oportunidades.

Para abordar completamente o material das duas primeiras partes, os capítulos deverão ser lidos em sequência. Com exceção do Advanced Encryption Standard (AES), nenhum material na **Parte Um** exige qualquer

base matemática especial. Para entender o AES, é preciso ter algum conhecimento sobre corpos finitos. Por sua vez, um conhecimento sobre corpos finitos requer uma base sobre números primos e aritmética modular. Em consequência disso, o Capítulo 4 abrange todas as preliminares matemáticas imediatamente antes do seu uso no Capítulo 5, sobre AES. Assim, se o Capítulo 5 for pulado, é seguro pular o Capítulo 4 também.

O Capítulo 2 apresenta alguns conceitos que serão úteis em outros capítulos da Parte Um. Porém, para o leitor cujo único interesse é a criptografia contemporânea, este capítulo pode ser apenas examinado superficialmente. Os dois algoritmos criptográficos simétricos mais importantes são DES e AES, que são explicados nos capítulos 3 e 5, respectivamente.

O Capítulo 6 abrange técnicas específicas para o uso das cifras simétricas de bloco. O Capítulo 7 traz cifras de fluxo e geração de número aleatório. Esses dois capítulos podem ser pulados em uma leitura inicial, mas o material é referenciado em outras partes do livro, mais adiante.

Para a **Parte Dois**, a única base matemática adicional necessária está na área da teoria dos números, que é explicada no Capítulo 8. O leitor que tiver pulado os capítulos 4 e 5 deverá primeiro rever o material nas seções de 4.1 a 4.3.

Os dois algoritmos de chave pública para uso geral mais utilizados são RSA e curva elíptica, sendo que RSA obteve maior aceitação. O leitor poderá pular o material sobre criptografia com curva elíptica no Capítulo 10, pelo menos em uma primeira leitura.

Na **Parte Três**, os tópicos das seções 12.6 e 12.7 têm menor importância.

As **partes Quatro, Cinco e Seis** são relativamente independentes uma da outra, e podem ser lidas em qualquer ordem. As três partes assumem um conhecimento básico do material contido nas partes Um, Dois e Três. Os cinco capítulos da **Parte Cinco**, sobre segurança na rede e na Internet, são relativamente independentes um do outro, e podem ser lidos em qualquer ordem.

0.3 Internet e recursos da Web

Existem inúmeros recursos disponíveis na Internet e na web para dar suporte a este livro e ajudá-lo a manter-se atualizado com os desenvolvimentos nessa área.

Websites deste livro

Para ter acesso aos recursos adicionais, acesse a Sala Virtual do livro (sv.pearson.com.br), que contém material disponível para alunos e professores. Neste site, o leitor encontrará também parte do conteúdo disponibilizado em (williamstallings.com/crypto.graphy), página indicada pelo autor.

Site de recursos para alunos de ciência da computação

Também há um site de recursos para alunos de ciência da computação, ComputerScienceStudent.com. A finalidade desse site é oferecer documentos, informações e links para alunos e profissionais de ciência da computação. Links e documentos são organizados em sete categorias:

- **Matemática:** inclui uma revisão da matemática básica, um manual de análise de fila, um manual de sistema numérico e links para vários sites de matemática.
- **Como fazer:** conselho e orientação para solucionar trabalhos de casa, escrever relatórios técnicos e preparar apresentações técnicas.
- **Fontes de pesquisa:** links para coleções importantes de artigos, relatórios técnicos e bibliografias.
- **Diversos:** uma série de outros documentos e links úteis.
- **Carreiras em ciência da computação:** links e documentos úteis para aqueles que estão considerando uma carreira em ciência da computação.
- **Ajuda para escrita:** ajuda para se tornar um escritor mais claro e eficaz.
- **Tópicos diversos e humor:** você precisa se desviar do seu trabalho de vez em quando.

0.3 Padrões

Muitas das técnicas de segurança e aplicações descritas neste livro foram especificadas como padrões. Além disso, foram desenvolvidos padrões para cobrir práticas de gerenciamento e a arquitetura geral dos mecanismos e serviços de segurança. No decorrer das páginas, descreveremos os padrões mais importantes em uso ou sendo desenvolvidos para diferentes aspectos da criptografia e segurança da rede. Diversas organizações têm sido envolvidas no desenvolvimento ou promoção desses padrões. As organizações mais importantes (no contexto atual) são as seguintes:

- **National Institute of Standards and Technology (NIST):** federal dos EUA que lida com a ciência da medição, padrões e tecnologia relacionados ao uso do governo e à promoção de inovação no setor privado norte-americano. Apesar de seu escopo nacional, a Federal Information Processing Standards (FIPS) e a Special Publications (SP) do NIST têm um impacto mundial.
- **Internet Society (ISOC):** sociedade de membros profissionais com participação organizacional e individual no mundo inteiro. Ela oferece liderança no tratamento de questões que se referem ao futuro da Internet e é a organização pai para os grupos responsáveis por padrões de infraestrutura da Internet, incluindo a Internet Engineering Task Force (IETF) e o Internet Architecture Board (IAB). Essas organizações desenvolvem padrões da Internet e especificações relacionadas, todos publicados como Requests for Comments (RFCs).
- **ITU-T The International Telecommunication Union (ITU):** organização internacional dentro do Sistema das Nações Unidas em que os governos e o setor privado coordenam redes e serviços de telecomunicação global. O ITU Telecommunication Standardization Sector (ITU-T) é um dos três setores da ITU. A missão da ITU-T é a produção de padrões que abrangem todos os campos das telecomunicações. Os padrões ITU-T são chamados de Recomendações.
- **International Organization for Standardization (ISO)¹:** federação mundial de agências de padrões nacionais para mais de 140 países, uma de cada país. ISO é uma organização não governamental, que promove o desenvolvimento da padronização e atividades relacionadas, com uma visão para facilitar a troca internacional de bens e serviços e desenvolver a cooperação nas esferas da atividade intelectual, científica, tecnológica e econômica. O trabalho da ISO resulta em acordos internacionais que são publicados como Padrões Internacionais.

Uma discussão mais detalhada dessas organizações está contida no Apêndice D (na Sala Virtual, em inglês).

¹ ISO não é um acrônimo (se fosse, seria IOS), mas é uma palavra, derivada do grego, que significa *igual*.

Introdução

1

TÓPICOS ABORDADOS

1.1 CONCEITOS DE SEGURANÇA DE COMPUTADORES

Uma definição de segurança de computadores
Exemplos
Os desafios da segurança de computadores

1.2 A ARQUITETURA DE SEGURANÇA OSI

1.3 ATAQUES À SEGURANÇA

Ataques passivos
Ataques ativos

1.4 SERVIÇOS DE SEGURANÇA

Autenticação
Controle de acesso
Confidencialidade de dados
Integridade de dados
Irretratabilidade
Serviço de disponibilidade

1.5 MECANISMOS DE SEGURANÇA

1.6 UM MODELO PARA SEGURANÇA DE REDE

1.7 LEITURA RECOMENDADA

1.8 PRINCIPAIS TERMOS, PERGUNTAS PARA REVISÃO E PROBLEMAS

OBJETIVOS DE APRENDIZAGEM

APÓS ESTUDAR ESTE CAPÍTULO, VOCÊ SERÁ CAPAZ DE:

- ☒ Descrever os principais requisitos de segurança de confidencialidade, integridade e disponibilidade.
- ☒ Discutir os tipos de ameaças e ataques à segurança que devem ser tratados, com exemplos dos que se aplicam a diferentes categorias de computadores e redes.
- ☒ Resumir os requisitos funcionais para segurança de computadores.
- ☒ Descrever a arquitetura de segurança X.800 para OSI.

“A combinação de espaço, tempo e resistência que precisam ser considerados como os elementos básicos dessa teoria de defesa torna essa questão bastante complicada. Consequentemente, não é fácil encontrar um ponto de partida fixo.”

— On War, Carl Von Clausewitz

Este livro tem foco em duas áreas principais: protocolos e algoritmos de criptografia, que possuem uma ampla gama de aplicações, e segurança de rede e de Internet, que se baseia de forma expressiva em técnicas de criptografia.

Os **algoritmos e protocolos de criptografia** podem ser agrupados em quatro áreas principais:

- **Encriptação simétrica:** utilizada para ocultar o conteúdo dos blocos ou fluxos contínuos de dados de qualquer tamanho, incluindo mensagens, arquivos, chaves de encriptação e senhas.
- **Encriptação assimétrica:** usada para ocultar pequenos blocos de dados, como valores de função de *hash* e chaves de encriptação, que são usados em assinaturas digitais.
- **Algoritmos de integridade de dados:** usados para proteger blocos de dados, como mensagens, de possíveis alterações.
- **Protocolos de autenticação:** esses são esquemas baseados no uso de algoritmos criptográficos projetados para autenticar a identidade de entidades.

A área de **segurança de rede e de Internet** consiste de medidas para desviar, prevenir, detectar e corrigir violações de segurança que envolvam a transmissão de informações. Essa é uma definição abrangente que envolve várias possibilidades. A fim de lhe oferecer uma ideia das áreas cobertas por este livro, considere os seguintes exemplos de violações de segurança:

1. O usuário A transmite um arquivo ao usuário B. O arquivo contém informações confidenciais (por exemplo, registros de folha de pagamento) que devem ser protegidas contra divulgação. O usuário C, que não está autorizado a ler o arquivo, é capaz de monitorar a transmissão e capturar uma cópia dele nesse momento.
2. Um gerente de rede, D, transmite uma mensagem a um computador, E, sob seu gerenciamento. A mensagem instrui o computador E a atualizar um arquivo de autorização para incluir as identidades de diversos usuários novos, que deverão receber acesso a esse computador. O usuário F intercepta a mensagem, altera seu conteúdo para incluir ou excluir entradas, e depois encaminha-a para E, que a aceita como se estivesse vindo do gerente D e atualiza seu arquivo de autorização conforme solicitado.
3. Em vez de interceptar uma mensagem, o usuário F constrói a sua própria com as entradas desejadas e a transmite para E como se tivesse vindo do gerente D. O computador E a aceita como proveniente do gerente D e atualiza seu arquivo de autorização conforme solicitado.
4. Um empregado é demitido sem aviso. O gerente de pessoal envia uma mensagem a um sistema servidor para invalidar a conta do empregado. Quando a invalidação é realizada, o servidor deve postar uma nota no arquivo do empregado como confirmação da ação. O empregado é capaz de interceptar a mensagem e adiá-la por um tempo necessário para fazer um acesso final ao servidor e apanhar informações confidenciais. A mensagem é então encaminhada, a ação, tomada e a confirmação, postada. A ação do empregado pode passar despercebida por um tempo considerável.
5. Uma mensagem é enviada por um cliente a uma corretora de ações com instruções para diversas transações. Depois disso, os investimentos perdem valor, e o cliente nega ter enviado a mensagem.

Embora essa lista de forma alguma esgote os tipos possíveis de violações de segurança, ela ilustra a gama de problemas de segurança de rede.

1.1 CONCEITOS DE SEGURANÇA DE COMPUTADORES

Uma definição de segurança de computadores

O *Manual de Segurança de Computadores* da NIST [NIST95] define o termo *segurança de computadores* da seguinte forma:

Segurança de computadores: a proteção oferecida para um sistema de informação automatizado a fim de alcançar os objetivos de preservar a integridade, a disponibilidade e a confidencialidade dos recursos do sistema de informação (incluindo hardware, software, firmware, informações/dados e telecomunicações).

Essa definição introduz três objetivos principais que são o coração da segurança de computadores:

- **Confidencialidade:** esse termo cobre dois conceitos relacionados:
 - Confidencialidade de dados:**¹ assegura que informações privadas e confidenciais não estejam disponíveis nem sejam reveladas para indivíduos não autorizados.
 - Privacidade:** assegura que os indivíduos controlem ou influenciem quais informações relacionadas a eles podem ser obtidas e armazenadas, da mesma forma que como, por quem e para quem essas informações são passíveis de ser reveladas.
- **Integridade:** esse termo abrange dois conceitos relacionados:
 - Integridade de dados:** assegura que as informações e os programas sejam modificados somente de uma maneira especificada e autorizada.
 - Integridade do sistema:** assegura que um sistema execute as suas funcionalidades de forma ílesa, livre de manipulações deliberadas ou inadvertidas do sistema.
- **Disponibilidade:** assegura que os sistemas operem prontamente e seus serviços não fiquem indisponíveis para usuários autorizados.

Esses três conceitos formam o que é normalmente chamado de **tríade CIA** (do acrônimo em inglês para *confidentiality, integrity and availability*). Os três conceitos envolvem os objetivos fundamentais da segurança tanto para dados quanto para serviços de informação e computação. Por exemplo, os padrões FIPS 199 (*padrões para categorização de segurança para as informações e sistemas de informação federais*) da NIST listam a confidencialidade, integridade e disponibilidade como os três objetivos de segurança para informação e sistemas de informação. O FIPS 199 fornece uma caracterização muito útil para esses três objetivos em termos de requisitos e da definição de uma perda de segurança em cada categoria:

- **Confidencialidade:** preservar restrições autorizadas sobre acesso e divulgação de informação, incluindo meios para proteger a privacidade de indivíduos e informações privadas. Uma perda de confidencialidade seria a divulgação não autorizada de informação.
- **Integridade:** prevenir-se contra a modificação ou destruição imprópria de informação, incluindo a irretratabilidade e autenticidade dela. Uma perda de integridade seria a modificação ou destruição não autorizada de informação.
- **Disponibilidade:** assegurar acesso e uso rápido e confiável da informação. Uma perda de disponibilidade é a perda de acesso ou de uso da informação ou sistema de informação.

Embora o emprego da tríade CIA para definir os objetivos da segurança esteja bem estabelecido, alguns no campo da segurança percebem que conceitos adicionais são necessários para apresentar um quadro completo. Seguem abaixo dois desses conceitos que são mais comumente mencionados:

- **Autenticidade:** a propriedade de ser genuíno e capaz de ser verificado e confiável; confiança na validação de uma transmissão, em uma mensagem ou na origem de uma mensagem. Isso significa verificar que os usuários são quem dizem ser e, além disso, que cada entrada no sistema vem de uma fonte confiável.
- **Responsabilização:** a meta de segurança que gera o requisito para que ações de uma entidade sejam atribuídas exclusivamente a ela. Isso provê irretratabilidade, dissuasão, isolamento de falhas, detecção e prevenção de intrusão, além de recuperação pós-ação e ações legais. Como sistemas totalmente seguros não são ainda uma meta alcançável, temos que ser capazes de associar uma violação de segurança a uma parte responsável. Os sistemas precisam manter registros de suas atividades a fim de permitir posterior análise forense, de modo a rastrear as violações de segurança ou auxiliar em disputas de uma transação.

¹ RFC 4949 define *informação* como “fatos e ideias que podem ser representadas (codificadas) em vários formatos de dados”; e *dados* como “informações em uma representação física específica, usualmente uma sequência de símbolos que possuem significado; sobretudo, uma representação da informação que pode ser processada ou produzida por um computador”. A literatura referente à segurança em geral não faz muita distinção entre esses dois termos, tampouco o faz este livro.

Exemplos

Seguem alguns exemplos de aplicações que ilustram os requisitos que acabamos de definir.² Para esses exemplos, usamos três níveis de impacto sobre organizações ou indivíduos que podem representar uma quebra de segurança (por exemplo, a perda de confidencialidade, integridade ou disponibilidade). Esses níveis são definidos no FIPS PUB 199:

- **Baixo:** é esperado que a perda represente um efeito adverso limitado nas operações da organização, em seus recursos ou nos indivíduos. Um efeito adverso limitado implica que, por exemplo, a perda de confidencialidade, integridade ou disponibilidade (i) cause uma degradação na capacidade de cumprir sua missão em uma extensão e por um tempo nos quais a organização consiga realizar suas funções primárias, mas com a eficiência delas notadamente reduzida; (ii) resulte em um dano limitado nos recursos da organização; (iii) apresente uma perda financeira limitada; ou (iv) origine um menor prejuízo aos indivíduos.
- **Moderado:** é esperado que a perda represente graves efeitos adversos nas operações da organização, em seus recursos ou nos indivíduos. Um efeito adverso grave implica que, por exemplo, a perda (i) cause uma degradação significativa na capacidade de cumprir sua missão em uma extensão e por um tempo nos quais a organização consiga realizar suas funções primárias, mas com a eficiência delas reduzida de forma significativa; (ii) resulte em danos expressivos nos recursos da organização; (iii) mostre significativas perdas financeiras; ou (iv) aponte prejuízos relevantes para indivíduos que não signifiquem perda da vida ou lesões graves, com risco de morte.
- **Alto:** a perda esperada possui efeitos adversos muito graves ou catastróficos nas operações da organização, em seus recursos ou nos indivíduos. Um efeito adverso muito grave ou catastrófico implica que, por exemplo, a perda (i) cause uma grave degradação ou perda da capacidade de cumprir sua missão por uma extensão e um período nos quais a organização não consiga desempenhar uma ou mais de suas funções primárias; (ii) resulte em grande dano aos recursos da organização; (iii) origine grandes perdas financeiras; ou (iv) desencadeie danos grandes ou catastróficos aos indivíduos envolvendo perda da vida ou lesões graves, com risco de morte.

CONFIDENCIALIDADE Informações referentes às notas de estudantes são um conteúdo cuja confidencialidade é considerada de altíssima importância por eles. Nos Estados Unidos, a disponibilização de tais informações é regulamentada pelo Ato sobre a Privacidade e os Direitos Educacionais da Família (Ferpa – do acrônimo em inglês para Family Educational Rights and Privacy Act). Informações relacionadas às notas devem ser somente disponibilizadas para os estudantes, seus pais e funcionários que precisem delas para realizar o seu trabalho. Dados de matrícula dos estudantes podem se amparar em uma confidencialidade moderada. Ainda que estejam cobertas pela Ferpa, uma vez que são visualizadas por mais pessoas diariamente, é menos provável que esses dados sejam alvo de ataques do que informações de notas, e isso implica em menor dano se forem revelados. Informações da diretoria, como listas de estudantes, de corpo docente ou de departamentos, podem envolver um nível de confidencialidade baixo, ou talvez nem tenham uma classificação. Essa informação normalmente fica disponível ao público e é publicada no website da escola.

INTEGRIDADE Muitos aspectos da integridade são ilustrados pelo exemplo das informações das alergias dos pacientes de um hospital armazenadas em um banco de dados. O médico precisa confiar que elas estão corretas e atualizadas. Suponha que um funcionário (uma enfermeira, por exemplo) que está autorizado a consultar e atualizar essa informação deliberadamente falsifique os dados para causar prejuízo ao hospital. Então o banco de dados precisará rapidamente ser restaurado para um ponto anterior que seja confiável, assim como ser rastreada a pessoa responsável pelo erro. As informações de alergia dos pacientes são um exemplo de conteúdo com um requisito de integridade de nível alto. Informações erradas podem gerar danos graves ou mesmo a morte, e assim expor o hospital a uma responsabilização generalizada.

Um exemplo de um conteúdo ao qual pode ser associado um requisito de integridade de nível moderado é um website que oferece um fórum para usuários registrados discutirem algum tópico específico. Tanto um usuário registrado quanto um *hacker* podem falsificar algumas entradas ou desfigurar a página. Se o fórum existe

² Esses exemplos foram retirados de um documento de política de segurança publicado pelo Escritório de Segurança e Privacidade de Tecnologia da Informação da Universidade de Purdue.

somente para o entretenimento dos usuários, introduz pouco ou nenhum rendimento com propaganda e não é usado para alguma coisa importante como pesquisa, então os danos que podem ocorrer não serão graves. O webmaster é que talvez tenha uma pequena perda de dados, tempo ou dinheiro.

Um exemplo de um requisito de integridade de nível baixo é uma enquete on-line anônima. Muitos websites, como por outro lado organizações de notícias, oferecem essas enquetes para seus usuários com muito poucos meios de segurança. Por outro lado, a imprecisão e a natureza não científica dessas enquetes é bem conhecida.

DISPONIBILIDADE Quanto mais crítico for um componente ou serviço, maior será o nível de disponibilidade requerido. Considere um sistema que oferece serviços de autenticação para sistemas, aplicações e dispositivos críticos. Uma interrupção do serviço resulta na incapacidade dos clientes de acessar os recursos computacionais e de pessoal a fim de chegar ao que necessitam para realizar tarefas críticas. A perda do serviço se traduz em grande perda financeira, de produtividade dos empregados e de potencial de clientes.

Um recurso que poderia apresentar um nível moderado de disponibilidade é um website público para uma universidade. Esse website forneceria informações para estudantes e doadores atuais e potenciais. Um website como esse não é um componente decisivo para o sistema de informação da universidade, mas sua indisponibilidade pode causar alguns percalços.

Um aplicativo de consulta on-line à lista telefônica seria classificado com um nível baixo de disponibilidade. Embora a perda temporária do aplicativo seja um incômodo, existem outros meios de acessar a informação, como uma cópia impressa ou um operador.

Os desafios da segurança de computadores

A segurança de computadores e redes é tão fascinante quanto complexa. Seguem algumas das razões para isso:

1. Segurança não é tão simples quanto parece à primeira vista para o iniciante. Os requisitos aparentam ser claros e diretos; de fato, a maioria dos mais importantes requisitos para serviços de segurança pode ser autoexplicativa e identificada com rótulos de: confidencialidade, autenticação, irretratabilidade ou integridade. No entanto, os mecanismos usados para satisfazê-los talvez sejam bastante complexos e seu entendimento envolva razões bastante sutis.
2. No desenvolvimento de um mecanismo ou algoritmo específico de segurança, deve-se sempre considerar potenciais ataques a essas funcionalidades. Em muitos casos, os ataques bem-sucedidos são projetados a fim de olhar para o problema de uma forma completamente diferente, portanto, explorando uma fraqueza inesperada no mecanismo.
3. Por conta do ponto 2, os procedimentos usados para fornecer os serviços de segurança são muitas vezes nem um pouco intuitivos. Normalmente, um mecanismo de segurança é complexo, e não fica óbvio na definição de seus requisitos que essas medidas são necessárias. Só faz sentido elaborar mecanismos de segurança quando os vários aspectos de ameaças são considerados.
4. Tendo projetado vários mecanismos de segurança, é necessário decidir onde eles devem ser usados. Essa é uma verdade tanto em termos da localização física (por exemplo, em que pontos na rede são exigidos certos mecanismos de segurança) quanto do sentido lógico (por exemplo, em que camada ou camadas de uma arquitetura como TCP/IP [*Transmission Control Protocol/Internet Protocol*] devem ser postos tais mecanismos).
5. Mecanismos de segurança normalmente envolvem mais do que um algoritmo ou protocolo em particular. Eles também requerem que os participantes possuam algumas informações secretas (como chave de encriptação), o que levanta outras questões relacionadas à criação, distribuição e proteção delas. Pode haver igualmente uma dependência de protocolos de comunicação, cujo comportamento talvez complique a tarefa de desenvolver o mecanismo de segurança. Por exemplo, se o funcionamento adequado do mecanismo de segurança requer determinar limites de tempo de trânsito de uma mensagem do emitente ao destinatário, então qualquer protocolo ou rede que introduza atrasos variáveis ou imprevisíveis pode implicar na perda de sentido de utilizar esses limites de tempo.
6. Segurança de computadores e redes é, essencialmente, uma batalha de inteligência entre um criminoso que tenta encontrar buracos e o projetista ou administrador que tenta fechá-los. A grande vantagem que o atacante possui é que ele ou ela precisa encontrar uma simples brecha, enquanto o projetista tem que encontrar e eliminar todas as possíveis brechas para garantir uma segurança perfeita.

7. Existe uma tendência natural de uma parte dos usuários e gerentes de sistemas a perceber poucos benefícios com os investimentos em segurança, até que uma falha nela ocorra.
8. A segurança requer um monitoramento regular, ou até mesmo constante, e isso é algo difícil com os curtos prazos e nos ambientes sobrecarregados dos dias de hoje.
9. Segurança ainda é muito frequentemente um adendo a ser incorporado no sistema após o projeto estar completo, em vez de ser parte do processo de sua criação.
10. Muitos usuários, e até mesmo administradores de segurança, veem uma segurança forte como um impedimento à eficiência e à operação amigável de um sistema de informação ou do uso da informação.

As dificuldades apresentadas serão encontradas de muitas maneiras na medida em que forem examinadas as várias ameaças de segurança e mecanismos ao longo deste livro.

1.2 A ARQUITETURA DE SEGURANÇA OSI

Para avaliar efetivamente as necessidades de segurança de uma organização e escolher diversos produtos e políticas de segurança, o gerente responsável precisa de algum meio sistemático de definir os requisitos para a segurança e caracterizar as técnicas para satisfazê-los. Isso já é difícil em um ambiente de processamento de dados centralizado; com o uso de redes locais e remotas, os problemas são ainda maiores.

A recomendação X.800 da ITU-T,³ *Security Architecture for OSI*, define tal técnica sistemática.⁴ A arquitetura de segurança OSI é útil para os gerentes como um meio de organizar a tarefa de fornecer segurança. Além do mais, como essa arquitetura foi desenvolvida como um padrão internacional, fornecedores de computador e de comunicação estabeleceram recursos de segurança para seus produtos e serviços, que se relacionam com essa definição estruturada de serviços e mecanismos.

Para os nossos propósitos, a arquitetura de segurança OSI oferece uma visão geral útil, abstrata, de muitos dos conceitos de que este livro trata. Ela focaliza ataques, mecanismos e serviços de segurança. Eles podem ser definidos resumidamente da seguinte forma:

- **Ataque à segurança:** qualquer ação que comprometa a segurança da informação pertencida a uma organização.
- **Mecanismo de segurança:** um processo (ou um dispositivo incorporando tal processo) que é projetado para detectar, impedir ou recuperar-se de um ataque à segurança.
- **Serviço de segurança:** um serviço de processamento ou comunicação que aumenta a segurança dos sistemas de processamento de dados e das transferências de informação de uma organização. Os serviços servem para frustrar ataques à segurança, e utilizam um ou mais mecanismos para isso.

Na literatura, os termos *ameaça* e *ataque* normalmente são usados mais ou menos para a mesma coisa. O Quadro 1.1 oferece definições retiradas da RFC 4949, *Internet Security Glossary*.

Quadro 1.1 Ameaças e ataques (RFC 4949).

Ameaça

Uma chance de violação da segurança que existe quando há uma circunstância, capacidade, ação ou evento que poderia quebrar a segurança e causar danos. Ou seja, uma ameaça é um possível perigo a explorar uma vulnerabilidade.

Ataque

Um ataque à segurança do sistema, derivado de uma ameaça inteligente; ou seja, um ato inteligente que é uma tentativa deliberada (especialmente no sentido de um método ou técnica) de fugir dos serviços de segurança e violar a política de segurança de um sistema.

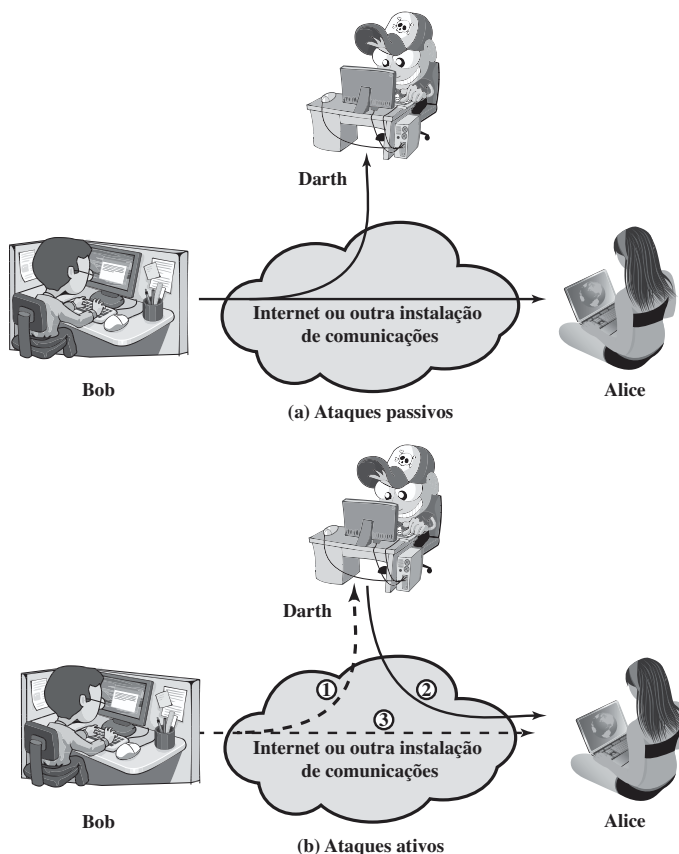
³ A International Telecommunication Union (ITU), Telecommunication Standardization Sector (ITU-T), é uma agência patrocinada pelas Nações Unidas que desenvolve padrões, chamados de Recomendações, relacionados a telecomunicações e a Open Systems Interconnection (OSI).

⁴ A arquitetura de segurança OSI foi desenvolvida no contexto da arquitetura de protocolo OSI, que é descrita no Apêndice L (<sv.pearson.com.br>, em inglês). Porém, para nossos propósitos neste capítulo, um conhecimento da arquitetura de protocolos OSI não é obrigatório.

1.3 ATAQUES À SEGURANÇA

Uma maneira útil de classificar os ataques à segurança, usada tanto na X.800 quanto na RFC 4949, é em termos de *ataques passivos* e *ataques ativos* (Figura 1.1). Um ataque passivo tenta descobrir ou utilizar informações do sistema, mas não afeta os seus recursos. Um ataque ativo tenta alterar recursos do sistema ou afetar sua operação.

Figura 1.1 Ataques à segurança.



Ataques passivos

Os ataques passivos (Figura 1.1a) estão na natureza de bisbilhotar ou monitorar transmissões. O objetivo do oponente é obter informações que estão sendo transmitidas. Dois tipos de ataques passivos são vazamento de conteúdo de mensagem e análise de tráfego.

O **vazamento de conteúdo de mensagem** é facilmente compreendido. Uma conversa telefônica, uma mensagem de correio eletrônico e um arquivo transferido podem conter informações, sensíveis ou confidenciais. Desejamos impedir que um oponente descubra o conteúdo dessas transmissões.

Um segundo tipo de ataque passivo, a **análise de tráfego**, é mais sutil. Suponha que tivéssemos uma maneira de disfarçar o conteúdo das mensagens ou outro tráfego de informações, de modo que os oponentes, mesmo que capturassem a mensagem, não pudessem extrair as informações dela. A técnica comum para mascarar o conteúdo é a encriptação. Se tivéssemos proteção por encriptação, um oponente ainda poderia conseguir observar o padrão dessas mensagens. Ele teria meios para determinar o local e a identidade dos interlocutores em comunicação e poderia observar a frequência e o tamanho das mensagens trocadas. Essa informação seria útil para descobrir a natureza da comunicação que estivesse ocorrendo.

Ataques passivos são muito difíceis de se detectar, pois não envolvem qualquer alteração dos dados. Em geral, o tráfego de mensagens é enviado e recebido em um padrão aparentemente normal, e nem o emissor nem o receptor estão cientes de que um terceiro leu as mensagens ou observou o padrão de tráfego. Porém, é viável impedir o sucesso desses ataques, normalmente por meio da encriptação. Assim, a ênfase em lidar com ataques passivos está na prevenção, em vez de na detecção.

Ataques ativos

Ataques ativos (Figura 1.1b) envolvem alguma modificação do fluxo de dados ou a criação de um fluxo falso, e podem ser subdivididos em quatro categorias: disfarce, repasse, modificação de mensagens e negação de serviço.

Um **disfarce** ocorre quando uma entidade finge ser outra diferente (o caminho 2 da Figura 1.1b é ativo). Um ataque de disfarce normalmente inclui uma das outras formas de ataque ativo. Por exemplo, sequências de autenticação podem ser capturadas e reproduzidas depois que houver uma delas, válida, permitindo assim que uma entidade autorizada com poucos privilégios obtenha alguns extras, personificando uma que os tenha.

Repasse envolve a captura passiva de uma unidade de dados e sua subsequente retransmissão para produzir um efeito não autorizado (caminhos 1, 2 e 3 ativos).

Modificação de mensagens simplesmente significa que alguma parte de uma mensagem legítima é alterada, ou que as mensagens são adiadas ou reordenadas, para produzir um efeito não autorizado (caminhos 1 e 2 ativos). Por exemplo, uma mensagem significando “Permitir que John Smith leia o arquivo confidencial *contas*” é modificada para “Permitir que Fred Brown leia o arquivo confidencial *contas*”.

A **negação de serviço** impede ou inibe o uso ou gerenciamento normal das instalações de comunicação (caminho 3 ativo). Esse ataque pode ter um alvo específico; por exemplo, uma entidade a suprimir todas as mensagens dirigidas para determinado destino (por exemplo, o serviço de auditoria de segurança). Outra forma de negação de serviço é a perturbação de uma rede inteira, seja desativando-a ou sobrecarregando-a com mensagens, a fim de prejudicar seu desempenho.

Os ataques ativos apresentam as características opostas dos ataques passivos. Embora os ataques passivos sejam difíceis de detectar, existem medidas para impedir seu sucesso. Por outro lado, é muito difícil impedir de forma absoluta os ataques ativos, em virtude da grande variedade de potenciais vulnerabilidades físicas, de software e de rede. Em vez disso, o objetivo é detectar ataques ativos e recuperar-se de qualquer rompimento ou atrasos causados por eles. Se a detecção tiver um efeito intimidador, ela também pode contribuir para a prevenção.

1.4 SERVIÇOS DE SEGURANÇA

X.800 define um serviço de segurança como aquele fornecido por uma camada de protocolo de comunicação de sistemas abertos, que garante a segurança adequada dos sistemas ou das transferências de dados. Talvez uma definição mais clara seja encontrada na RFC 4949, que diz: um serviço de processamento ou comunicação que é fornecido por um sistema para dar um tipo específico de proteção aos recursos do sistema; os serviços de segurança implementam políticas (ou diretrizes) de segurança e são implementados por mecanismos de segurança.

X.800 divide esses serviços em cinco categorias e quatorze serviços específicos (Quadro 1.2). Vamos examinar cada categoria, uma por vez.⁵

Autenticação

O serviço de autenticação refere-se à garantia de que uma comunicação é autêntica. No caso de uma única mensagem, como uma advertência ou um sinal de alarme, a função do serviço de autenticação é garantir ao destinatário que a mensagem tem a origem de que ela afirma ter vindo. No caso de uma interação em curso, como a conexão de um terminal a um *host*, dois aspectos estão envolvidos. Primeiro, no momento do início da conexão, o serviço garante que as duas entidades são autênticas, ou seja, que cada uma é a entidade que ela afirma ser. Segundo, o serviço precisa garantir que a conexão não sofra interferência de modo que um terceiro possa fingir ser uma das duas partes legítimas, para fins de transmissão ou recepção não autorizada.

⁵ Não existe um consenso universal sobre muitos dos termos empregados na literatura de segurança. Por exemplo, o termo *integridade* às vezes é usado para se referir a todos os aspectos da segurança da informação. O termo *autenticação* de vez em quando é utilizado para se referir tanto à verificação da identidade quanto às diversas funções listadas sob integridade neste capítulo. Nosso uso aqui adere à recomendação X.800, e também à RFC 4949.

Quadro 1.2 Serviços de segurança (X.800).

AUTENTICAÇÃO A certeza de que a entidade se comunicando é aquela que ela afirma ser. Autenticação de entidade pareada Usada em associação com uma conexão lógica para fornecer confiança na identidade das entidades conectadas. Autenticação da origem de dados Em uma transferência sem conexão, oferece certeza de que a origem dos dados recebidos é conforme alegada. CONTROLE DE ACESSO A prevenção de uso não autorizado de um recurso (ou seja, esse serviço controla quem pode ter acesso a um recurso, sob que condições o acesso pode ocorrer e o que é permitido àqueles que acessam o recurso). CONFIDENCIALIDADE DOS DADOS A proteção dos dados contra divulgação não autorizada. Confidencialidade da conexão A proteção de todos os dados do usuário em uma conexão. Confidencialidade sem conexão A proteção de todos os dados do usuário em um único bloco de dados. Confidencialidade com campo seletivo A confidencialidade de campos selecionados dentro dos dados do usuário em uma conexão ou em um único bloco de dados. Confidencialidade do fluxo de tráfego A proteção das informações que poderiam ser derivadas dos fluxos de tráfego.	INTEGRIDADE DE DADOS A certeza de que os dados recebidos são exatamente conforme enviados por uma entidade autorizada (ou seja, não contém modificação, inserção, exclusão ou repasse). Integridade da conexão com recuperação Providencia a integridade de todos os dados do usuário em uma conexão e detecta qualquer modificação, inserção, exclusão ou repasse de quaisquer dados dentro de uma sequência inteira, com tentativa de recuperação. Integridade da conexão sem recuperação Como acima, mas oferece apenas detecção sem tentativa de recuperação. Integridade da conexão com campo seletivo Providencia a integridade de campos selecionados nos dados do usuário de um bloco de dados transferido por uma conexão e determina se os campos selecionados foram modificados, inseridos, excluídos ou repassados. Integridade sem conexão Providencia a integridade de um único bloco de dados sem conexão e pode tomar a forma de detecção da modificação de dados. Além disso, pode haver uma forma limitada de detecção de repasse. Integridade sem conexão com campo seletivo Providencia a integridade de campos selecionados dentro de um único bloco de dados sem conexão; determina se os campos selecionados foram modificados. IRRETRATABILIDADE Oferece proteção contra negação, por parte de uma das entidades envolvidas em uma comunicação, de ter participado de toda ou parte dela. Irretratabilidade, Origem Prova de que a mensagem foi enviada pela parte especificada. Irretratabilidade, Destino Prova de que a mensagem foi recebida pela parte especificada.
--	---

Dois serviços de autenticação específicos são definidos na X.800:

- **Autenticação da entidade pareada:** fornece autenticação para a identidade de uma entidade pareada em uma associação. Duas entidades são consideradas pareadas se elas implementam o mesmo protocolo em sistemas diferentes; por exemplo, dois módulos TCP em dois sistemas de comunicação. É fornecida para uso no estabelecimento de uma conexão ou, às vezes, durante a fase de transferência de dados. Tenta oferecer confiança de que uma entidade não está realizando um disfarce ou um repasse não autorizado de uma conexão anterior.
- **Autenticação da origem de dados:** fornece autenticação para a origem de uma unidade de dados. Não oferece proteção contra a duplicação ou a modificação das unidades de dados. Esse tipo de serviço dá suporte a aplicações como correio eletrônico, nas quais não existem interações anteriores entre as entidades que se comunicam.

Controle de acesso

No contexto da segurança de redes, o controle de acesso é a capacidade de limitar e dominar o acesso aos sistemas e aplicações por meio de links de comunicação. Para conseguir isso, cada entidade que tenta obter acesso precisa primeiro ser identificada, ou autenticada, de modo que os direitos de acessos possam ser ajustados ao indivíduo.

Confidencialidade de dados

Confidencialidade é a proteção dos dados transmitidos contra ataques passivos. Com relação ao conteúdo de uma transmissão de dados, vários níveis de proteção podem ser elencados. O serviço mais amplo protege todos os dados do usuário transmitidos entre dois indivíduos por um período de tempo. Por exemplo, quando uma conexão TCP é estabelecida entre dois sistemas, essa proteção ampla impede a divulgação de quaisquer dados do usuário transmitidos pela conexão TCP. Formas mais restritas desse serviço também podem ser definidas, incluindo a proteção de uma única mensagem, ou até mesmo de campos específicos dentro de uma mensagem. Esses refinamentos são menos úteis do que a técnica ampla, e podem ainda ser mais complexos e mais dispendiosos de serem implementados.

O outro aspecto da confidencialidade é a proteção do fluxo de tráfego contra análise. Isso exige que um atacante não consiga observar a origem e o destino, a frequência, o tamanho ou outras características do tráfego em uma comunicação.

Integridade de dados

Assim como a confidencialidade, a integridade pode se aplicar a um fluxo de mensagens, a uma única mensagem ou a campos selecionados dentro de uma mensagem. Novamente, a técnica mais útil e direta é a proteção total do fluxo.

Um serviço de integridade orientado à conexão, que lida com um fluxo de mensagens, garante que elas sejam recebidas conforme enviadas, sem duplicação, inserção, modificação, reordenação ou repasses. A destruição dos dados também está coberta sob esse serviço. Assim, o serviço de integridade orientada à conexão relaciona-se tanto à modificação do fluxo de mensagem quanto à negação de serviço. Por outro lado, um serviço de integridade sem conexão, que lida com mensagens individuais sem considerar qualquer contexto maior, geralmente oferece proteção apenas contra modificação da mensagem.

Podemos fazer uma distinção entre o serviço com e o sem recuperação. Como o serviço de integridade se relaciona com ataques ativos, tratamos da detecção em vez da prevenção. Se uma violação de integridade for detectada, então o serviço pode simplesmente informar essa violação, e alguma outra parte do software ou intervenção humana será necessária para se recuperar da violação. Como alternativa, existem mecanismos disponíveis para recuperar-se da perda de integridade de dados, conforme veremos mais adiante. A incorporação de mecanismos de recuperação automatizados, em geral, é a opção mais atraente.

Irretratabilidade

A irretratabilidade impede que o emissor ou o receptor neguem uma mensagem transmitida. Assim, quando uma mensagem é enviada, o receptor pode provar que o emissor alegado de fato a transmitiu. De modo semelhante, quando uma mensagem é recebida, o emissor pode provar que o receptor alegado de fato a obteve.

Serviço de disponibilidade

Tanto X.800 quanto RFC 4949 definem a disponibilidade como a propriedade de um sistema ou de um recurso do sistema de ser acessível e utilizável sob demanda por uma entidade autorizada, de acordo com especificações de desempenho (ou seja, um sistema está disponível se oferecer serviços de acordo com a sua arquitetura sempre que for solicitado pelos usuários). Diversos ataques podem resultar na perda ou na redução da disponibilidade. Alguns deles são favoráveis a contramedidas automatizadas, como autenticação e encriptação, enquanto outros exigem algum tipo de ação física para impedir ou recuperar-se da perda de disponibilidade dos elementos de um sistema distribuído.

X.800 trata a disponibilidade como uma propriedade a ser associada a vários serviços de segurança. Porém, faz sentido convocar especificamente um serviço de disponibilidade, que é aquele que protege um sistema para garantir sua disponibilidade. Esse serviço lida com as questões de segurança levantadas pelos ataques de negação de serviço. Ele depende do gerenciamento e do controle apropriado dos recursos do sistema, e, sendo assim, depende do serviço de controle de acesso e outros serviços de segurança.

1.5 MECANISMOS DE SEGURANÇA

O Quadro 1.3 lista os mecanismos de segurança definidos na recomendação X.800. Como podemos ver, os mecanismos são divididos entre aqueles implementados em uma camada de protocolo específica, como TCP ou protocolo da camada de aplicação, e aqueles que não são específicos a camadas de protocolo ou serviços de segurança em particular. Esses mecanismos serão abordados nos lugares apropriados no livro, e, portanto, não trataremos deles agora, exceto para comentar sobre a definição da codificação. X.800 distingue entre mecanismos de codificação reversíveis e irreversíveis. Um mecanismo de codificação reversível é simplesmente um algoritmo de encriptação que permite que os dados sejam encriptados e, então, decryptados. Mecanismos de codificação irreversíveis incluem algoritmos de *hash* e códigos de autenticação de mensagem, que são usados em aplicações de assinatura digital e autenticação de mensagem.

Quadro 1.3 Mecanismos de segurança (X.800).

MECANISMOS DE SEGURANÇA ESPECÍFICOS	MECANISMOS DE SEGURANÇA DIFUSOS
Podem ser incorporados à camada de protocolo apropriada a fim de oferecer alguns dos serviços de segurança OSI. Codificação O uso de algoritmos matemáticos para transformar os dados para um formato que não seja prontamente inteligível. A transformação e subsequente recuperação dos dados depende de um algoritmo e zero ou mais chaves de encriptação. Assinatura digital Dados anexados a (ou uma transformação criptográfica de) uma unidade de dados que permite que um destinatário dela prove sua origem e integridade e a proteja contra falsificação (por exemplo, pelo destinatário). Controle de acesso Uma série de mecanismos que impõem direitos de acesso aos recursos. Integridade de dados Uma série de mecanismos utilizados para garantir a integridade de uma unidade de dados ou fluxo de unidades de dados. Troca de autenticação Um mecanismo intencionado a garantir a identidade de uma entidade por meio da troca de informações. Preenchimento de tráfego A inserção de bits nas lacunas de um fluxo de dados para frustrar as tentativas de análise de tráfego. Controle de roteamento Permite a seleção de determinadas rotas fisicamente seguras para certos dados e mudanças de roteamento, sobretudo quando uma brecha de segurança é suspeitada. Notarização O uso de um terceiro confiável para garantir certas propriedades de uma troca de dados.	Mecanismos que não são específicos a qualquer serviço de servidor OSI ou camada de protocolo específica. Funcionalidade confiada Aquilo que é percebido como sendo correto com relação a alguns critérios (por exemplo, conforme estabelecido por uma política de segurança). Rótulo de segurança A marcação vinculada a um recurso (que pode ser uma unidade de dados) que nomeia ou designa os atributos de segurança desse recurso. Deteção de evento Deteção de eventos relevantes à segurança. Trilha de auditoria de segurança Dados coletados e potencialmente utilizados para facilitar uma auditoria de segurança, que é uma revisão e exame independentes dos registros e das atividades do sistema. Recuperação de segurança Lida com solicitações de mecanismos, como funções de tratamento e gerenciamento de eventos, e toma medidas de recuperação.

O Quadro 1.4, baseado na recomendação X.800, indica o relacionamento entre serviços e mecanismos de segurança.

Quadro 1.4 Relacionamento entre serviços e mecanismos de segurança.

SERVIÇO	MECANISMO							
	Codificação	Assinatura digital	Controle de acesso	Integridade de dados	Troca de autenticação	Preenchimento de tráfego	Controle de roteamento	Notarização
Autenticação de entidade pareada	S	S			S			
Autenticação da origem de dados	S	S						
Controle de acesso			S					
Confidencialidade	S					S		
Confidencialidade do fluxo de tráfego	S					S	S	
Integridade de dados	S	S		S				
Responsabilização		S		S				S
Disponibilidade				S	S			

1.6 UM MODELO PARA SEGURANÇA DE REDE

Um modelo para grande parte do que estaremos discutindo é capturado, em termos muito gerais, na Figura 1.2. Uma mensagem deve ser transferida de uma parte para outra por meio de algum tipo de inter-rede. As duas partes, que são os *principais* nessa transação, precisam cooperar para que a troca ocorra. Um canal de informação lógico é estabelecido definindo-se uma rota pela inter-rede da origem ao destino, e pelo uso cooperativo de protocolos de comunicação (por exemplo, TCP/IP) pelos dois principais.

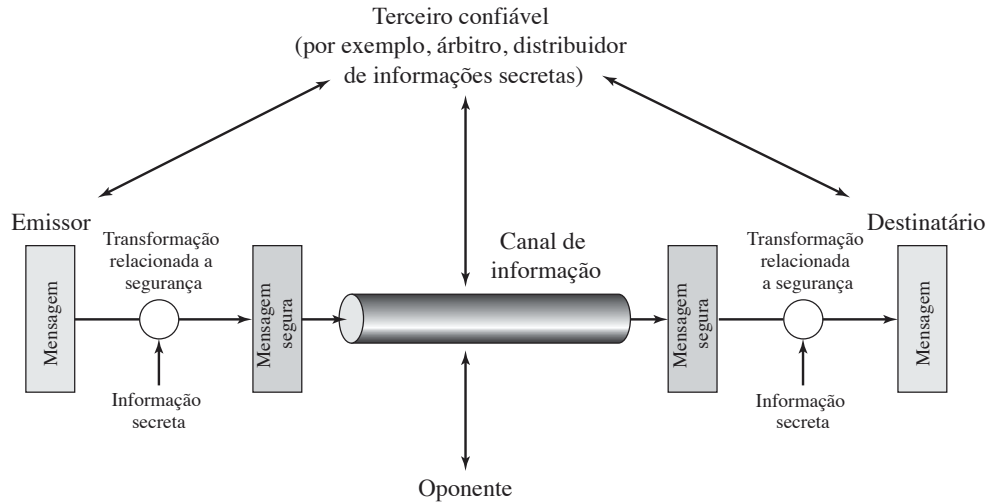
Os aspectos de segurança entram em cena quando é necessário ou desejável proteger a transmissão de informações de um oponente que pode apresentar uma ameaça à confidencialidade, autenticidade, e assim por diante. As técnicas para oferecer segurança possuem dois componentes:

- Uma transformação relacionada à segurança sobre a informação a ser enviada. Alguns exemplos incluem a encriptação da mensagem, que a “embaralha” de modo que fique ilegível pelo oponente, e o acréscimo de um código com base no conteúdo da mensagem, que pode ser usado para verificar a identidade do emissor.
- Alguma informação secreta compartilhada pelos dois principais e, espera-se, ser desconhecida do oponente. Um exemplo é uma chave de encriptação usada com a transformação para embaralhar a mensagem antes da transmissão e desembaralhá-la no recebimento.⁶

Um terceiro confiável pode ser necessário para se conseguir uma transmissão segura. Por exemplo, um terceiro pode ser responsável por distribuir a informação secreta aos dois principais, enquanto a protege contra qualquer oponente. Ou, então, um terceiro talvez seja necessário para arbitrar disputas entre os dois principais com relação à autenticidade de uma transmissão de mensagem.

Esse modelo geral mostra que existem quatro tarefas básicas no projeto de um serviço de segurança em particular:

⁶ A Parte 2 discute uma forma de encriptação, conhecida como encriptação assimétrica, em que somente um dos dois principais precisa ter a informação secreta.

Figura 1.2 Modelo para segurança de rede.

1. Crie um algoritmo para realizar a transformação relacionada à segurança. O algoritmo deverá ser tal que um oponente não possa reverter sua finalidade.
2. Gere a informação secreta a ser usada com o algoritmo.
3. Desenvolva métodos para a distribuição e compartilhamento da informação secreta.
4. Especifique um protocolo a ser usado pelos dois principais, que utilize o algoritmo de segurança e a informação secreta para estabelecer determinado serviço de segurança.

As Partes de 1 a 5 deste livro se concentram nos tipos de mecanismos e serviços de segurança que se encaixam no modelo mostrado na Figura 1.2. Porém, existem outras situações de interesse, relacionadas à segurança, que não se adequam bem a esse modelo, mas que são consideradas. Um modelo geral dessas outras situações é ilustrado pela Figura 1.3, que reflete uma preocupação por proteger um sistema de informação contra acesso indesejado. A maioria dos leitores está familiarizada com os problemas causados pela existência de hackers, que tentam penetrar em sistemas que são passíveis de ser acessados por uma rede. Um hacker pode ser alguém que, sem intenção maliciosa, simplesmente se satisfaz em romper e entrar em um sistema de computador. Ou, então, o intruso pode ser um funcionário aborrecido, que deseja causar danos, ou um criminoso que busca explorar recursos do computador para obter lucro financeiro (por exemplo, obter números de cartão de crédito ou realizar transferências ilegais de dinheiro).

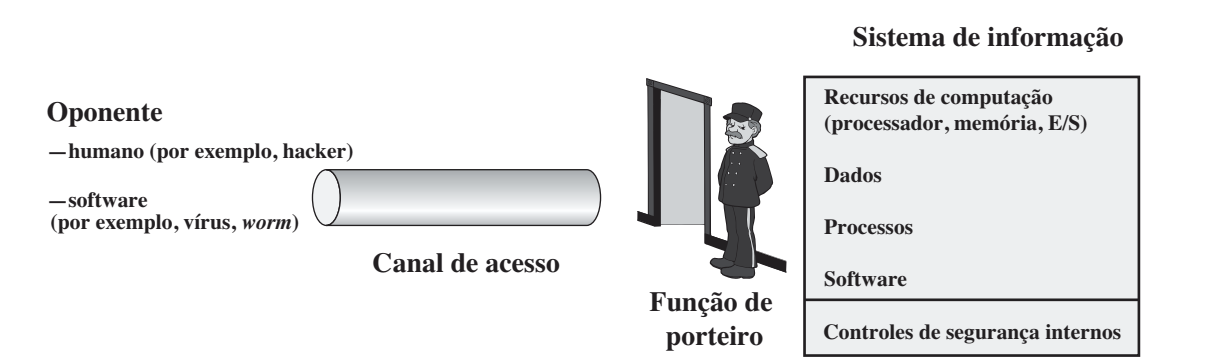
Outro tipo de acesso indesejado é a colocação, em um sistema computadorizado, de uma lógica que explore as vulnerabilidades no sistema e que possa afetar programas de aplicação e utilitários, como editores e compiladores. Os programas podem apresentar dois tipos de ameaças:

- **De acesso à informação:** interceptam ou modificam dados em favor de usuários que não deveriam ter acesso a eles.
- **De serviço:** exploram falhas de serviço nos computadores, para inibir seu acesso por usuários autorizados.

Vírus e *worms* são dois exemplos de ataques de software, que podem ser introduzidos em um sistema por meio de um disco que contém a lógica indesejada encoberta em um software útil de outras maneiras. Eles também podem ser inseridos em um sistema por meio de uma rede; esse último mecanismo é mais preocupante em segurança de rede.

Os mecanismos de segurança necessários para se lidar com o acesso indesejado estão em duas categorias amplas (ver Figura 1.3). A primeira categoria poderia ser chamada de função de porteiro. Ela inclui procedimentos de login baseados em senha, que são criados para negar acesso a usuários não autorizados, e lógica de filtragem, que é elaborada para detectar e rejeitar *worms*, vírus e outros ataques semelhantes. Quando um usuário ou software indesejado obtém acesso, a segunda linha de defesa consiste em uma série de controles internos que monitoram a atividade e analisam a informação armazenada, em uma tentativa de detectar a presença de intrusos. Essas questões são exploradas na Parte 6.

Figura 1.3 Modelo de segurança de acesso à rede.



1.7 LEITURA RECOMENDADA

[STAL12] oferece uma ampla introdução à segurança de computador e rede. [SCHN00] é uma leitura valiosa para qualquer profissional no campo de segurança de computadores ou rede: ela discute as limitações da tecnologia, e da criptografia, em particular, proporcionando segurança, além da necessidade de considerar o hardware, a implementação do software, as redes e as pessoas envolvidas no fornecimento e ataque à segurança. É útil ler alguns dos artigos tutoriais clássicos sobre segurança de computadores; eles oferecem uma perspectiva histórica a partir da qual podem ser apreciados os trabalhos e pensamentos atuais. Os artigos que devem ser lidos são [WARE79], [BROW72], [SALT75], [SHAN77] e [SUMM84]. Duas referências mais recentes e curtas sobre segurança de computadores são [ANDR04] e [LAMP04]. [NIST95] é um tratamento profundo (290 páginas) do assunto. Outra boa referência é [NRC91]. [FRAS97] também é relevante.

ANDR04 ANDREWS, M.; WHITTAKER, J. “Computer Security”. *IEEE Security and Privacy*, set./out. 2004.

BROW72 BROWNE, P. “Computer Security — A Survey”. *ACM SIGMIS Database*, outono 1972.

FRAS97 FRASER, B. *Site Security Handbook*. RFC 2196, set. 1997.

LAMP04 LAMPSON, B. “Computer Security in the Real World”, *Computer*, jun. 2004.

NIST95 NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY. *An Introduction to Computer Security: The NIST Handbook*. Special Publication 800-12, out. 1995.

NRC91 NATIONAL RESEARCH COUNCIL. *Computers at Risk: Safe Computing in the Information Age*. Washington, D.C.: National Academy Press, 1991.

SALT75 SALTZER, J.; SCHROEDER, M. “The Protection of Information in Computer Systems”. *Proceedings of the IEEE*, set. 1975.

SCHN00 SCHNEIER, B. *Secrets and Lies: Digital Security in a Networked World*. Nova York: Wiley, 2000.

SHAN77 SHANKER, K. “The Total Computer Security Problem: An Overview”. *Computer*, jun. 1977.

STAL12 STALLINGS, W.; BROWN, L. *Computer Security*. Upper Saddle River, NJ: Prentice Hall, 2012.

SUMM84 SUMMERS, R. “An Overview of Computer Security”. *IBM Systems Journal*, Vol. 23, n. 4, 1984.

WARE79 WARE, W. (ed.). *Security Controls for Computer Systems*. RAND Report 609-1, out. 1979.

1.8 PRINCIPAIS TERMOS, PERGUNTAS PARA REVISÃO E PROBLEMAS

Principais termos

ameaça ativa	confidencialidade de dados	intruso
ameaça passiva	controle de acesso	irretratabilidade
análise de tráfego	disfarce	mecanismos de segurança
arquitetura de segurança OSI	disponibilidade	negação de serviço
ataques à segurança	criptação	repasse
autenticação	integridade	responsabilização
autenticidade	integridade de dados	serviços de segurança

Perguntas para revisão

- 1.1 O que é a arquitetura de segurança OSI?
- 1.2 Qual é a diferença entre ameaças à segurança passivas e ativas?
- 1.3 Liste e defina resumidamente as categorias de ataques passivos e ativos à segurança.
- 1.4 Liste e defina resumidamente as categorias dos serviços de segurança.
- 1.5 Liste e defina resumidamente as categorias dos mecanismos de segurança.

Problemas

- 1.1 Considere um caixa eletrônico, ATM no qual os usuários fornecem um cartão e um número de identificação pessoal (senha). Dê exemplos de requisitos de confidencialidade, integridade e disponibilidade associados com esse sistema e, em cada caso, indique o grau de importância desses requisitos.
- 1.2 Aplique o Problema 1.1 para um sistema de comutação de telefonia que faz o direcionamento de chamadas baseado no número do telefone requisitado por quem iniciou a ligação.
- 1.3 Considere um sistema de editoração eletrônica usado para produzir documentos para várias organizações.
 - a. Dê um exemplo de um tipo de publicação em que a confidencialidade dos dados armazenados é o requisito mais importante.
 - b. Dê um exemplo de um tipo de publicação no qual a integridade dos dados é o requisito mais importante.
 - c. Dê um exemplo no qual a disponibilidade é o requisito mais importante.
- 1.4 Para cada um dos seguintes recursos, determine um nível de impacto baixo, moderado ou alto à perda de confidencialidade, disponibilidade e integridade, respectivamente. Justifique suas respostas.
 - a. Uma organização gerenciando informações públicas em seu servidor web.
 - b. Uma organização de aplicação da lei gerindo informações de investigação extremamente sensíveis.
 - c. Uma organização financeira gerindo informações administrativas rotineiras (sem informações relacionadas à privacidade).
 - d. Um sistema de informação utilizado para grandes aquisições em uma organização voltada a contratações que contém dados sensíveis da fase de pré-solicitação e dados administrativos rotineiros. Avalie o impacto de haver dois conjuntos de dados separadamente e o sistema de informação único.
 - e. Uma indústria de energia contém um sistema SCADA (controle supervísório e aquisição de dados, do acrônimo em inglês para *supervisory control and data acquisition*) controlando a distribuição da energia elétrica para uma grande instalação militar. O sistema SCADA contém tanto sensores de dados em tempo real quanto informações das rotinas administrativas. Avalie o impacto de haver dois conjuntos de dados separadamente e o sistema de informação único.
- 1.5 Desenhe uma matriz similar ao Quadro 1.4 que mostre o relacionamento entre serviços de segurança e ataques.
- 1.6 Desenhe uma matriz similar ao Quadro 1.4 que mostre o relacionamento entre mecanismos de segurança e ataques.
- 1.7 Leia todos os artigos clássicos citados na Seção 1.7. Escreva uma composição com 500 a 1.000 palavras (apresentação no PowerPoint com 8 a 12 slides) que seja um resumo dos principais conceitos nesses artigos, enfatizando os comuns à maioria ou todos eles.

Técnicas clássicas de encriptação

2

TÓPICOS ABORDADOS

2.1 MODELO DE CIFRA SIMÉTRICA

Criptografia
Criptoanálise e ataque por força bruta

2.2 TÉCNICAS DE SUBSTITUIÇÃO

Cifra de César
Cifras monoalfabéticas
Cifra Playfair
Cifra de Hill
Cifras polialfabéticas
One-time pad

2.3 TÉCNICAS DE TRANSPOSIÇÃO

2.4 MÁQUINAS DE ROTOR

2.5 ESTEGANOGRAFIA

2.6 LEITURA RECOMENDADA

2.7 PRINCIPAIS TERMOS, PERGUNTAS PARA REVISÃO E PROBLEMAS

OBJETIVOS DE APRENDIZAGEM

APÓS ESTUDAR ESTE CAPÍTULO, VOCÊ SERÁ CAPAZ DE:

- ☒ Apresentar uma visão geral dos principais conceitos de criptografia simétrica.
- ☒ Explicar a diferença entre criptoanálise e ataque por força bruta.
- ☒ Entender a operação de uma cifra de substituição monoalfabética.
- ☒ Entender a operação de uma cifra polialfabética.
- ☒ Apresentar uma visão geral da cifra de Hill.
- ☒ Descrever a operação de uma máquina de rotor.

“Estou bastante familiarizado com todas as formas de escritas secretas, e eu mesmo sou autor de um monógrafo divertido sobre o assunto, no qual analiso cento e sessenta cifras separadas”, disse Holmes.

— The Adventure of the Dancing Men, Sir Arthur Conan Doyle

A encriptação simétrica, também chamada de encriptação convencional ou encriptação de chave única, era o único tipo em uso antes do desenvolvimento da encriptação por chave pública na década de 1970. Esse continua sendo de longe o mais usado dos dois tipos de encriptação. A Parte 1 avalia diversas cifras simétricas. Neste capítulo, começaremos olhando um modelo geral para o processo de encriptação simétrica; isso nos permitirá entender o contexto dentro do qual os algoritmos são usados. Em seguida, examinaremos diversos algoritmos em uso antes da era do computador. Finalmente, estudaremos rapidamente uma técnica diferente, conhecida como esteganografia. Os capítulos 3 e 5 introduzem as duas cifras simétricas mais utilizadas: DES e AES.

Antes de começar, definiremos alguns termos. Uma mensagem original é conhecida como **texto claro** (ou *plaintext*), enquanto a mensagem codificada é chamada de **texto cifrado** (ou *ciphertext*). O processo de converter um texto claro em um texto cifrado é conhecido como **cifração** ou **criptação**; restaurar o texto claro a partir do texto cifrado é **decifração** ou **decriptação**. Os muitos esquemas utilizados para a encriptação constituem a área de estudo conhecida como **criptografia**. Esse esquema é designado **sistema criptográfico** ou **cifra**. As técnicas empregadas para decifrar uma mensagem sem qualquer conhecimento dos detalhes de encriptação estão na área da **criptoanálise**, que é o que os leigos chamam de “quebrar o código”. As áreas da criptografia e criptoanálise, juntas, são chamadas de **criptologia**.

2.1 MODELO DE CIFRA SIMÉTRICA

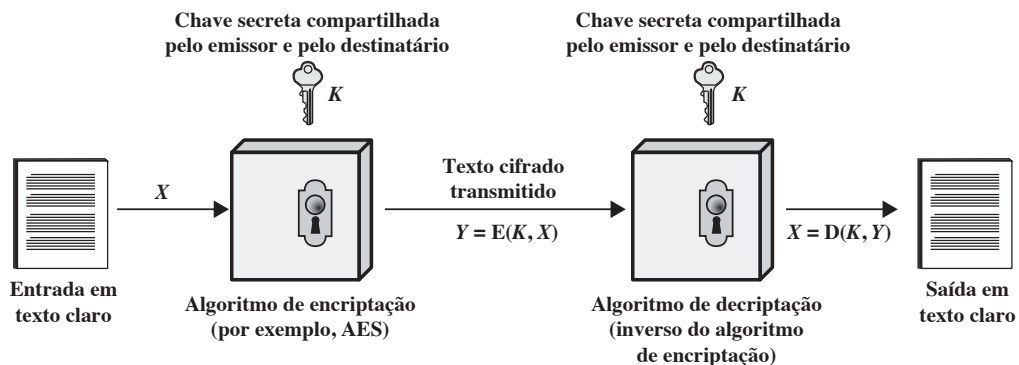
Um esquema de encriptação simétrica possui cinco itens (Figura 2.1):

- **Texto claro:** essa é a mensagem ou dados originais, inteligíveis, que servem como entrada do algoritmo de encriptação.
- **Algoritmo de encriptação:** realiza diversas substituições e transformações no texto claro.
- **Chave secreta:** também é uma entrada para o algoritmo de encriptação. A chave é um valor independente do texto claro e do algoritmo. O algoritmo produzirá uma saída diferente, dependendo da chave usada no momento. As substituições e transformações exatas realizadas pelo algoritmo dependem da chave.
- **Texto cifrado:** essa é a mensagem embaralhada, produzida como saída do algoritmo de encriptação. Ela depende do texto claro e da chave secreta. Para determinada mensagem, duas chaves diferentes produzirão dois textos cifrados distintos. O texto cifrado é um conjunto de dados aparentemente aleatório e, nesse formato, ininteligível.
- **Algoritmo de decriptação:** esse é basicamente o algoritmo de encriptação executado de modo inverso. Ele apanha o texto cifrado e a chave secreta e produz o texto claro original.

Existem dois requisitos para o uso seguro da encriptação simétrica:

1. Precisamos de um algoritmo de encriptação forte. No mínimo, gostaríamos que o algoritmo fosse tal que um oponente que conheça o algoritmo e tenha acesso a um ou mais textos cifrados seja incapaz de decifrar o texto cifrado ou descobrir a chave. Esse requisito normalmente é indicado de maneira mais forte: o oponente deverá ser incapaz de decriptar o texto cifrado ou descobrir a chave, mesmo que possua diversos textos cifrados com seus respectivos textos claros.
2. Emissor e receptor precisam ter obtido cópias da chave secreta de uma forma segura e mantê-la protegida. Se alguém conseguir descobrir a chave e o algoritmo, toda a comunicação usando essa chave poderá ser lida.

Figura 2.1 Modelo simplificado da encriptação simétrica.



Consideramos que é impraticável decriptar uma mensagem com base no texto cifrado, *mais* o conhecimento do algoritmo de encriptação/decriptação. Em outras palavras, não precisamos manter o algoritmo secreto, mas apenas a chave secreta. Essa característica da encriptação simétrica é o que a torna viável para uso generalizado. O fato de que o algoritmo não precisa ser mantido secreto significa que os fabricantes podem desenvolver, e realmente têm desenvolvido, implementações de chip de baixo custo com algoritmos de encriptação de dados. Esses chips são encontrados com facilidade e estão incorporados em diversos produtos. Com o uso da encriptação simétrica, o principal problema de segurança consiste de manter o sigilo da chave.

Vejamos mais de perto os elementos essenciais de um esquema de encriptação simétrica, usando a Figura 2.2. Uma origem produz uma mensagem em texto claro, $X = [X_1, X_2, \dots, X_M]$. Os M elementos de X são letras em algum alfabeto finito. Tradicionalmente, o alfabeto consiste de 26 letras maiúsculas. Hoje, o alfabeto binário $\{0, 1\}$ em geral é utilizado. Para a encriptação, uma chave na forma $K = [K_1, K_2, \dots, K_J]$ é gerada. Se isso acontecer na origem da mensagem, então ela também precisa ser fornecida ao destino por meio de algum canal seguro. Como alternativa, um terceiro poderia gerar a chave e oferecê-la com segurança à origem e ao destino.

Com a mensagem X e a chave de encriptação K como entradas, o algoritmo de encriptação produz o texto cifrado $Y = [Y_1, Y_2, \dots, Y_N]$. Podemos escrever isso como:

$$Y = E(K, X)$$

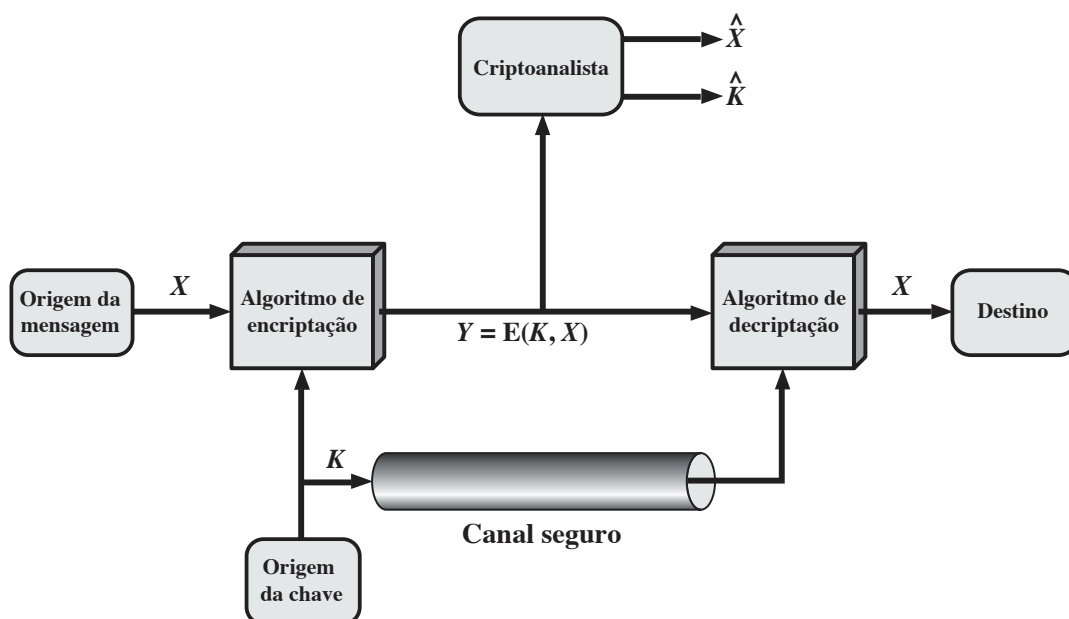
Essa notação indica que Y é produzido usando-se o algoritmo de encriptação E como função do texto claro X , com a função específica determinada pelo valor da chave K .

O receptor legítimo, de posse da chave, é capaz de inverter a transformação:

$$X = D(K, Y)$$

Um oponente, observando Y , mas não tendo acesso a K ou X , pode tentar recuperar X ou K , ou ambos. Considera-se que o oponente conhece os algoritmos de encriptação (E) e decriptação (D). Se o oponente estiver interessado apenas nessa mensagem em particular, então o foco do ataque é recuperar X , gerando uma estimativa de texto claro $\hat{X}$. Normalmente, porém, o oponente está interessado em ser capaz de ler também mensagens futuras, quando se faz uma tentativa de recuperar K , gerando uma estimativa $\hat{K}$.

Figura 2.2 Modelo de criptossistema simétrico.



Criptografia

Os sistemas criptográficos são caracterizados ao longo de três dimensões independentes:

1. **O tipo das operações usadas para transformar texto claro em texto cifrado.** Todos os algoritmos de encriptação são baseados em dois princípios gerais: substituição, em que cada elemento no texto claro (bit, letra, grupo de bits ou letras) é mapeado em outro elemento, e transposição, em que os elementos no texto claro são rearranjados. O requisito fundamental é que nenhuma informação seja perdida (ou seja, que todas as operações sejam reversíveis). A maioria dos sistemas envolve vários estágios de substituições e transposições (sendo chamados de *sistemas de produto*).
2. **O número de chaves usadas.** Se tanto o emissor quanto o receptor utilizarem a mesma chave, o sistema é considerado de encriptação simétrica, de chave única, de chave secreta ou convencional. Se emissor e receptor usarem chaves diferentes, o sistema é considerado de encriptação assimétrica, de duas chaves ou de chave pública.
3. **O modo em que o texto claro é processado.** Uma *cifra de bloco* processa a entrada de um bloco de elementos de cada vez, produzindo um de saída para cada de entrada. Uma *cifra em fluxo* processa os elementos da entrada continuamente, proporcionando a saída de um elemento de cada vez.

Criptanálise e ataque por força bruta

Em geral, o objetivo de atacar um sistema de encriptação é recuperar a chave em uso, em vez de simplesmente recuperar o texto claro a partir de um único texto cifrado. Existem duas técnicas gerais para o ataque a um esquema de encriptação convencional:

- **Criptanálise:** os ataques criptoanalíticos utilizam-se da natureza do algoritmo, e talvez de mais algum conhecimento das características comuns ao texto claro, ou ainda de algumas amostras de pares de texto claro-texto cifrado. Esse tipo de ataque explora as características do algoritmo para tentar deduzir um texto claro específico ou a chave utilizada.
- **Ataque por força bruta:** o atacante testa todas as chaves possíveis em um trecho do texto cifrado, até obter uma tradução inteligível para o texto claro. Na média, metade de todas as chaves possíveis precisam ser experimentadas para então se obter sucesso.

Se algum dos tipos de ataque tiver sucesso na dedução da chave, o efeito é catastrófico: todas as mensagens futuras e passadas, encriptadas com essa chave, ficam comprometidas.

Primeiro, consideramos a criptanálise, e depois os ataques por força bruta.

O Quadro 2.1 resume os diversos tipos de **ataques de criptanálise**, baseados na quantidade de informação conhecida pelo criptoanalista. O cenário mais difícil surge quando a única informação disponível é *apenas o texto cifrado*. Em alguns casos, nem sequer o algoritmo de encriptação é conhecido, mas em geral podemos considerar que o oponente sabe qual é o algoritmo usado para a encriptação. Um ataque sob essas circunstâncias é a técnica de força bruta de testar todas as chaves possíveis. Se o espaço de chaves for muito grande, isso se torna impraticável. Assim, o oponente precisa contar com uma análise baseada apenas no texto cifrado, geralmente aplicando diversos testes estatísticos a ele. Para usar essa técnica, o oponente necessita ter alguma ideia geral do tipo de texto claro que está encoberto, como um texto em inglês ou francês, um arquivo EXE, um código fonte em Java, um arquivo de contabilidade, e assim por diante.

O ataque apenas com texto cifrado é o mais fácil de ser defendido, pois o oponente tem a quantidade mínima de informação para trabalhar. Em muitos casos, porém, o analista tem mais informações. Ele pode ser capaz de capturar uma ou mais mensagens de texto claro, além de suas encriptações. Ou então pode saber que certos padrões de texto claro aparecerão em uma mensagem. Por exemplo, um arquivo codificado no formato Postscript sempre começa com o mesmo padrão, ou pode ter um cabeçalho ou *banner* padronizado para uma mensagem de transferência eletrônica financeira, e assim por diante. Todos esses exemplos são de *texto claro conhecido*. Ciente disso, o analista pode ser capaz de deduzir a chave com base no modo como o texto claro conhecido é transformado.

Bastante relacionado ao ataque de texto claro conhecido é o que poderia ser chamado de ataque de palavra provável. Se o oponente estiver trabalhando com a encriptação de alguma mensagem de texto geral, ele talvez tenha pouco conhecimento do que está nela. Porém, se o oponente estiver atrás de alguma informação muito

Quadro 2.1 Tipos de ataque sobre mensagens encriptadas.

TIPO DE ATAQUE	CONHECIDO AO CRIPTOANALISTA
Apenas texto cifrado	■ Algoritmo de encriptação ■ Texto cifrado
Texto claro conhecido	■ Algoritmo de encriptação ■ Texto cifrado ■ Um ou mais pares de texto claro-texto cifrado produzidos pela chave secreta
Texto claro escolhido	■ Algoritmo de encriptação ■ Texto cifrado ■ Mensagem de texto claro escolhida pelo criptoanalista, com seu respectivo texto cifrado gerado com a chave secreta
Texto cifrado escolhido	■ Algoritmo de encriptação ■ Texto cifrado ■ Texto cifrado escolhido pelo criptoanalista, com seu respectivo texto claro decriptado produzido pela chave secreta
Texto escolhido	■ Algoritmo de encriptação ■ Texto cifrado ■ Mensagem de texto claro escolhida pelo criptoanalista, com seu respectivo texto cifrado produzido pela chave secreta ■ Texto cifrado escolhido pelo criptoanalista, com seu respectivo texto claro decriptado produzido pela chave secreta

específica, então partes da mensagem podem ser conhecidas. Por exemplo, se um arquivo de contabilidade estiver sendo transmitido, o oponente pode conhecer o posicionamento de certas palavras-chave no cabeçalho do arquivo. Em outro caso, o código fonte para um programa desenvolvido pela Empresa X poderia incluir uma nota de direito autoral em alguma posição padronizada.

Se o analista de alguma forma for capaz de fazer a origem inserir no sistema uma mensagem escolhida por ele, então o ataque de *texto claro escolhido* é possível. Um exemplo dessa estratégia é a criptoanálise diferencial, explicada no Capítulo 3. Em geral, se o analista for capaz de escolher as mensagens a encriptar, ele poderá escolher de forma deliberada padrões que talvez revelarão a estrutura da chave.

O Quadro 2.1 lista dois outros tipos de ataque: texto cifrado escolhido e texto escolhido. Estes são menos empregados como técnicas criptoanalíticas, mas são possíveis meios de ataque.

Somente algoritmos relativamente fracos não conseguem resistir a um ataque de texto cifrado. Em geral, um algoritmo de encriptação é projetado para aguentar a um ataque de texto claro conhecido.

Duas outras definições merecem ser comentadas. Um esquema de encriptação é **incondicionalmente seguro** se o texto cifrado gerado por ele não tiver informação suficiente para determinar exclusivamente o texto claro correspondente, não importa quanto texto cifrado esteja à disposição. Ou seja, é indiferente quanto tempo um oponente tem, ele não tem como decriptar o texto cifrado, simplesmente porque a informação exigida não está lá. Com a exceção de um esquema conhecido como *one-time pad* (descrito mais adiante neste capítulo), não existe algoritmo de encriptação que seja incondicionalmente seguro. Portanto, tudo o que os usuários de um algoritmo de encriptação podem se esforçar para obter é um algoritmo que atenda a um ou a ambos os critérios a seguir:

- O custo para quebrar a cifra ultrapassa o valor da informação encriptada.
- O tempo exigido para quebrar a cifra supera o tempo de vida útil da informação.

Um esquema de encriptação é considerado **computacionalmente seguro** se um desses dois critérios for atendido. O problema é que é muito difícil estimar a quantidade de esforço exigido para criptoanalisar textos cifrados com sucesso.

Todas as formas de criptoanálise para esquemas de encriptação simétricos são projetadas para explorar o fato de que rastros da estrutura ou do padrão do texto claro podem sobreviver à encriptação e ser discerníveis no texto cifrado. Isso se tornará mais claro à medida que examinarmos diversos esquemas de encriptação

simétrica neste capítulo. Na Parte 2, veremos que a criptoanálise para esquemas de chave pública partem de uma premissa fundamentalmente diferente, a saber, de que as propriedades matemáticas do par de chaves possibilitam que uma das duas chaves seja deduzida a partir da outra.

Um **ataque por força bruta** envolve a tentativa de cada chave possível até que seja obtida uma tradução inteligível de texto cifrado para texto claro. Em média, metade de todas as chaves possíveis precisa ser experimentada para se obter sucesso. Ou seja, se houver X chaves diferentes, um intruso descobriria a verdadeira após $X/2$ tentativas, em média. É importante observar que há mais coisas em um ataque por força bruta do que simplesmente testar todas as chaves possíveis. A menos que seja fornecido um texto claro conhecido, o analista deverá ser capaz de reconhecê-lo como tal. Se a mensagem for simplesmente texto claro em inglês, então o resultado aparece facilmente, embora a tarefa de reconhecer o inglês tenha que ser automatizada. Se a mensagem de texto foi compactada antes da encriptação, então o reconhecimento é mais difícil. E, se a mensagem for de algum tipo mais geral de dado, como um arquivo numérico, e este tiver sido compactado, o problema se torna ainda mais difícil de automatizar. Assim, para suplementar o método por força bruta, é preciso haver algum grau de conhecimento sobre o texto claro esperado, além de algum meio de distinguir automaticamente o texto claro de dados aleatórios.

2.2 TÉCNICAS DE SUBSTITUIÇÃO

Nesta seção e na próxima, examinaremos algumas técnicas de encriptação clássicas. Um estudo dessas técnicas nos permite ilustrar aquelas básicas da encriptação simétrica usadas hoje e os tipos de ataque criptoanalítico que precisam ser antecipados.

Os dois blocos de montagem básicos de todas as técnicas de encriptação são substituição e transposição. Vamos examiná-los nas duas seções seguintes. Por fim, discutiremos um sistema que combina substituição e transposição.

Uma técnica de substituição é aquela em que as letras do texto claro são substituídas por outras letras, números ou símbolos.¹ Se o texto claro for visto como uma sequência de bits, então a substituição envolve trocar padrões de bits de texto claro por padrões de bits de texto cifrado.

Cifra de César

O uso mais antigo que conhecemos de uma cifra de substituição, e o mais simples, foi feito por Júlio César. A cifra de César envolve substituir cada letra do alfabeto por aquela que fica três posições adiante. Por exemplo,

claro: meet me after the toga party
cifra: PHHW PH DIWHU WKH WRJD SDUWB

Observe que o alfabeto recomeça no final, de modo que a letra após Z é A. Podemos definir a transformação listando todas as alternativas, da seguinte forma:

claro: a b c d e f g h i j k l m n o p q r s t u v w x y z
cifra: D E F G H I J K L M N O P Q R S T U V W X Y Z A B C

Vamos atribuir um equivalente numérico a cada letra:

a	b	c	d	e	f	g	h	i	j	k	l	m
0	1	2	3	4	5	6	7	8	9	10	11	12

n	o	p	q	r	s	t	u	v	w	x	y	z
13	14	15	16	17	18	19	20	21	22	23	24	25

¹ Quando envolvem letras, as convenções a seguir são usadas neste livro. Texto claro está sempre em minúsculas; texto cifrado está em maiúsculas; os valores de chave estão em minúsculas e itálico.

Então, o algoritmo pode ser expresso da forma a seguir. Para cada letra em texto claro p , substitua-a pela letra do texto cifrado C :²

$$C = E(3, p) = (p + 3) \bmod 26$$

Um deslocamento pode ser de qualquer magnitude, de modo que o algoritmo de César geral é

$$C = E(k, p) = (p + k) \bmod 26 \quad (2.1)$$

onde k assume um valor no intervalo de 1 a 25. O algoritmo de decifração é simplesmente

$$p = D(k, C) = (C - k) \bmod 26 \quad (2.2)$$

Se for conhecido que determinado texto cifrado é uma cifra de César, então uma criptoanálise pela força bruta será facilmente realizada. Basta experimentar todas as 25 chaves possíveis. A Figura 2.3 mostra os resultados da aplicação dessa estratégia ao texto cifrado do exemplo. Nesse caso, o texto claro aparece na terceira fileira.

Três características importantes desse problema nos permitiram usar a criptoanálise pela força bruta:

1. Os algoritmos de encriptação e decifração são conhecidos.
2. Existem apenas 25 chaves para experimentar.
3. A linguagem do texto claro é conhecida e facilmente reconhecível.

Figura 2.3 Criptoanálise por força bruta da cifra de César.

CHAVE	PHHW	PH	DIWHU	WKH	WRJD	SDUWB
1	oggv	og	chvgt	vjg	vqic	rctva
2	nffu	nf	bgufs	uif	uphb	qbsuz
3	meet	me	after	the	toga	party
4	ldds	ld	zesdq	sgd	snfz	ozqsx
5	kccr	kc	ydrpc	rfc	rmey	nyprw
6	jbbq	jb	xcqbo	qeb	qldx	mxoqv
7	iaap	ia	wbpan	pda	pkcw	lwnpu
8	hzzo	hz	vaozm	ocz	objv	kvmot
9	gyyn	gy	uznyl	nby	niau	julns
10	fxxm	fx	tymxk	max	mhzt	itkmr
11	ewwl	ew	sxlwj	lzw	lgys	hsjlg
12	dvvk	dv	rwkvi	kyv	kfxr	grikp
13	cuuj	cu	qvjuh	jxu	jewq	fqhjo
14	btti	bt	putig	iwt	idvp	epgin
15	assh	as	othsf	hvs	hcuo	dofhm
16	zrrg	zr	nsgre	gur	gbtn	cnegl
17	yqqf	yq	mrfqd	ftq	fasm	bmdfk
18	xppe	xp	lqepc	esp	ezrl	alcej
19	wood	wo	kpdob	dro	dyqk	zkbdi
20	vnnc	vn	jocna	cqn	cxpj	yjach
21	ummb	um	inbmz	bpm	bwoi	xizbg
22	tlla	tl	hmaly	aol	avnh	whyaf
23	skkz	sk	glzkk	znk	zumg	vgxze
24	rjyy	rj	fkyjw	ymj	ytlf	ufwyd
25	qiix	qi	ejxiv	xli	xske	tevxk

² Definimos $a \bmod n$ como sendo o resto quando a é dividido por n . Por exemplo, $11 \bmod 7 = 4$. Veja, no Capítulo 4, uma discussão mais detalhada sobre aritmética modular.

Na maioria das situações de rede, podemos considerar que os algoritmos são conhecidos. O que geralmente torna a criptoanálise pela força bruta impraticável é o uso de um algoritmo que emprega um grande número de chaves. Por exemplo, o algoritmo *Triple DES*, examinado no Capítulo 6, utiliza uma chave de 168 bits, gerando um espaço de chave de 2^{168} , ou mais de $3,7 \times 10^{50}$ chaves possíveis.

A terceira característica também é significativa. Se a linguagem do texto claro for desconhecida, então a saída de texto claro pode não ser reconhecível. Além do mais, a entrada pode ser abreviada ou compactada de alguma maneira, novamente dificultando o reconhecimento. Por exemplo, a Figura 2.4 mostra uma parte de um arquivo de texto compactada usando um algoritmo chamado ZIP. Se esse arquivo for então encriptado com uma cifra de substituição simples (expandida para incluir mais do que apenas 26 caracteres alfabéticos), então o texto claro não poderá ser reconhecido quando for revelado na criptoanálise por força bruta.

Figura 2.4 Exemplo de texto compactado.

```

~+Wµ"- Ω-0)≤4{∞‡, ë~Ω%ràü·-í Ø-Z-
Ú#20#Åæð æ«q7,Ωn·@3N0Ú Çz'Y-f∞Í[±Ů_ èΩ,<NO-±«~xã Åäfeü3Å
x}ö$ke^Å
_yí ^ÉÉ] ,µ J/'iTê&1 'c<uΩ-
ÄD(G WÄC~Y_iöÄW PÖ1«fÜ+ç],µ;~î^üÑπ~≈~L^90gflo~&æ≤ ~≤ ØØ$":
^æ!SGqèvo^ ú\,S>h<-*6ø‡%x""|ñ0#≈~my%~≥ñP<,fi Åj Åð;~Zù-
Ω"Ö-6æY{%,ΩÊó ,i π+Äî'ú02çSÿ'O-
2Äñßi /@^"ΠK^=PÇπ,úé^'3Σ~ö^Ôzî"Y-ÿΩæY> Ω+eð/'<Kf;~*+~"≤û~
B ZøK~Qßÿüf,!òñfzss/]>ÈQ ü

```

Cifras monoalfabéticas

Com apenas 25 chaves possíveis, a cifra de César está longe de ser segura. Um aumento dramático no espaço de chave pode ser conseguido permitindo-se uma substituição arbitrária. Antes de prosseguir, definimos o termo *permutação*. Uma **permutação** é um conjunto finito de elementos S em uma sequência ordenada de todos os elementos de S , com cada um aparecendo exatamente uma vez. Por exemplo, se $S = \{a, b, c\}$, existem seis permutações de S :

abc, acb, bac, bca, cab, cba

Em geral, existem $n!$ permutações de um conjunto de n elementos, pois o primeiro deles pode ser escolhido de n maneiras, o segundo, de $n - 1$ maneiras, o terceiro, de $n - 2$ maneiras, e assim por diante.

Lembre-se da atribuição para a cifra de César:

```

claro: a b c d e f g h i j k l m n o p q r s t u v w x y z
cifra: D E F G H I J K L M N O P Q R S T U V W X Y Z A B C

```

Se, em vez disso, a linha “cifra” puder ser qualquer permutação dos 26 caracteres alfabéticos, então haverá $26!$ ou mais do que 4×10^{26} chaves possíveis. Isso significa 10 ordens de grandeza a mais do que o espaço de chave para DES, e evitaria qualquer técnica de força bruta para criptoanálise. Essa técnica é conhecida como **cifra por substituição monoalfabética**, pois um único alfabeto de cifra (mapeando do alfabeto claro para um cifrado) é utilizado por mensagem.

Porém, existe outra linha de ataque. Se o criptoanalista souber a natureza do texto claro (por exemplo, texto em inglês não compactado), então o analista poderá explorar as regularidades da linguagem. Para ver como essa criptoanálise poderia prosseguir, damos um exemplo parcial aqui, que é adaptado de outro em [SINK09]. O texto cifrado a ser resolvido é

```

UZQSOVUOHXMOPVGPOZPEVSGZWSZOPFPESXUDBMETSXAIZ
VUEPHZHMDZSHZOWSFPAPPDTSVPPQUZWMYXUZUHSX
EPEYPOPDZSZUFPOMBZWPFUPZHMDJUDTMOHMQ

```

Como um passo inicial, a frequência relativa das letras poderá ser determinada e comparada com uma distribuição de frequência padrão para o inglês, como vemos na Figura 2.5 (com base em [LEWA00]). Se a mensagem fosse longa o suficiente, essa técnica talvez tivesse sucesso, mas, como essa é relativamente curta,

não podemos esperar uma combinação exata. De qualquer forma, as frequências relativas das letras no texto cifrado (em porcentagens) são as seguintes:

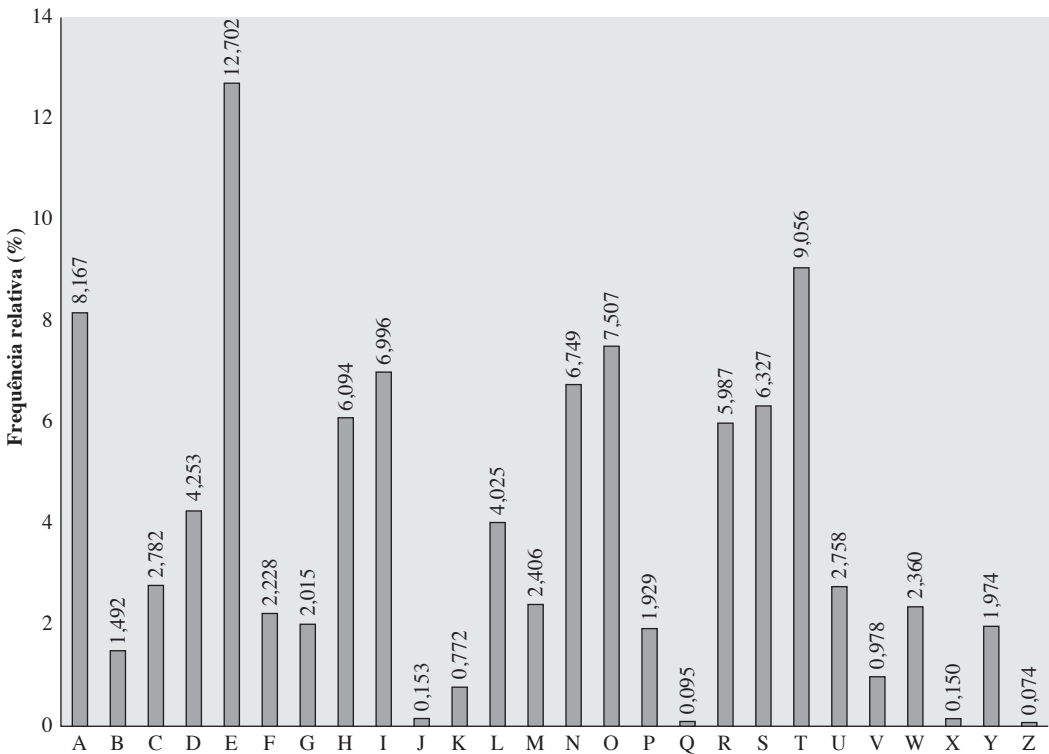
P 13,33	H 5,83	F 3,33	B 1,67	C 0,00
Z 11,67	D 5,00	W 3,33	G 1,67	K 0,00
S 8,33	E 5,00	Q 2,50	Y 1,67	L 0,00
U 8,33	V 4,17	T 2,50	I 0,83	N 0,00
O 7,50	X 4,17	A 1,67	J 0,83	R 0,00
M 6,67				

Comparando esses dados com a Figura 2.5, parece provável que as letras cifradas P e Z sejam equivalentes às letras do texto claro e e t, mas não se sabe ao certo quem é quem. As letras S, U, O, M e H são todas de frequência relativamente alta e é provável que correspondem às que estão no conjunto {a, h, i, n, o, r, s}. As letras com frequências mais baixas (a saber, A, B, G, Y, I, J) provavelmente estão incluídas no conjunto {b, j, k, q, v, x, z}.

Neste ponto, existem diversas maneiras de prosseguir. Poderíamos fazer algumas tentativas de atribuição e começar a preencher o texto claro para ver se ele tem um “esqueleto” pertinente a uma mensagem. Uma técnica mais sistemática é procurar outras regularidades. Por exemplo, talvez saber que certas palavras estão no texto. Ou então poderíamos procurar sequências repetidas de letras cifradas e tentar deduzir seus equivalentes no texto claro.

Uma ferramenta poderosa é examinar a frequência de combinações de duas letras, conhecidas como **digramas**. Uma tabela semelhante à Figura 2.5 poderia ser montada para mostrar a frequência relativa dos digramas. O mais comum deles é th. Em nosso texto cifrado, o digrama mais comum é ZW, que aparece três vezes. Assim, fazemos a correspondência de Z com t e de W com h. Depois, pela nossa hipótese anterior, podemos igualar P com e. Agora, observe que a sequência ZWP aparece no texto cifrado, e podemos traduzir essa sequência como “the”. Esse é o trigramma (combinação de três letras) mais frequente em inglês, o que parece indicar que estamos no caminho certo.

Figura 2.5 Frequência relativa de letras no texto em inglês.



Em seguida, observe a sequência ZWSZ na primeira linha. Não sabemos que essas quatro letras compõem uma palavra completa, mas, se sim, ela tem a forma th_t. Nesse caso, S é igual a a.

Até aqui, então, temos

```
UZQSOVUOHXMOPVGPOZPEVSGZWSZOPFPESXUDBMETSXAIZ
t a e e te a that e e a a
VUEPHZHMDZSHZOWSFPAPPDTSVPQUZWMXUZHUSX
e t ta t ha e ee a e th t a
EPYEPOPDZSZUFPOMBZWPFPUPZHMDJUDTMOHMQ
e e e tat e the t
```

Somente quatro letras foram identificadas, mas já temos um bom pedaço da mensagem. A análise continuada das frequências, mais tentativa e erro, deverão facilmente gerar uma solução a partir desse ponto. O texto claro completo, com espaços incluídos entre as palavras, é o seguinte:*

```
it was disclosed yesterday that several informal but
direct contacts have been made with political
representatives of the viet cong in moscow
```

As cifras monoalfabéticas são fáceis de se quebrar porque refletem os dados de frequência do alfabeto original. Uma contramedida é oferecer vários substitutos, conhecidos como homófonos, para uma única letra. Por exemplo, a letra e poderia ser atribuída a diversos símbolos de cifra diferentes, como 16, 74, 35 e 21, com cada homófono usado em rodízio, ou aleatoriamente. Se o número de símbolos atribuídos a cada letra for proporcional à frequência relativa dela, então a informação de frequência de única letra é completamente extinta. O grande matemático Carl Friedrich Gauss acreditava ter criado uma cifra indecifrável usando homófonos. Porém, até mesmo com homófonos, cada elemento do texto claro afeta somente um elemento do texto cifrado, e padrões de múltiplas letras (por exemplo, frequências de digrama) ainda sobrevivem no texto cifrado, tornando a criptoanálise relativamente simples.

Dois métodos principais são usados nas cifras de substituição para reduzir a extensão da estrutura sobrevivente do texto claro no cifrado. Uma técnica é encriptar várias letras do texto claro, e a outra é usar vários alfabetos de cifra. Examinamos rapidamente cada uma delas.

Cifra Playfair

A cifra de encriptação de múltiplas letras mais conhecida é a Playfair, que trata os digramas no texto claro como unidades isoladas e as traduz para digramas de texto cifrado.³

O algoritmo Playfair é baseado no uso de uma matriz 5×5 de letras construídas usando uma palavra-chave. Aqui está um exemplo, solucionado por Lord Peter Wimsey em *Have His Carcase*, de Dorothy Sayers:⁴

M	O	N	A	R
C	H	Y	B	D
E	F	G	I/J	K
L	P	Q	S	T
U	V	W	X	Z

Nesse caso, a palavra-chave é *monarchy*. A matriz é construída com o preenchimento das letras da palavra-chave (menos duplicatas) da esquerda para a direita e de cima para baixo, e depois do restante da matriz com as outras letras na ordem alfabética. As letras I e J contam como uma só. O texto claro é encriptado com duas letras de cada vez, de acordo com as seguintes regras:

³ Essa cifra, na realidade, foi inventada pelo cientista britânico Sir Charles Wheatstone em 1854, mas recebeu o nome de seu amigo Barão Playfair de St. Andrews, que a defendeu na agência estrangeira da Grã Bretanha.

⁴ O livro fornece um relato fascinante de um ataque de palavra provável.

* N. do Ed.: “Foi revelado ontem que diversos contatos informais, mas diretos, tem sido feitos com representantes políticos dos vietcongues em Moscou”

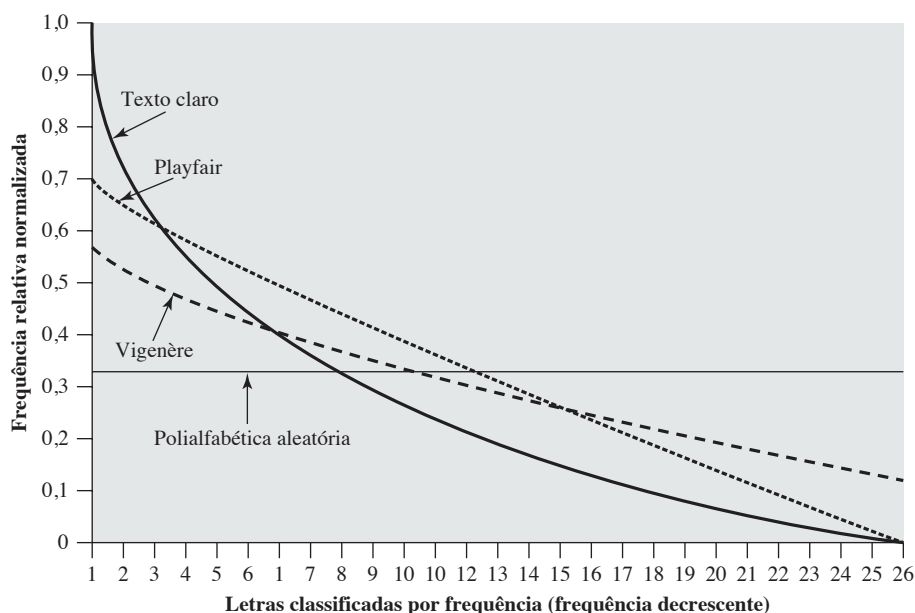
1. Letras de texto claro repetidas que estão no mesmo par são separadas por uma de preenchimento, como x, de modo que *balloon* seria tratado como ba lx lo on.
2. Duas letras de texto claro que estejam na mesma linha da matriz são substituídas pela letra à direita, com o primeiro elemento da linha vindo após o último, de forma rotativa. Por exemplo, ar é encriptado como RM.
3. Duas letras de texto claro que estejam na mesma coluna são substituídas pela letra abaixo, com o elemento de cima da coluna vindo após o último, de forma rotativa. Por exemplo, mu é encriptado como CM.
4. Caso contrário, cada letra de texto claro em um par é substituída por aquela que esteja em sua própria linha e na coluna ocupada pela outra letra de texto claro. Assim, hs torna-se BP, e ea torna-se IM (ou JM, a critério do cifrador).

A cifra Playfair é um grande avanço em relação às cifras monoalfabéticas simples. Primeiramente, enquanto existem apenas 26 letras, existem $26 \times 26 = 676$ digramas, de modo que a identificação de digramas individuais é mais difícil. Além do mais, as frequências relativas das letras individuais exibem um intervalo muito maior do que o dos digramas, tornando a análise de frequência muito mais difícil. Por esses motivos, a cifra Playfair foi, por muito tempo, considerada indecifrável. Ela foi usada como sistema de campo padrão pelo Exército britânico na Primeira Guerra Mundial, e ainda gozava de um uso considerável pelo Exército dos Estados Unidos e outras forças aliadas durante a Segunda Guerra Mundial.

Apesar desse nível de confiança em sua segurança, a cifra Playfair é relativamente fácil de ser quebrada, pois ainda deixa intacta grande parte da estrutura da linguagem de texto claro. Algumas centenas de letras de texto cifrado geralmente são suficientes para quebrá-la.

Um modo de revelar a eficácia da Playfair e outras cifras aparece na Figura 2.6. A linha rotulada com *texto claro* apresenta a distribuição de frequência dos mais de 70.000 caracteres alfabéticos presentes no artigo sobre criptologia da Enciclopédia Britânica. Essa também é a distribuição de frequência de qualquer cifra por substituição monoalfabética, pois os valores de frequência para letras individuais são os mesmos, apenas com diferentes letras substituídas pelas originais. O gráfico foi desenvolvido da seguinte maneira: o número de ocorrência de cada letra no texto foi contado e dividido pelo da letra mais utilizada. Usando os resultados da Figura 2.5, vemos que e é a letra empregada com mais frequência. Desse modo, e tem uma frequência relativa de 1, t, de $9,056/12,702 \approx 0,72$, e assim por diante. Os pontos no eixo horizontal correspondem às letras na ordem de frequência decrescente.

Figura 2.6 Frequência relativa de ocorrência das letras.



A Figura 2.6 também mostra a distribuição de frequência que resulta quando o texto é encriptado usando a cifra Playfair. Para normalizar o gráfico, o número de ocorrências de cada letra no texto cifrado novamente foi dividido pelo número de ocorrências de e no texto claro. O gráfico resultante, portanto, mostra a extensão à qual a distribuição de frequência das letras, que torna trivial solucionar as cifras de substituição, é mascarada pela encriptação. Se a informação de distribuição de frequência fosse totalmente escondida no processo de encriptação, o desenho de frequências do texto cifrado seria achatado, e a criptoanálise usando o texto cifrado se tornaria efetivamente impossível. Como mostra a figura, a cifra Playfair tem uma distribuição mais achatada do que o texto claro, mas, apesar disso, ela revela muita estrutura para um criptoanalista trabalhar.

O gráfico também mostra a cifra Vigenère, discutida mais adiante. As curvas Hill e Vigenère no gráfico são baseadas em resultados relatados em [SIMM93].

Cifra de Hill⁵

Outra cifra multiletas interessante é a de Hill, desenvolvida pelo matemático Lester Hill em 1929.

CONCEITOS DA ÁLGEBRA LINEAR Antes de descrevermos a cifra de Hill, vamos revisar rapidamente alguma terminologia da álgebra linear. Nesta discussão, estamos preocupados com a aritmética de matriz módulo 26. O leitor que precisa relembrar a multiplicação e inversão de matrizes deverá consultar o Apêndice E.

Definimos o inverso $\mathbf{M}^{-1}$ de uma matriz quadrada $\mathbf{M}$ pela equação $\mathbf{M}(\mathbf{M}^{-1}) = \mathbf{M}^{-1}\mathbf{M} = \mathbf{I}$, onde $\mathbf{I}$ é a matriz identidade. $\mathbf{I}$ é uma matriz quadrada que contém todos os elementos iguais a zero, exceto por 1's ao longo da diagonal principal do canto superior esquerdo ao inferior direito. O inverso de uma matriz nem sempre existe, mas, quando sim, satisfaz a equação anterior. Por exemplo,

$$\begin{aligned}\mathbf{A} &= \begin{pmatrix} 5 & 8 \\ 17 & 3 \end{pmatrix} & \mathbf{A}^{-1} \bmod 26 &= \begin{pmatrix} 9 & 2 \\ 1 & 15 \end{pmatrix} \\ \mathbf{A}\mathbf{A}^{-1} &= \begin{pmatrix} (5 \times 9) + (8 \times 1) & (5 \times 2) + (8 \times 15) \\ (17 \times 9) + (3 \times 1) & (17 \times 2) + (3 \times 15) \end{pmatrix} \\ &= \begin{pmatrix} 53 & 130 \\ 156 & 79 \end{pmatrix} \bmod 26 = \begin{pmatrix} 1 & 0 \\ 0 & 1 \end{pmatrix}\end{aligned}$$

Para explicar como é determinado o inverso de uma matriz, começamos com o conceito de determinante. Para qualquer matriz quadrada ($m \times m$), o **determinante** é igual à soma de todos os produtos que podem ser formados apanhando-se exatamente um elemento de cada linha e um de cada coluna, com certos termos do produto precedidos por um sinal de menos. Para uma matriz 2×2 ,

$$\begin{pmatrix} k_{11} & k_{12} \\ k_{21} & k_{22} \end{pmatrix}$$

o determinante é $k_{11}k_{22} - k_{12}k_{21}$. Para uma matriz 3×3 , o valor do determinante é $k_{11}k_{22}k_{33} + k_{21}k_{32}k_{13} + k_{31}k_{12}k_{23} - k_{31}k_{22}k_{13} - k_{21}k_{12}k_{33} - k_{11}k_{32}k_{23}$. Se uma matriz quadrada $\mathbf{A}$ tiver um determinante diferente de zero, então o inverso da matriz é calculado como $[\mathbf{A}^{-1}]_{ij} = (\det \mathbf{A})^{-1}(-1)^{i+j}(\mathbf{D}_{ji})$, onde $(\mathbf{D}_{ji})$ é o subdeterminante formado pela exclusão da linha j e coluna i de $\mathbf{A}$, $\det(\mathbf{A})$ é o determinante de $\mathbf{A}$ e $(\det \mathbf{A})^{-1}$ é o inverso multiplicativo de $(\det \mathbf{A}) \bmod 26$.

Continuando nosso exemplo,

$$\det \begin{pmatrix} 5 & 8 \\ 17 & 3 \end{pmatrix} = (5 \times 3) - (8 \times 17) = -121 \bmod 26 = 9$$

Podemos mostrar que $9^{-1} \bmod 26 = 3$, pois $9 \times 3 = 27 \bmod 26 = 1$ (veja no Capítulo 4 ou no Apêndice E – este último em <sv.pearson.com.br>, em inglês). Portanto, calculamos o inverso de $\mathbf{A}$ como

⁵ Essa cifra é um pouco mais difícil de entender do que as outras neste capítulo, mas ilustra um ponto importante sobre a criptoanálise, que será útil mais adiante. Esta subseção pode ser pulada em uma primeira leitura.

$$\mathbf{A} = \begin{pmatrix} 5 & 8 \\ 17 & 3 \end{pmatrix}$$

$$\mathbf{A}^{-1} \bmod 26 = 3 \begin{pmatrix} 3 & -8 \\ -17 & 5 \end{pmatrix} = 3 \begin{pmatrix} 3 & 18 \\ 9 & 5 \end{pmatrix} = \begin{pmatrix} 9 & 54 \\ 27 & 15 \end{pmatrix} = \begin{pmatrix} 9 & 2 \\ 1 & 15 \end{pmatrix}$$

O ALGORITMO DE HILL Esse algoritmo de encriptação utiliza m letras de texto claro sucessivas e as substitui por m letras de texto cifrado. A substituição é determinada por m equações lineares, em que cada caractere recebe um valor numérico ($a = 0, b = 1, \dots, z = 25$). Para $m = 3$, o sistema pode ser descrito da seguinte forma:

$$\begin{aligned} c_1 &= (k_{11}p_1 + k_{21}p_2 + k_{31}p_3) \bmod 26 \\ c_2 &= (k_{12}p_1 + k_{22}p_2 + k_{32}p_3) \bmod 26 \\ c_3 &= (k_{13}p_1 + k_{23}p_2 + k_{33}p_3) \bmod 26 \end{aligned}$$

Isso pode ser expresso em termos de vetores de linhas e matrizes:⁶

$$(c_1 \ c_2 \ c_3) = (p_1 \ p_2 \ p_3) \begin{pmatrix} k_{11} & k_{12} & k_{13} \\ k_{21} & k_{22} & k_{23} \\ k_{31} & k_{32} & k_{33} \end{pmatrix} \bmod 26$$

ou

$$\mathbf{C} = \mathbf{PK} \bmod 26$$

onde $\mathbf{C}$ e $\mathbf{P}$ são vetores de coluna de tamanho 3, representando o texto claro e o texto cifrado, e $\mathbf{K}$ é uma matriz 3×3 , indicando a chave de encriptação. As operações são realizadas com mod 26.

Por exemplo, considere o texto claro “paymoremoney” e use a chave de encriptação

$$\mathbf{K} = \begin{pmatrix} 17 & 17 & 5 \\ 21 & 18 & 21 \\ 2 & 2 & 19 \end{pmatrix}$$

As três primeiras letras do texto claro são representadas pelo vetor (15 0 24). Então, $(15 \ 0 \ 24)\mathbf{K} = (303 \ 303 \ 531) \bmod 26 = (17 \ 17 \ 11) = \text{RRL}$. Continuando dessa forma, o texto cifrado para o texto claro inteiro é RRLMWBKASPDH.

A decipação exige o uso do inverso da matriz $\mathbf{K}$. Podemos calcular $\det \mathbf{K} = 23$ e, portanto, $(\det \mathbf{K})^{-1} \bmod 26 = 17$. Nesse caso, o inverso é⁷

$$\mathbf{K}^{-1} = \begin{pmatrix} 4 & 9 & 15 \\ 15 & 17 & 6 \\ 24 & 0 & 17 \end{pmatrix}$$

Isso é demonstrado da seguinte maneira:

$$\begin{pmatrix} 17 & 17 & 5 \\ 21 & 18 & 21 \\ 2 & 2 & 19 \end{pmatrix} \begin{pmatrix} 4 & 9 & 15 \\ 15 & 17 & 6 \\ 24 & 0 & 17 \end{pmatrix} = \begin{pmatrix} 443 & 442 & 442 \\ 858 & 495 & 780 \\ 494 & 52 & 365 \end{pmatrix} \bmod 26 = \begin{pmatrix} 1 & 0 & 0 \\ 0 & 1 & 0 \\ 0 & 0 & 1 \end{pmatrix}$$

É fácil ver que, se a matriz $\mathbf{K}^{-1}$ for aplicada ao texto cifrado, então o texto claro é recuperado.

Em termos gerais, o sistema de Hill pode ser expresso da seguinte forma:

⁶ Alguns livros de criptografia expressam o texto claro e o texto cifrado como vetores de colunas, de modo que o vetor de colunas é colocado após a matriz, em vez de o vetor de linhas ser posto antes da matriz. *Sage* usa vetores de linhas, de modo que adotamos essa convenção.

⁷ Os cálculos neste exemplo podem ser vistos com detalhes no Apêndice E (em <sv.pearson.com.br>, em inglês).

$$\begin{aligned} \mathbf{C} &= \mathbf{E}(\mathbf{K}, \mathbf{P}) = \mathbf{PK} \bmod 26 \\ \mathbf{P} &= \mathbf{D}(\mathbf{K}, \mathbf{C}) = \mathbf{CK}^{-1} \bmod 26 = \mathbf{PKK}^{-1} = \mathbf{P} \end{aligned}$$

Assim como na cifra Playfair, o ponto forte da cifra de Hill é que ela oculta completamente as frequências de única letra. De fato, com Hill, o uso de uma matriz maior esconde mais informações de frequência. Assim, uma cifra de Hill de 3×3 encobre não apenas informações de frequência de única letra, mas também de duas letras.

Embora a cifra de Hill seja forte contra um ataque apenas de texto cifrado, ela é facilmente quebrada com um ataque de texto claro conhecido. Para uma cifra de Hill de $m \times m$, suponha que tenhamos m pares de texto claro/texto cifrado, cada um com tamanho m . Rotulamos os pares com $\mathbf{P}_j = (p_{1j} p_{2j} \dots p_{mj})$ e $\mathbf{C}_j = (c_{1j} c_{2j} \dots c_{mj})$, de modo que $\mathbf{C}_j = \mathbf{P}_j \mathbf{K}$ para $1 \leq j \leq m$ e para alguma matriz de chave desconhecida $\mathbf{K}$. Então, definimos duas matrizes $m \times m$, $\mathbf{X} = (p_{ij})$ e $\mathbf{Y} = (c_{ij})$. Depois, podemos formar a equação matricial $\mathbf{Y} = \mathbf{XK}$. Se $\mathbf{X}$ tiver um inverso, podemos determinar $\mathbf{K} = \mathbf{X}^{-1}\mathbf{Y}$. Se $\mathbf{X}$ não puder ser invertida, uma nova versão de $\mathbf{X}$ terá chances de ser formada com pares adicionais de texto claro/texto cifrado, até que se obtenha uma matriz $\mathbf{X}$ a ser invertida.

Considere este exemplo. Suponha que o texto claro “hillcipher” seja encriptado usando uma cifra de Hill 2×2 para gerar o texto cifrado HCRZSSXNSP. Assim, sabemos que $(7\ 8)\mathbf{K} \bmod 26 = (7\ 2)$; $(11\ 11)\mathbf{K} \bmod 26 = (17\ 25)$; e assim por diante. Usando os dois primeiros pares de texto claro/texto cifrado, temos

$$\begin{pmatrix} 7 & 2 \\ 17 & 25 \end{pmatrix} = \begin{pmatrix} 7 & 8 \\ 11 & 11 \end{pmatrix} \mathbf{K} \bmod 26$$

O inverso de $\mathbf{X}$ pode ser calculado:

$$\begin{pmatrix} 7 & 8 \\ 11 & 11 \end{pmatrix}^{-1} = \begin{pmatrix} 25 & 22 \\ 1 & 23 \end{pmatrix}$$

de modo que

$$\mathbf{K} = \begin{pmatrix} 25 & 22 \\ 1 & 23 \end{pmatrix} \begin{pmatrix} 7 & 2 \\ 17 & 25 \end{pmatrix} = \begin{pmatrix} 549 & 600 \\ 398 & 577 \end{pmatrix} \bmod 26 = \begin{pmatrix} 3 & 2 \\ 8 & 5 \end{pmatrix}$$

Esse resultado é verificado testando-se o par restante de texto claro-texto cifrado.

Cifras polialfabéticas

Outra forma de melhorar a técnica monoalfabética simples é usar diferentes substituições monoalfabéticas enquanto se prossegue pela mensagem de texto claro. O nome geral para essa técnica é **cifra por substituição polialfabética**. Essas técnicas têm as seguintes características em comum:

1. Um conjunto de regras de substituição monoalfabéticas é utilizado.
2. Uma chave define qual regra em particular é escolhida para determinada transformação.

CIFRA DE VIGENÈRE A mais conhecida – e uma das mais simples – cifras polialfabéticas é a de Vigenère. Nesse esquema, o conjunto de regras de substituição monoalfabéticas consiste nas 26 cifras de César, com deslocamentos de 0 a 25. Cada cifra é indicada por uma letra da chave, que é a letra do texto cifrado que substitui a letra do texto claro a. Assim, uma cifra de César com um deslocamento de 3 é indicada pelo valor de chave 3.⁸

Podemos expressar a cifra de Vigenère da seguinte maneira. Considere uma sequência de letras em texto claro $P = p_0, p_1, p_2, \dots, p_{n-1}$ e uma chave consistindo na sequência de letras $K = k_0, k_1, k_2, \dots, k_{m-1}$, onde normalmente $m < n$. A sequência de letras em texto cifrado $C = C_0, C_1, C_2, \dots, C_{n-1}$ é calculada da seguinte forma:

$$\begin{aligned} C &= C_0, C_1, C_2, \dots, C_{n-1} = \mathbf{E}(K, P) = \mathbf{E}[(k_0, k_1, k_2, \dots, k_{m-1}), (p_0, p_1, p_2, \dots, p_{n-1})] \\ &= (p_0 + k_0) \bmod 26, (p_1 + k_1) \bmod 26, \dots, (p_{m-1} + k_{m-1}) \bmod 26, \\ &\quad (p_m + k_0) \bmod 26, (p_{m+1} + k_1) \bmod 26, \dots, (p_{2m-1} + k_{m-1}) \bmod 26, \dots \end{aligned}$$

⁸ Para ajudar na compreensão do esquema e auxiliar em seu uso, é possível construir uma matriz conhecida como tabela de Vigenère.

Assim, a primeira letra da chave é somada à primeira letra do texto claro, mod 26, a segunda letra da chave é somada à segunda letra do texto claro, e assim por diante, pelas primeiras m letras do texto claro. Para as próximas m letras do texto claro, as da chave são repetidas. Esse processo continua até que toda a sequência de texto claro esteja encriptada. Uma equação geral do processo de encriptação é

$$C_i = (p_i + k_{i \bmod m}) \bmod 26 \quad (2.3)$$

Compare isso com a Equação 2.1 para a cifra de César. Basicamente, cada caractere de texto claro é encriptado com uma cifra de César diferente, dependendo do caractere de chave correspondente. De modo semelhante, a decaptação é uma generalização da Equação 2.2:

$$p_i = (C_i - k_{i \bmod m}) \bmod 26 \quad (2.4)$$

Para encriptar uma mensagem, é preciso que haja uma chave tão longa quanto ela. Normalmente, a chave é uma palavra-chave repetida. Por exemplo, se a palavra-chave for “*deceptive*” [“ilusório”], a mensagem “*we are discovered save yourself*” [“fomos descobertos, salve-se”] é encriptada desta forma:

```

chave:           deceptivedeceptive
texto claro:      wearediscoveredsaveyourself
texto cifrado:    ZICVTWQNGRZGVTWAVZHCQYGLMGJ

```

Expresso numericamente, temos o seguinte resultado:

chave	3	4	2	4	15	19	8	21	4	3	4	2	4	15
texto claro	22	4	0	17	4	3	8	18	2	14	21	4	17	4
texto cifrado	25	8	2	21	19	22	16	13	6	17	25	6	21	19

chave	19	8	21	4	3	4	2	4	15	19	8	21	4
texto claro	3	18	0	21	4	24	14	20	17	18	4	11	5
texto cifrado	22	0	21	25	7	2	16	24	6	11	12	6	9

A força dessa cifra é que existem múltiplas letras de texto cifrado para cada uma do texto claro, uma para cada letra exclusiva da palavra-chave. Assim, informações referentes à frequência de letra são ocultadas. Porém, nem todo conhecimento da estrutura do texto claro é perdido. Por exemplo, a Figura 2.6 mostra a distribuição de frequência para uma cifra de Vigenère com uma palavra-chave de tamanho 9. Uma melhoria é obtida em relação à cifra Playfair, mas informações de frequência consideráveis ainda permanecem.

É instrutivo esboçar um método para quebrar essa cifra, pois ele revela alguns dos princípios matemáticos que se aplicam na criptoanálise.

Primeiro, suponha que o oponente acredite que o texto cifrado foi encriptado ou usando a substituição monoalfabética, ou uma cifra de Vigenère. Um teste simples pode ser feito para se distinguir esses dois cenários. Se uma substituição monoalfabética for empregada, então as propriedades estatísticas do texto cifrado deverão ser iguais às da linguagem do texto claro. Assim, referenciando a Figura 2.5, deverá haver uma letra de cifra com uma frequência relativa de ocorrência de aproximadamente 12,7%, uma com cerca de 9,06%, e assim por diante. Se apenas uma única mensagem estiver disponível para análise, não esperaríamos encontrar uma combinação exata do perfil estatístico da linguagem de texto claro. Entretanto, se a correspondência for próxima, podemos considerar uma substituição monoalfabética.

Se, por outro lado, uma cifra de Vigenère for utilizada, então o progresso da criptoanálise depende da determinação do tamanho da palavra-chave. Agora, nos concentraremos em como determinar o tamanho da palavra-chave. A ideia principal que leva a determinar o tamanho da palavra-chave é a seguinte: se duas sequências idênticas de letras de texto claro ocorrem a uma distância que seja um múltiplo inteiro do tamanho da palavra-chave, elas gerarão sequências de texto cifrado idênticas. No exemplo anterior, duas ocorrências da sequência “*red*” são separadas por nove posições de caractere. Consequentemente, em ambos os casos, *r* é codificado com a letra-chave *e*, *e* é codificado com a letra-chave *p*, e *d* é codificado com a letra-chave *t*. Assim, nos dois casos, a sequência é VTW. Indicamos isso anteriormente sublinhando as letras relevantes e sombreando os números relevantes do texto cifrado.

Um analista examinando apenas o texto cifrado detectaria as sequências repetidas VTW a uma distância de 9 e consideraria que a palavra-chave tem três ou nove letras de extensão. O surgimento de VTW duas vezes poderia ser por acaso, e não refletir letras de texto claro idênticas codificadas com letras-chave idênticas. Porém, se a mensagem for longa o suficiente, haverá diversas dessas sequências de texto cifrado repetidas. Procurando fatores comuns nos deslocamentos das diversas sequências, o analista deverá ser capaz de fazer uma boa escolha do tamanho da palavra-chave.

A solução da cifra agora depende de uma percepção importante. Se o tamanho da palavra-chave é m , então a cifra, por conseguinte, consiste em m cifras de substituição monoalfabéticas. Por exemplo, com a palavra-chave DECEPTIVE, as letras nas posições 1, 10, 19, e assim por diante, são todas encriptadas com a mesma cifra monoalfabética. Assim, podemos usar as características de frequência conhecidas da linguagem do texto claro para atacar cada uma das cifras monoalfabéticas separadamente.

A natureza periódica da palavra-chave pode ser eliminada usando-se uma palavra-chave não repetida que seja tão grande quanto a própria mensagem. Vigenère propôs o que é conhecido como um **sistema de auto-chave**, em que uma palavra-chave é concatenada ao próprio texto claro para oferecer uma chave corrente. Para o nosso exemplo,

chave:	<i>deceptivewerearediscoveredsav</i>
texto claro:	<i>werearediscoveredsaveyourself</i>
texto cifrado:	<i>ZICVTWQNGKZEIIGASXSTSLVVWLA</i>

Até mesmo esse esquema é vulnerável à criptoanálise. Como a chave e o texto claro compartilham a mesma distribuição de frequência das letras, uma técnica estatística poderá ser aplicada. Por exemplo, pode-se esperar que e codificado por e , pela Figura 2.5, ocorra com uma frequência de $(0,127)^2 \approx 0,016$, enquanto t codificado por t ocorreria apenas com a metade dessa frequência. Essas regularidades podem ser exploradas para se conseguir sucesso na criptoanálise.⁹

CIFRA DE VERNAM A principal defesa contra a técnica criptoanalítica descrita é escolher uma palavra-chave que seja tão longa quanto o texto claro e que não possua relacionamento estatístico com ele. Esse sistema foi introduzido por um engenheiro da AT&T, chamado Gilbert Vernam, em 1918. Seu sistema funciona sobre dados binários (bits), em vez de letras. O sistema pode ser expresso de forma sucinta da seguinte forma (Figura 2.7):

$$c_i = p_i \oplus k_i$$

onde

p_i = dígito binário na posição i do texto claro

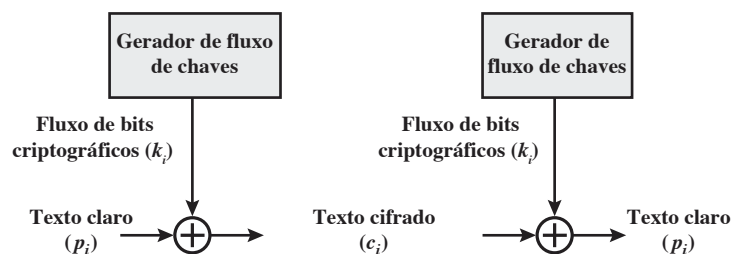
k_i = dígito binário na posição i da chave

c_i = dígito binário na posição i do texto cifrado

$\oplus$ = operação ou – exclusivo (XOR)

Compare isso com a Equação 2.3, para a cifra de Vigenère.

Figura 2.7 Cifra de Vernam.



⁹ Embora as técnicas para quebrar uma cifra de Vigenère não sejam complexas, uma edição de 1917 da *Scientific American* caracterizava esse sistema como “impossível de tradução”. Esse é um ponto que merece ser lembrado quando afirmações semelhantes são feitas para algoritmos modernos.

Assim, o texto cifrado é gerado realizando-se o XOR (operação lógica ou-exclusivo) bit a bit entre texto claro e a chave. Por conta das propriedades do XOR, a deciptação simplesmente envolve a mesma operação bit a bit:

$$p_i = c_i \oplus k_i$$

que é comparada à Equação 2.4.

A essência dessa técnica é a forma de construção da chave. Vernam propôs o uso de uma palavra-chave muito longa, porém que eventualmente era repetida. Embora esse esquema com uma chave longa apresente dificuldades de criptoanálise formidáveis, ele pode ser quebrado com um número suficiente de texto cifrado, com o uso de sequências de texto claro conhecidas ou prováveis, ou ambos.

One-time pad

Um oficial do Exército, Joseph Mauborgne, propôs uma melhoria na cifra de Vernam, que gera o máximo em segurança. Mauborgne sugeriu o uso de uma chave aleatória que fosse tão grande quanto a mensagem, de modo que a chave não precisasse ser repetida. Além disso, a chave deve ser empregada para encriptar e deciptar uma única mensagem, e depois descartada. Cada nova mensagem exige uma nova chave com o mesmo tamanho. Esse esquema, conhecido como *one-time pad*, é inquebrável. Ele produz saída aleatória que não possui qualquer relacionamento estatístico com o texto claro. Como o texto cifrado não contém qualquer informação sobre o texto claro, simplesmente não existe um meio de quebrar o código.

Um exemplo deverá ilustrar nosso argumento. Suponha que estejamos usando um esquema de Vigenère com 27 caracteres, no qual o vigésimo sétimo é o de espaço, mas com uma chave de uso único que é tão grande quanto a mensagem. Considere o texto cifrado

ANKYODKYUREPFJBYOJDSPLREYIUNOFDOIUERFPLUYTS

Agora mostramos duas deciptações diferentes usando duas chaves distintas:

texto cifrado:	ANKYODKYUREPFJBYOJDSPLREYIUNOFDOIUERFPLUYTS
chave:	<i>p x l m v m s y d o f u y r v z w c t n l e b n e c v g d u p a h f z z l m n y i h</i>
texto claro:*	mr mustard with the candlestick in the hall
texto cifrado:	ANKYODKYUREPFJBYOJDSPLREYIUNOFDOIUERFPLUYTS
chave:	<i>m f u g p m i y d g a x g o u f h k l l l m h s q d q o g t e w b q f g y o v u h w t</i>
texto claro:**	miss scarlet with the knife in the library

Suponha que um criptoanalista conseguisse encontrar essas duas chaves. Dois textos claros plausíveis são produzidos. Como ele decide qual é a deciptação correta (ou seja, qual é a chave correta)? Se a chave real fosse produzida de uma forma verdadeiramente aleatória, então o criptoanalista não pode saber que uma dessas duas é mais provável que a outra. Assim, não existe um meio de decidir qual chave é a correta e, por consequência, qual texto claro é o correto.

De fato, dado qualquer texto claro de mesmo tamanho do texto cifrado, existe uma chave que o produz. Portanto, se você fizesse uma busca exaustiva em todas as chaves possíveis, acabaria com muitos textos claros legíveis, sem saber qual foi o intencionado. O código é inquebrável.

A segurança do *one-time pad* é inteiramente decorrente da aleatoriedade da chave. Se o fluxo de caracteres que constitui a chave for verdadeiramente aleatório, então o de caracteres que constitui o texto cifrado também o será. Assim, não existem padrões ou regularidades que um criptoanalista possa usar para atacar o texto cifrado.

Em teoria, não precisamos mais procurar uma cifra. O *one-time pad* oferece segurança completa, mas, na prática, tem dois empecilhos fundamentais:

1. Criar grandes quantidades de chaves aleatórias representa um problema prático. Qualquer sistema bastante utilizado poderia exigir milhões de caracteres aleatórios regularmente. O fornecimento de caracteres de fato aleatórios nesse volume é uma tarefa significativa.
2. Ainda mais assustador é o problema da distribuição e proteção da chave. A cada mensagem a ser enviada, uma chave de mesmo tamanho é necessária para uso do emissor e do receptor. Assim, existe um problema gigantesco de distribuição de chave.

* “Senhor Mustard com o candelabro no salão”

** “Senhorita Scarlet com a faca na biblioteca”

Por causa dessas dificuldades, o *one-time pad* tem utilidade limitada, e aplicação principalmente para canais de pouca largura de banda que exigem segurança muito alta.

O *one-time pad* é o único criptossistema que apresenta o que é conhecido como *segredo perfeito*. Esse conceito é explorado no Apêndice F (disponível na Sala Virtual, em <sv.pearson.com.br>, em inglês).

2.3 TÉCNICAS DE TRANSPOSIÇÃO

Todas as técnicas examinadas até aqui envolvem a substituição de um símbolo de texto cifrado por um de texto claro. Uma espécie bem diferente de mapeamento é obtida realizando-se algum tipo de permutação nas letras do texto claro. Essa técnica é referenciada como uma cifra de transposição.

A cifra mais simples desse tipo é a técnica de **cerca de trilho**, em que o texto claro é escrito como uma sequência de diagonais, e depois lido como uma sequência de linhas. Por exemplo, para cifrar a mensagem “*meet me after the toga party*” com uma cerca de trilho de profundidade 2, escrevemos o seguinte:

```
m e m a t r h t g p r y
e t e f e t e o a a t
```

A mensagem encriptada é

MEMATRHTGPRYETEFETEOAAT

Esse tipo de coisa seria trivial de ser criptanalísada. Um esquema mais complexo é escrever a mensagem em um retângulo, linha por linha, e a ler coluna por coluna, mas permutar a ordem destas. A ordem das colunas, então, torna-se a chave para o algoritmo. Por exemplo,

```
Chave:          4 3 1 2 5 6 7
Texto claro:    a t t a c k p
                o s t p o n e
                d u n t i l t
                w o a m x y z
Texto cifrado:  TTNAAPTMTSUOAODWCOIXKNLYPETZ
```

Assim, neste exemplo, a chave é 4312567. Para encriptar, comece com a coluna rotulada com 1, neste caso, a coluna 3. Escreva todas as letras dessa coluna. Prossiga para a coluna 4, que é rotulada com 2, depois para a coluna 2, então para a coluna 1, por fim para as colunas 5, 6 e 7.

Uma cifra de pura transposição é facilmente reconhecida, pois tem as mesmas frequências de letra do texto claro original. Para o tipo de transposição de colunas mostrada, a criptoanálise é muito simples e envolve dispor o texto cifrado em uma matriz, além de mexer com as posições de coluna. As tabelas de frequência de digrama e trigrama podem ser úteis.

A cifra de transposição pode se tornar muito mais segura realizando-se mais de um estágio de transposição. O resultado é uma permutação mais complexa, que não é facilmente reconstruída. Assim, se a mensagem anterior for reencriptada usando o mesmo algoritmo,

```
Chave:          4 3 1 2 5 6 7
Entrada:        t t n a a p t
                m t s u o a o
                d w c o i x k
                n l y p e t z
Saída:          NSCYAUOPTTWLTMDNAOIEPAXTTOKZ
```

Para visualizar o resultado dessa dupla transposição, designe as letras na mensagem de texto claro original pelos números que indicam a sua posição. Assim, com 28 letras na mensagem, a sequência original das letras é

```
01 02 03 04 05 06 07 08 09 10 11 12 13 14
15 16 17 18 19 20 21 22 23 24 25 26 27 28
```

Depois da primeira transposição, temos

```
03 10 17 24 04 11 18 25 02 09 16 23 01 08
15 22 05 12 19 26 06 13 20 27 07 14 21 28
```

que tem uma estrutura um tanto regular. Mas, depois da segunda transposição, temos

```
17 09 05 27 24 16 12 07 10 02 22 20 03 25
15 13 04 23 19 14 11 01 26 21 18 08 06 28
```

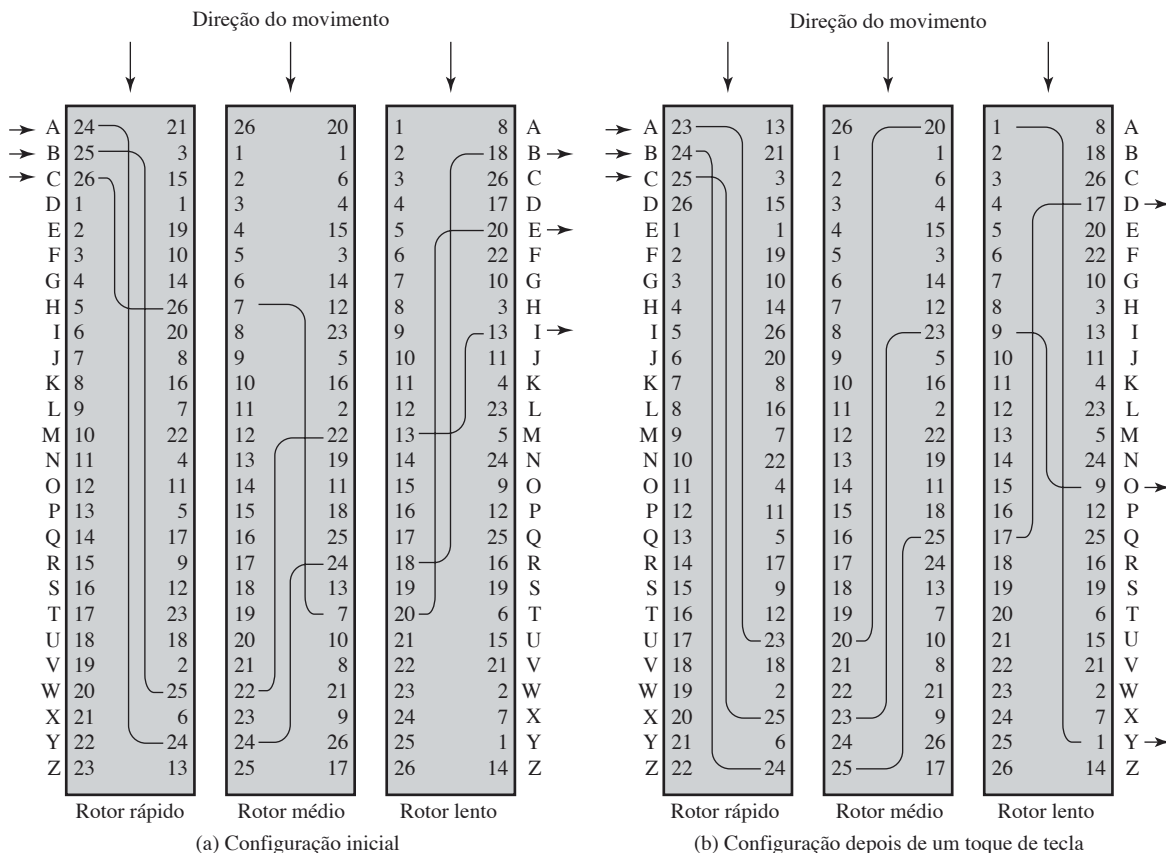
Essa é uma permutação muito menos estruturada e muito mais difícil de se criptoanalisar.

2.4 MÁQUINAS DE ROTOR

O exemplo que acabamos de dar sugere que várias etapas de encriptação podem produzir um algoritmo que é significativamente mais difícil para criptoanalisar. Isso vale tanto para cifras de substituição quanto para de transposição. Antes da introdução do DES, a aplicação mais importante do princípio de múltiplas etapas de encriptação era uma classe de sistemas conhecida como máquinas de rotor.¹⁰

O princípio básico da máquina de rotor é ilustrado na Figura 2.8. A máquina consiste em um conjunto de cilindros rotativos independentes, através dos quais pulsos elétricos podem fluir. Cada cilindro tem 26 pinos de entrada e 26 pinos de saída, com fiação interna que conecta cada pino de entrada a um único pino de saída. Para simplificar, mostramos somente três das conexões internas em cada cilindro.

Figura 2.8 Máquina de três rotores com fiação representada por contatos numerados.



¹⁰ Máquinas baseadas no princípio de rotor foram usadas pela Alemanha (Enigma) e pelo Japão (Purple) na Segunda Guerra Mundial. A quebra desses dois códigos pelos Aliados foi um fator significativo para o resultado da guerra.

Se associarmos cada pino de entrada e saída a uma letra do alfabeto, então um único cilindro define uma substituição monoalfabética. Por exemplo, na Figura 2.8, se um operador pressionar uma tecla para a letra A, um sinal elétrico é aplicado ao primeiro pino do primeiro cilindro e flui pela conexão interna para o vigésimo quinto pino de saída.

Considere uma máquina com um único cilindro. Depois que cada tecla de entrada é pressionada, o cilindro gira uma posição, de modo que as conexões internas são deslocadas de acordo. Assim, é definida uma cifra de substituição monoalfabética diferente. Depois de 26 letras de texto claro, o cilindro estaria de volta à posição inicial. Assim, temos um algoritmo de substituição polialfabética com um período de 26.

Um sistema de único cilindro é trivial e não apresenta uma tarefa criptoanalítica formidável. O poder da máquina de rotor está no uso de múltiplos cilindros, em que os pinos de saída de um cilindro são conectados aos de entrada do seguinte. A Figura 2.8 mostra um sistema de três cilindros. A metade esquerda da figura mostra uma posição em que a entrada do operador para o primeiro pino (letra a em texto claro) é direcionada pelos três cilindros para aparecer na saída do segundo pino (letra B em texto cifrado).

Com múltiplos cilindros, aquele mais próximo da entrada do operador gira uma posição de pino a cada toque de tecla. A metade direita da Figura 2.8 mostra a configuração do sistema depois de um único toque de tecla. Para cada rotação completa do cilindro interno, o do meio gira uma posição de pino. Finalmente, para cada rotação completa do cilindro do meio, o externo gira uma posição de pino. Esse é o mesmo tipo de operação vista com os antigos marcadores de quilometragem (odômetros) de automóvel. O resultado é que existem $26 \times 26 \times 26 = 17.576$ alfabetos de substituição diferentes usados antes que o sistema repita. O acréscimo de quarto e quinto rotores resulta em períodos de 456.976 e 11.881.376 letras, respectivamente. Assim, determinada configuração de uma máquina de 5 rotores é equivalente a uma cifra de Vigenère com um tamanho de chave de 11.881.376.

Esse esquema apresenta um desafio criptoanalítico formidável. Por exemplo, se o criptoanalista tentar usar uma técnica de análise de frequência de letra, ele enfrentará o equivalente a mais de 11 milhões de cifras monoalfabéticas. Talvez fosse preciso cerca de 50 letras em cada cifra monoalfabética para uma solução, o que significa que o analista necessita estar em posse de um texto cifrado com um tamanho de mais de meio bilhão de letras.

O significado da máquina de rotor hoje é que ela aponta o caminho para a cifra mais utilizada de todos os tempos: Data Encryption Standard (DES), que será explicada no Capítulo 3.

2.5 ESTEGANOGRAFIA

Concluiremos com uma discussão sobre uma técnica que, estritamente falando, não é encriptação — a saber, a **esteganografia**.

Uma mensagem em texto claro pode estar oculta de duas maneiras. Os métodos de **esteganografia** escondem a existência da mensagem, enquanto os métodos de criptografia a tornam ininteligível a estranhos por meio de várias transformações do texto.¹¹

Uma forma simples de esteganografia, mas demorada de se construir, é aquela em que um arranjo de palavras e letras dentro de um texto aparentemente inofensivo soletra a mensagem real. Por exemplo, a sequência de primeiras letras de cada palavra da mensagem geral soletra a mensagem escondida.

Diversas outras técnicas têm sido usadas historicamente, e alguns exemplos são [MYER91]:

- **Marcação de caractere:** letras selecionadas do texto impresso ou datilografado são escritas com lápis por cima. As marcas normalmente não são visíveis, a menos que o papel seja mantido contra uma fonte de luz clara.
- **Tinta invisível:** diversas substâncias podem ser usadas para a escrita sem deixar rastros visíveis, a menos que alguma química seja aplicada ao papel.
- **Perfurações:** pequenos furos em letras selecionadas normalmente não são visíveis, a menos que o papel tenha uma fonte de luz no fundo.
- **Fita corretiva de máquina de escrever:** usada entre as linhas digitadas com uma fita preta, os resultados de digitar com a fita corretiva são visíveis apenas sob uma luz forte.

¹¹ *Esteganografia* era uma palavra obsoleta que foi revivida por David Kahn e recebeu o significado que tem hoje [KAHN96].

Embora essas técnicas possam parecer arcaicas, elas possuem equivalentes contemporâneos. [WAYN09] propõe esconder uma mensagem usando os bits menos significativos dos frames em um CD. Por exemplo, a resolução máxima do formato Kodak Photo CD é de 3.096 por 6.144 pixels, com cada pixel contendo 24 bits de informações de cor RGB. O bit menos significativo de cada pixel de 24 bits pode ser alterado sem afetar muito a qualidade da imagem. O resultado é que você pode ocultar uma mensagem de 130 kB em uma única foto digital. Agora, existem diversos pacotes de software disponíveis que levam esse tipo de técnica à esteganografia.

A esteganografia tem diversas desvantagens quando comparada à encriptação. Ela exige muito *overhead* para esconder relativamente poucos bits de informação, embora algum esquema como o proposto no parágrafo anterior possa torná-la mais eficaz. Além disso, quando o sistema é descoberto, ele se torna praticamente inútil. Esse problema também pode ser contornado se o método de inserção depender de algum tipo de chave (por exemplo, veja o Problema 2.20). Como alternativa, uma mensagem pode ser primeiramente encriptada, e depois escondida, usando a esteganografia.

A vantagem da esteganografia é que ela pode ser empregada pelas partes que têm algo a perder se a sua comunicação secreta (não necessariamente o conteúdo) for descoberta. A encriptação sinaliza o tráfego como importante ou secreto, ou pode identificar o emissor ou o receptor como alguém com algo a esconder.

2.6 LEITURA RECOMENDADA

Para quem estiver interessado na história da criação e quebra de código, o livro a ser lido é [KAHN96]. Embora trate mais do impacto da criptologia do que de seu desenvolvimento técnico, essa é uma introdução excelente e compõe uma leitura interessante. Outro ótimo relato histórico é [SING99].

Uma abordagem curta incluindo as técnicas deste capítulo, além de outras, é [GARD72]. Existem muitos livros que abordam a criptografia clássica em um estilo mais técnico; um dos melhores é [SINK09]. [KORN96] é um livro agradável de se ler e contém uma extensa seção sobre técnicas clássicas. Dois livros de criptografia que contêm uma grande quantidade de material sobre técnicas clássicas são [GARR01] e [NICH99]. Para o leitor verdadeiramente interessado, os dois volumes de [NICH96] abrangem diversas cifras clássicas com detalhes, e oferecem muitos textos cifrados para serem criptoanalisados, com as soluções.

Um tratamento excelente das máquinas de rotor, incluindo uma discussão sobre sua criptoanálise, pode ser encontrado em [KUMA97].

[KATZ00] oferece um tratamento completo da esteganografia. Outra fonte interessante é [WAYN09].

GARD72 GARDNER, M. *Codes, Ciphers, and Secret Writing*. Nova York: Dover, 1972.

GARR01 GARRETT, P. *Making, Breaking Codes: An Introduction to Cryptology*. Upper Saddle River, NJ: Prentice Hall, 2001.

KAHN96 KAHN, D. *The Codebreakers: The Story of Secret Writing*. Nova York: Scribner, 1996.

KATZ00 KATZENBEISSER, S. (ed.). *Information Hiding Techniques for Steganography and Digital Watermarking*. Boston: Artech House, 2000.

KORN96 KORNER, T. *The Pleasures of Counting*. Cambridge, Inglaterra: Cambridge University Press, 1996.

KUMA97 KUMAR, I. *Cryptology*. Laguna Hills, CA: Aegean Park Press, 1997.

NICH96 NICHOLS, R. *Classical Cryptography Course*. Laguna Hills, CA: Aegean Park Press, 1996.

NICH99 NICHOLS, R. (ed.). *ICSA Guide to Cryptography*. Nova York: McGraw-Hill, 1999.

SING99 SINGH, S. *The Code Book: The Science of Secrecy from Ancient Egypt to Quantum Cryptography*. Nova York: Anchor Books, 1999.

SINK09 SINKOV, A. *Elementary Cryptanalysis: A Mathematical Approach*. Washington, DC: The Mathematical Association of America, 2009.

WAYN09 WAYNER, P. *Disappearing Cryptography*. Boston: AP Professional Books, 2009.

2.7 PRINCIPAIS TERMOS, PERGUNTAS PARA REVISÃO E PROBLEMAS

Principais termos

ataque de força bruta	cifra Playfair	criptação
cifra	cifra polialfabética	criptação convencional
cifra cerca de trilho	cifragem	criptação de chave única
cifra de bloco	computacionalmente seguro	criptação simétrica
cifra de César	criptoanálise	esteganografia
cifra de fluxo	criptografia	incondicionalmente seguro
cifra de Hill	criptologia	<i>one-time pad</i>
cifra de transposição	decifragem	sistema criptográfico
cifra de Vigenère	decriptação	texto cifrado
cifra monoalfabética	digrama	texto claro

Perguntas para revisão

- 2.1 Quais são os elementos essenciais de uma cifra simétrica?
- 2.2 Quais são as duas funções básicas usadas nos algoritmos de encriptação?
- 2.3 Quantas chaves são necessárias para duas pessoas se comunicarem por meio de uma cifra?
- 2.4 Qual é a diferença entre uma cifra de bloco e uma cifra de fluxo?
- 2.5 Quais são as duas técnicas gerais para atacar uma cifra?
- 2.6 Liste e defina rapidamente os tipos de ataque criptoanalítico com base naquilo que o atacante conhece.
- 2.7 Qual é a diferença entre uma cifra incondicionalmente segura e uma cifra computacionalmente segura?
- 2.8 Defina resumidamente a cifra de César.
- 2.9 Defina resumidamente a cifra monoalfabética.
- 2.10 Defina resumidamente a cifra Playfair.
- 2.11 Qual é a diferença entre uma cifra monoalfabética e uma polialfabética?
- 2.12 Quais são os dois problemas com o *one-time pad*?
- 2.13 O que é uma cifra de transposição?
- 2.14 O que é esteganografia?

Problemas

- 2.1 Uma generalização da cifra de César, conhecida como cifra de César afim, tem a seguinte forma: a cada letra de texto claro p , substitua-a pela letra de texto cifrado C :

$$C = E([a, b], p) = (ap + b) \bmod 26$$

Um requisito básico de qualquer algoritmo de encriptação é que ele seja um para um. Ou seja, se $p \neq q$, então $E(k, p) \neq E(k, q)$. Caso contrário, a decifração é impossível, pois mais de um caractere de texto claro é mapeado no mesmo caractere de texto cifrado. A cifra de César afim não é um-para-um para todos os valores de a . Por exemplo, para $a = 2$ e $b = 3$, então $E([a, b], 0) = E([a, b], 13) = 3$.

- a. Existem limitações sobre o valor de b ? Explique por que sim ou por que não.
- b. Determine quais valores de a não são permitidos.
- c. Ofereça uma afirmação geral sobre quais valores de a são e não são permitidos. Justifique-a.

- 2.2 Quantas cifras de César afins um para um existem?
- 2.3 Um texto cifrado foi gerado com uma cifra afim. A letra mais frequente do texto cifrado é B, e a segunda mais frequente é U. Quebre esse código.
- 2.4 O texto cifrado a seguir foi gerado usando um algoritmo de substituição simples:

53++†305))6*;4826)4+.)4+);806*;48†8¶60))85;;]8*;;†*8†83
 (88)5*†;46(;88*96*?;8)*†(;485);5*†2:††(;4956*2(5*-4)8¶8*
 ;4069285);)6†8)4††;1(†9;48081;8:8†1;48†85;4)485†528806*81
 (†9;48;(88;4(†?34;48)4†;161;;188;†?;

Decripte essa mensagem.

Dicas:

1. A letra que ocorre com mais frequência em inglês é e. Portanto, o primeiro ou segundo (ou talvez terceiro?) caractere mais comum na mensagem provavelmente signifique e. Além disso, e normalmente é visto em pares (por exemplo, *meet, fleet, speed, seen, been, agree* etc.). Tente encontrar um caractere no texto cifrado que seja decriptado para e.
2. A palavra mais comum em inglês é *the*. Use esse fato para adivinhar os caracteres que representam t e h.
3. Decifre o restante da mensagem deduzindo outras palavras.

Aviso: a mensagem resultante está em inglês, mas pode não fazer muito sentido em uma primeira leitura.

- 2.5** Um modo de solucionar o problema de distribuição de chave é usar uma linha de um livro que o emissor e o receptor possuem. Normalmente, pelo menos em romances de espionagem, a primeira sentença de um livro serve como chave. O esquema em particular discutido neste problema é de um dos melhores romances de suspense envolvendo códigos secretos, *Talking to Strange Men (Falando com Homens Estranhos)*, de Ruth Rendell. Discuta este problema sem consultar esse livro!

Considere a mensagem a seguir:

SIDKHKDM AF HCRKIABIE SHIMC KD LFEAILA

Esse texto cifrado foi produzido usando-se a primeira sentença de *The Other Side of Silence (O Outro Lado do Silêncio)* – um livro sobre o espião Kim Philby):

The snow lay thick on the steps and the snowflakes driven by the
wind looked black in the headlights of the cars.

Uma cifra de substituição simples foi utilizada.

- a. Qual é o algoritmo de encriptação?
- b. Qual a sua segurança?
- c. Para simplificar o problema de distribuição de chave, as duas partes podem combinar em usar a primeira ou última sentença de um livro como chave. Para mudá-la, eles simplesmente precisam escolher um novo livro. O uso da primeira sentença seria preferível ao da última. Por quê?

- 2.6** Em um de seus casos, Sherlock Holmes foi confrontado com a seguinte mensagem:

534 C2 13 127 36 31 4 17 21 41
DOUGLAS 109 293 5 37 BIRLSTONE
26 BIRLSTONE 9 127 171

Embora Watson estivesse confuso, Holmes foi imediatamente capaz de deduzir o tipo de cifra. Você consegue descobri-lo?

- 2.7** Este problema usa um exemplo do mundo real, de um antigo manual das Forças Especiais dos Estados Unidos (domínio público). O documento, com nome de arquivo *SpecialForces.pdf*, está disponível na Sala Virtual para este livro.

- a. Usando as duas chaves (palavras de memória) *cryptographic* e *network security*, encripte a mensagem a seguir:

Be at the third pillar from the left outside the lyceum theatre tonight at seven. If you are distrustful bring two friends.

Faça suposições razoáveis sobre como tratar letras redundantes e letras em excesso nas palavras de memória e como tratar os espaços e a pontuação. Indique quais são as suas suposições. *Nota:* a mensagem é do romance de Sherlock Holmes *The Sign of Four (O Sinal dos Quatro)*.

- b. Decripte o texto cifrado. Mostre o seu trabalho.
- c. Comente sobre quando seria apropriado usar esta técnica e quais são suas vantagens.

- 2.8** Uma desvantagem da cifra monoalfabética é que tanto o emissor quanto o receptor precisam confiar a sequência da cifra permutada à memória. Uma técnica comum para evitar isso é usar uma palavra-chave da qual a sequência da cifra possa ser gerada. Por exemplo, utilizando a palavra-chave *CIPHER*, escreva-a seguida por letras não usadas na ordem normal e combine com as do texto claro:

texto claro: a b c d e f g h i j k l m n o p q r s t u v w x y z
texto cifrado: C I P H E R A B D F G J K L M N O Q S T U V W X Y Z

Se esse processo não produzir uma mistura suficiente, escreva as letras restantes em linhas sucessivas e depois gere a sequência lendo as colunas, de cima para baixo:

C I P H E R
A B D F G J
K L M N O Q
S T U V W X
Y Z

Isso resulta na sequência

C A K S Y I B L T Z P D M U H F N V E G O W R J Q X

Esse sistema é usado no exemplo da Seção 2.2 (aquele que começa com “it was disclosed yesterday”). Determine a palavra-chave.

- 2.9** Quando o barco de patrulha norte-americano PT-109, sob o comando do tenente John F. Kennedy, foi afundado por um destróier japonês, uma mensagem foi recebida na estação sem fio australiana em código Playfair:

KXJEY UREBE ZWEHE WRYTU HEYFS
KREHE GOYFI WTTTU OLKSY CAJPO
BOTEI ZONTX BYBNT GONEY CUZWR
GDSON SXBOU YWRHE BAAHY USEDQ

A chave usada foi *royal new zealand navy*. Decripte a mensagem. Traduza TT para tt.

- 2.10** a. Construa uma matriz Playfair com a chave *largest*.
b. Construa uma matriz Playfair com a chave *occurrence*. Faça uma suposição razoável sobre como tratar letras redundantes na chave.
- 2.11** a. Usando esta matriz Playfair

M	F	H	I/J	K
U	N	O	P	Q
Z	V	W	X	Y
E	L	A	R	G
D	S	T	B	C

encripte esta mensagem:

Must see you over Cadogan West. Coming at once.

Nota: a mensagem é da história de Sherlock Holmes, *The Adventure of the Bruce-Partington Plans* (*A Aventura dos Planos de Bruce-Partington*).

- b. Repita a parte (a) usando a matriz Playfair do Problema 2.10a.
c. Como você justifica os resultados desse problema? Você poderia generalizar sua conclusão?
- 2.12** a. Quantas chaves possíveis a cifra Playfair possui? Ignore o fato de que algumas chaves poderiam produzir resultados de encriptação idênticos. Expresse sua resposta como uma potência aproximada de 2.
b. Agora leve em conta o fato de que algumas chaves Playfair produzem os mesmos resultados de encriptação. Quantas chaves efetivamente exclusivas a cifra Playfair possui?
- 2.13** Que sistema de substituição resulta quando usamos uma matriz Playfair de 25×1 ?
- 2.14** a. Encripte a mensagem “meet me at the usual place at ten rather than eight oclock” usando a cifra de Hill com a chave $\begin{pmatrix} 9 & 4 \\ 5 & 7 \end{pmatrix}$. Mostre seus cálculos e o resultado.
b. Mostre os cálculos para a decrptação correspondente do texto cifrado a fim de recuperar o texto claro original.
- 2.15** Mostramos que a cifra de Hill sucumbe perante um ataque de texto claro conhecido se forem fornecidos suficientes pares de texto claro/texto cifrado. É ainda mais fácil de solucionar a cifra de Hill se um ataque de texto claro escolhido puder ser montado. Descreva esse ataque.
- 2.16** Pode-se mostrar que a cifra de Hill com a matriz $\begin{pmatrix} a & b \\ c & d \end{pmatrix}$ exige que $(ad - bc)$ seja relativamente primo de 26; ou seja, o único fator positivo comum entre $(ad - bc)$ e 26 é 1. Assim, se $(ad - bc) = 13$ ou se for par, a matriz não é permitida. Determine o número de chaves diferentes (boas) que existem para uma cifra de Hill 2×2 sem contá-las uma a uma, usando as seguintes etapas:
- a. Descubra o número de matrizes cujo determinante seja par porque uma ou ambas as linhas são pares. (Uma linha é “par” se as duas entradas na linha forem pares.)

- b. Descubra o número de matrizes cujo determinante é par porque uma ou ambas as colunas são pares. (Uma coluna é “par” se as duas entradas na coluna forem pares.)
- c. Descubra o número de matrizes cujo determinante é par porque todas as entradas são ímpares.
- d. Levando em conta as sobreposições, descubra o número total de matrizes cujo determinante é par.
- e. Descubra o número de matrizes cujo determinante é um múltiplo de 13 porque a primeira coluna é um múltiplo de 13.
- f. Descubra o número de matrizes cujo determinante é um múltiplo de 13, em que a primeira coluna não é um múltiplo de 13, mas a segunda é um múltiplo do primeiro módulo 13.
- g. Descubra o número total de matrizes cujo determinante é um múltiplo de 13.
- h. Descubra o número de matrizes cujo determinante é um múltiplo de 26 porque elas se ajustam aos casos (a) e (e), (b) e (e), (c) e (e), (a) e (f), e assim por diante.
- i. Descubra o número total de matrizes cujo determinante não é um múltiplo de 2 nem um múltiplo de 13.

2.17 Calcule o determinante mod 26 de

a. $\begin{pmatrix} 2 & 2 \\ 5 & 4 \end{pmatrix}$

b. $\begin{pmatrix} 1 & 7 & 22 \\ 4 & 9 & 2 \\ 1 & 2 & 5 \end{pmatrix}$

2.18 Determine o inverso mod 26 de

a. $\begin{pmatrix} 2 & 3 \\ 1 & 22 \end{pmatrix}$

b. $\begin{pmatrix} 6 & 24 & 1 \\ 13 & 16 & 1 \\ 2 & 17 & 15 \end{pmatrix}$

2.19 Usando a cifra de Vigenère, encripte a palavra “explanation” usando a chave *leg*.

2.20 Este problema explora o uso de uma versão do *one-time pad* da cifra de Vigenère. Nesse esquema, a chave é um fluxo de números aleatórios entre 0 e 26. Por exemplo, se a chave for 3 19 5..., então a primeira letra do texto claro é encriptada com um deslocamento de três letras, a segunda com um deslocamento de 19 letras, a terceira com um deslocamento de cinco letras, e assim por diante.

- a. Encripte o texto claro *sendmoremoney* com o fluxo de chaves

9 0 1 7 23 15 21 14 11 11 2 8 9

- b. Usando o texto cifrado produzido na parte a, encontre uma chave, de modo que o texto cifrado seja decifrado para o texto claro *cashnotneeded*.

Problemas de programação

- 2.22** Elabore um programa que possa encriptar e decifrar usando a cifra de César geral, também conhecida como cifra aditiva.
- 2.23** Elabore um programa que possa encriptar e decifrar usando a cifra afim, descrita no Problema 2.1.
- 2.24** Elabore um programa que possa realizar um ataque de frequência de letra em uma cifra aditiva sem intervenção humana. Seu software deverá produzir textos claros possíveis em ordem aproximada de probabilidade. Seria bom se a sua interface com o usuário permitisse que ele especificasse “mostre os 10 textos claros mais prováveis”.
- 2.25** Escreva um programa que possa realizar um ataque de frequência de letra em qualquer cifra de substituição mono-alfabética sem intervenção humana. Seu software deverá produzir textos claros possíveis em ordem aproximada de probabilidade. Seria bom se a sua interface com o usuário permitisse que ele especificasse “mostre os 10 textos claros mais prováveis”.
- 2.26** Crie um software que possa encriptar e decifrar usando uma cifra de Hill 2×2 .
- 2.27** Crie um software que possa realizar um ataque rápido de texto claro conhecido sobre uma cifra de Hill, dada a dimensão m . Qual a velocidade dos seus algoritmos, como uma função de m ?